Elektronische Gesundheitskarte und Telematikinfrastruktur

Spezifikation
Sektoraler Identity Provider

Version:	3.3.0
Revision:	1666033
Stand:	16.07.2026
Status:	freigegeben
Klassifizierung:	öffentlich
Referenzierung:	gemSpec_IDP_Sek

Dokumentinformationen

Gender-Hinweis

Aus Gründen der besseren Lesbarkeit wird in diesem Dokument überwiegend die männliche Form verwendet. Sämtliche Personenbezeichnungen gelten gleichermaßen für alle Geschlechter.

Änderungen zur Vorversion

Anpassungen des vorliegenden Dokumentes im Vergleich zur Vorversion können Sie der nachfolgenden Tabelle entnehmen.

Dokumentenhistorie

Version	Stand	Kap./ Seite	Grund der Änderung, besondere Hinweise	Bearbeitung
1.0.0	17.12.21		initiale Version	gematik
2.0.0	02.02.23		Einarbeitung IDP_Maintenance_22.2	gematik
2.0.1	20.02.23		A_23201 und A_23411 in [gemKPT_Betr] überführt	gematik
2.1.0	06.04.23		Einarbeitung IDP_Maintenance_23.1	gematik
2.2.0	01.08.23		Einarbeitung IDP_23.3	gematik
2.3.0	30.01.2024		Einarbeitung ePAfueralle	gematik
2.3.1	05.04.2024		Afo Zuordnung aufgrund von IDP_24_5	gematik
2.4.0	12.06.2024		Einarbeitung IDP_24.3	gematik
2.4.1	22.07.2024		Afo A_22867 hinzugefügt	gematik
2.5.0	16.08.2024		Einarbeitung ePA3.1	gematik
2.6.0	14.02.2025		Einarbeitung IDP_24_10	gematik
3.0.0	07.05.2025		Einarbeitung IDP_25_2 und IDP_25_3	gematik
3.1.0	14.08.202		Einarbeitung IDP_25_5	gematik

	5			
3.1.1	11.09.2025		Hotfix IDP_25_5-1 (C_12392 Verhinderung doppelter Konsenteinholung bei ePA-FdV SSO)	gematik
3.1.2	14.10.2025		Anpassung der A_27713	gematik
3.2.0	14.11.2025		Einarbeitung IDP_25_6	gematik
3.3.0	10.07.2026		Einarbeitung IDP_26_1	gematik

Inhaltsverzeichnis

1 Einordnung des Dokumentes....6
1.1 Zielsetzung....6
1.2 Zielgruppe....6
1.3 Geltungsbereich....6
1.4 Abgrenzungen....6
1.5 Methodik....7
2 Systemkontext....8
3 Übergreifende Festlegungen....9
3.1 Sicherheitsanforderungen für den operativen Betrieb....10
3.2 Vertrauenswürdige Ausführungsumgebung....14
3.2.1 Verarbeitungskontext....17
3.2.2 Ausschluss von nicht autorisierten Zugriffen aus dem Betriebsumfeld....19
3.2.3 Konsistenz des Systemzustands, Logging und Monitoring....23
3.3 Betriebliche Unterstützung des Probings....23
4 Funktionsmerkmale....25
4.1 Allgemeine Anforderungen an Teilnehmer der TI-Föderation....25
4.2 Entity Statement des sektoralen IDP....25
4.3 API-Endpunkte des sektoralen IDP....29
4.3.1 Anforderung an die Schnittstelle zum Authorization Server des Fachdienstes..29
4.3.2 PAR - Endpunkt....30
4.3.2.1 PAR-Endpunkt Eingangsdaten....31
4.3.2.2 PAR-Endpunkt Ausgangsdaten....32
4.3.3 Authorization-Endpunkt....32
4.3.3.1 Schnittstelle Authorization-Endpunkt....32
4.3.3.2 Authorization-Endpunkt Ausgangsdaten....32
4.3.4 Token-Endpunkt....33
4.3.4.1 Token-Endpunkt Eingangsdaten....33
4.3.4.2 Token-Endpunkt Ausgangsdaten....33
4.4 Identifizierung und Authentifizierung des Nutzers....38
4.4.1 Identifikation des Nutzers....39
4.4.2 Authentifizierungsverfahren....40
4.4.2.1 Gerätenutzung....45
4.4.2.2 Nutzung von Biometrie....47
4.4.2.3 Unterstützung Single-Sign-On (SSO) auf Anwendungsebene....49
5 Anforderungen an Authenticator-Module sektoraler IDP....52
5.1 Funktionsmerkmale Authenticator-Modul....52
5.2 Single-Sign-On (SSO) auf Anwendungsebene....56
5.2.1 Überblick....57

5.2.2 Rahmenbedingungen....57
5.2.3 SSO auf Anwendungsebene ePA-FdV....60
5.3 Verwaltung eGK....60
5.3.1 PIN der eGK ändern....61
5.3.2 PIN der eGK entsperren....63
5.4 Authenticator-Modul für Desktop-Plattformen Anwendungen....66
6 Anhang A – Verzeichnisse....69
6.1 Abkürzungen....69
6.2 Glossar....69
6.3 Abbildungsverzeichnis....70
6.4 Tabellenverzeichnis....70
6.5 Referenzierte Dokumente....70
6.5.1 Dokumente der gematik....70
6.5.2 Weitere Dokumente....71
7 Anhang B - Abläufe....74
8 Anhang C - Möglicher Aufbau einer VAU (informativ)....75
8.1 Standalone....75
8.1.1 Load Balancer....77
8.1.2 Anwendungsserver und zugehörige Infrastruktur....77
8.1.3 Vernetzung Load-Balancer/VAU-Server....78
8.1.4 Vernetzung VAU-Server/HSM....78
8.1.5 Vernetzung VAU-Server/Datenbankserver....78
8.1.6 Vernetzung des Management Interface mit dem internen Netz des Anbieters des sektoralen IDP....79
8.1.7 VAU-Server....79
8.1.8 VAU-Server Software Stack....79
8.1.9 Open Source Software Stack....80
8.1.10 Attestation und Integritätsschutz für VAU-Server....80
8.1.11 HSM....81
8.1.12 Datenbank....81
8.1.13 Repository....81
9 Anhang D - Verfahrensbeschreibung zur Migration nicht abwärtskompatibler Änderungen in der TI-Föderation....82

1 Einordnung des Dokumentes

1.1 Zielsetzung

Die vorliegende Spezifikation definiert die Anforderungen zu Herstellung, Test und Betrieb des Produkttyps sektoraler Identity Provider (IDP). Ein sektoraler IDP basiert auf den Standards OpenID Connect (OIDC), Open Authorization 2.0 (OAuth 2) und JSON Web Token (JWT). Die hier beschriebenen Schnittstellen werden vom Authenticator-Modul und von Clients zur Authentifikation eines Nutzers genutzt. Diese Authentifikation ist die Voraussetzung, damit ein Client Zugang zu Fachdaten und Prozessen eines Fachdienstes erlangen kann. Ein sektoraler IDP verwaltet und steuert denAuthentifizierungsprozess für Anwendungen der Telematikinfrastruktur (TI).

1.2 Zielgruppe

Das Dokument richtet sich an Hersteller und Anbieter von Identity Providern, die die Funktionen eines sektoralen IDP für die TI realisieren wollen.

1.3 Geltungsbereich

Dieses Dokument enthält normative Festlegungen zur TI des deutschen Gesundheitswesens. Der Gültigkeitszeitraum der vorliegenden Version und deren Anwendung in Zulassungs- oder Abnahmeverfahren wird durch die gematik GmbH in gesonderten Dokumenten (z. B. gemPTV_ATV_Festlegungen, Produkttypsteckbrief, Leistungsbeschreibung) festgelegt und bekanntgegeben.

Schutzrechts-/Patentrechtshinweis

Die nachfolgende Spezifikation ist von der gematik allein unter technischen Gesichtspunkten erstellt worden. Im Einzelfall kann nicht ausgeschlossen werden, dass die Implementierung der Spezifikation in technische Schutzrechte Dritter eingreift. Es ist allein Sache des Anbieters oder Herstellers, durch geeignete Maßnahmen dafür Sorge zu tragen, dass von ihm aufgrund der Spezifikation angebotene Produkte und/oder Leistungen nicht gegen Schutzrechte Dritter verstoßen und sich ggf. die erforderlichen Erlaubnisse/Lizenzen von den betroffenen Schutzrechtsinhabern einzuholen. Die gematik GmbH übernimmt insofern keinerlei Gewährleistung.

1.4 Abgrenzungen

Die konkrete Umsetzung der Authentifizierung eines Nutzers durch einen sektoralen IDP ist nicht Bestandteil des vorliegenden Dokumentes.

Als Umsetzungsleitlinie ist [OpenID Connect Core 1.0] heranzuziehen sowie das Kapitel [4.4.2- Authentifizierungsverfahren]. Die TI-weit übergreifenden Festlegungen –

insbesondere aus Dokumenten wie beispielsweise [gemSpec_Krypt] bezüglich Algorithmen und Schlüsselstärken sowie [gemSpec_PKI] bezüglich zu verwendender Zertifikatstypen und deren Attributausprägungen – haben Bestand, sind weiterhin bindend und werden nicht in diesem Dokument beschrieben. Die konkreten, für das Produkt relevanten Anforderungen finden sich in den entsprechenden Steckbriefen.

1.5 Methodik

Anforderungen als Ausdruck normativer Festlegungen werden durch eine eindeutige ID in eckigen Klammern sowie die dem [RFC2119] entsprechenden, in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS, DARF NICHT, SOLL, SOLL NICHT, KANN gekennzeichnet.

Sie werden im Dokument wie folgt dargestellt:
<AFO-ID> - <Titel der Afo>
Text / Beschreibung
[<=]

Dabei umfasst die Anforderung sämtliche zwischen Afo-ID und der Textmarke [<=] angeführten Inhalte.

Hinweis auf offene Punkte

Offener Punkt: Das Kapitel wird in einer späteren Version des Dokumentes ergänzt.

2 Systemkontext

In [gemKPT_TI-Föderation] ist das Konzeptes zur TI-Föderation hinsichtlich Motivation, Architektur und Beispielen ausführlich beschrieben. Für den Überblick über das Gesamtsystem sowie über Akteure, Rollen, Schnittstellen und Abläufe wird deshalb auf dieses Dokument verwiesen.

3 Übergreifende Festlegungen

Der sektorale IDP muss die folgenden übergreifenden Anforderungen erfüllen.

A_22838 -Entgegennahme von Sperrmeldungen
Der Anbieter des sektoralen IDP MUSS Sperrmeldungen von Sperrberechtigten, zu von ihm verantworteten Authentisierungsmitteln, jederzeit entgegennehmen und das betroffene Authentisierungsmittel oder auch den gesamten Zugang des Nutzers daraufhin unverzüglich sperren.**[<=]**

Hinweis: Dies bezieht sich nicht auf für eine Authentisierung verwendete elektronische Gesundheitskarte (eGK) oder denelektronischen Identitätsnachweis (Online-Ausweisfunktion).

Hinweis: Grundsätzlich sollte eine effektive Sperrung so schnell wie möglich erfolgen (siehe auch TR 03107-1 Kap. 3.4.1).

A_22690 -Darstellen der Voraussetzungen für sicheren Betrieb des Produkts im Betriebshandbuch
Der Hersteller des sektoralen IDP MUSS für sein Produkt im dazugehörigen Betriebshandbuch leicht ersichtlich darstellen, welche Voraussetzungen vom Betreiber und der Betriebsumgebung erfüllt werden müssen, damit ein sicherer Betrieb des Produktes gewährleistet werden kann.**[<=]**

A_22691 -Sicherer Betrieb des Produkts nach Betriebshandbuch
Der Anbieter eines sektoralen IDP MUSS die im Betriebshandbuch des eingesetzten sektoralen IDP beschriebenen Voraussetzungen für den sicheren Betrieb des Produktes gewährleisten.**[<=]**

A_23044 -Unterstützung von Diensten außerhalb der TI
Der Anbieter des sektoralen IDP KANN die Anmeldung an weiteren Diensten außerhalb der Föderation unterstützen und diesen die Authentisierung von Nutzern auf Basis der bestehenden digitalen Identitäten anbieten.**[<=]**

A_23337-01 -Mindestvorgaben für Schlüssel von sektoralen IDPs als Teilnehmer der TI-Föderation
Ein sektoraler IDP als Teilnehmer der TI-Föderation MUSS bei dem eingesetzten Schlüsselmaterial (Signatur, mTLS Clientzertifikat, Entity Statement, etc.), folgende Vorgaben umsetzen:

1. Alle verwendeten Schlüssel MÜSSEN ein Sicherheitsniveau von 120 Bit ermöglichen (vgl. [gemSpec_Krypt#5 "Migration 120-Bit Sicherheitsniveau"]).
2. Alle ECC-Schlüssel MÜSSEN auf einem folgenden der Domainparameter (Kurven) basieren:
   a. P-256 oder P-384 [FIPS-186-4]

[<=]

3.1 Sicherheitsanforderungen für den operativen Betrieb

A_22239 -Schützenswerte Objekte
Der Anbieter eines sektoralen Identity Provider MUSS die folgenden kryptographischen Objekte als schützenswerte Objekte in seinem Sicherheitskonzept berücksichtigen: (a) Private Schlüssel, (b) Öffentlicher Schlüssel, (c) Öffentliche Schlüssel von registrierten Clients, (d) Datensätze zu den einzelnen Nutzern, (e) Authentisierungsinformationen von Sperrberechtigten, (f) Dokumentation über beauftragte und durchgeführte Sperrungen, (g) Statusinformationen, (h) Authentisierungsinformationen zur Authentisierung von internen Akteuren bzw. Rollen, (i) Protokolldaten, (j) Konfigurationsdaten.**[<=]**

A_22240 -Berücksichtigung OWASP-Top-10-Risiken
Der Anbieter des sektoralen Identity Provider MUSS Maßnahmen zum Schutz vor den zum Zulassungszeitpunkt aktuellen OWASP-Top-10-Risiken umsetzen und dokumentieren, wie es vorgesehen ist, ebenfalls auf die nach dem Zulassungszeitpunkt aktuellen OWASP-Top-10-Risiken zu reagieren.**[<=]**

Hinweis: Die Nichtanwendbarkeit eines OWASP-Top-10-Risikos ist zu begründen. Für Informationen zum Umgang mit den OWASP-Top-10-Risiken wird auf den aktuellen [OWASP Top Ten] und die darin enthaltenen Vorgehensweisen für z. B. Entwickler und Tester verwiesen.

A_22241 -Interner Datenaustausch der Komponenten des sektoralen Identity Provider
Der Anbieter eines sektoralen Identity Provider MUSS beim internen Datenaustausch die Integrität, Authentizität und Vertraulichkeit der Daten sichern.**[<=]**

A_22242-01 -Gesicherte externe Schnittstellen des sektoralen Identity Provider
Der Anbieter eines sektoralen Identity Provider MUSS für den Datenaustausch mit anderen Rollen und Diensten Mechanismen zur Sicherung der Datenintegrität, der Authentizität und der Vertraulichkeit der Daten zur Verfügung stellen. Hierzu gehören z. B. die Schnittstellen vom Anbieter eines sektoralen Identity Provider zur Attributbestätigenden Stelle für die Übermittlung der Attribute bei der Einrichtung eines Nutzers sowie von Supportfälle.
[<=]

Hinweis: Eine Übersicht zu den externen Schnittstellen findet sich in der Tabelle "Schnittstellenübersicht".

Hinweis: Die Attributbestätigende Stelle (z. B. der Kostenträger für Versicherte) verantwortet die Korrektheit dieser Daten.

A_22243-02 -Nutzung bestehender Datensätze bei Registrierung für Endanwender (Versicherte)
Der Anbieter des sektorale Identity Provider SOLL für die Registrierung der Endanwender die bestehenden Datensätze der Endanwender (Versicherte) beim Kostenträger verwenden, so wie sie für eine Identifikation nach [GKV-SV Richtlinie "Kontakt mit Versicherten] beschrieben wurden.**[<=]**

A_22244 -Trennung der Betriebsumgebungen
Der Anbieter eines sektoralen Identity Provider MUSS sicherstellen, dass das Testsystem von dem Produktivsystem technisch, organisatorisch und betrieblich so getrennt wird, dass keine gegenseitige Beeinflussung und keine Verwechslung möglich sind.**[<=]**

A_22245 -Datenschutzgerechte Einrichtungs- und Sperrprozesse
Der Anbieter eines sektoralen Identity Provider MUSS die Einrichtungs- und Sperrprozesse datenschutzgerecht ausgestalten, d.h. insbesondere sind für die Verarbeitung der Antrags- und Sperrauftragsdaten die Datenschutzgrundsätze gemäß Art. 5 DSGVO zu berücksichtigen, sowie die technischen und organisatorischen Maßnahmen nach Art. 25 und Art. 32 DSGVO zu treffen.**[<=]**

A_22246 -Löschung von Nutzerinformationen

Der Anbieter eines sektoralen Identity Provider MUSS die Attributsdaten und Sperraufträge zu einem Nutzer unverzüglich löschen, sobald die gesetzlichen oder vertraglichen Aufbewahrungsfristen erreicht sind.**[<=]**

A_22839 -Fehlerprotokollierung
Falls der Anbieter eines sektoralen IDP eine Protokollierung zum Zwecke der Fehler- bzw. Störungsbehebung durchführen muss, MÜSSEN die Protokolldaten entsprechend dem Datenschutzgrundsatz der Datenminimierung (gemäß Art. 5 Abs. 1 Satz 1 lit.c DSGVO unter Berücksichtigung der Art. 25, 32 DSGVO) derart gestaltet sein, dass nur personenbezogene Daten in der Art und dem Umfang enthalten sind, wie sie zur Behebung erforderlich sind. Insbesondere MUSS der Anbieter eines sektoralen IDP sicherstellen, dass ein Bezug zwischen Nutzer und Fachdienst aus den Protokollen nicht ersichtlich sein.**[<=]**

Hinweis: Eine Protokollierungspflicht besteht nicht.

Hinweis: Sollte es zur Störungsbehebung notwendig sein, eine Fachdienstanfrage und Nutzerauthentisierung zu korrelieren, kann der sektorale IDP zu diesem Zweck die durch den Fachdienst für diesen Fall auf organisatorischem Weg zu liefernde "nonce" der Anfrage nutzen.

A_23021 -Trennung von Diensten der Föderation und weiteren unterstützten Anwendungen
Wenn der Anbieter eines sektoralen Identity Providers die Anmeldung an weiteren Dienste außerhalb der Föderation unterstützt, MUSS sichergestellt sein, dass die Anforderungen an Verfügbarkeit, Performance und Sicherheit der Schnittstellen für Fachdienste der Föderation erfüllt werden.**[<=]**

A_23023 -Sicherung externen Schnittstellen gegen bösartige Eingaben
Der sektorale IDP MUSS sicherstellen, dass alle Eingabewerte, welche vom sektoralen IDP über externe Schnittstellen (siehe Tabelle "*Schnittstellenübersicht*") entgegengenommen und verarbeitet werden, auf schadhafte Werte geprüft werden.
[<=]

Hinweis: Eine Prüfung der Eingabewerte muss produktseitig bereitgestellt werden und sollte mindestens Prüfungen auf Länge, Character Set, Schlüsselwörter und Steuerzeichen enthalten. Ein Fuzzing im Rahmen des Produkttests bzw. der Inbetriebnahme ist durchzuführen.

A_23022 -Prozesse zum Ändern oder Löschen von Daten der Authentisierungsprozesse
Werden Daten der Authentisierungsprozesse im sektoralen IDP ohne direkte Beteiligung des Nutzers geändert oder gelöscht, MUSS der Anbieter des sektoralen IDP sicherstellen, dass die operativen Prozesse hierfür ausschließlich im 4-Augen-Prinzip durchgeführt werden. Der Nutzer MUSS über die Änderungen informiert werden und die Änderung MUSS erkennbar sein.
[<=]

Hinweis: Serviceprozesse, die der Nutzer über den Support in Anspruch nimmt (z. B. Passwort ändern/rücksetzen) sind von dieser Anforderung nicht betroffen.

A_23499 -Prozesse zum Ändern oder Löschen von personenbezogenen Daten
Werden personenbezogene Daten im sektoralen IDP geändert oder gelöscht, ohne dass der Betroffene direkt involviert ist, so MUSS der Anbieter des sektoralen IDP sicherstellen, dass die operativen Prozesse dazu ausschließlich im 4-Augen-Prinzip ausgeführt werden. Der Nutzer ist über die Änderungen zu informieren. Personenbezogene Daten, die über den Synchronisationsprozess mit den Kassensystemen geändert oder gelöscht werden, sind von diesem operativen Prozess nicht betroffen.**[<=]**

Hinweis: Im Regelfall erfolgen solche Datenänderungen in den Bestandsystemen der Krankenkassen, die über Synchronisationsprozesse den Datenbestand des sektoralen IDP

aktualisieren. Hier erfolgt die Information an die Versicherten allein über die kassenüblichen Prozesse.

A_22824 -Verhalten bei Vollauslastung
Der Anbieter eines sektoralen Identity Provider MUSS den Dienst so konfigurieren, dass bei Vollauslastung der Systemressourcen im sektoralen Identity Provider keine weiteren Verbindungen angenommen werden und dieser stattdessen mit dem HTTP-Statuscode "429 - Too Many Requests" antwortet.**[<=]**

Hinweis: Durch die Zurückweisung von Verbindungen wird sichergestellt, dass Clients einen Verbindungsaufbau mit einer anderen Instanz des Dienstes versuchen, bei der die erforderlichen Systemressourcen zur Verfügung stehen.

A_22692 -Kriterien für die Standortwahl von Rechenzentren
Der Anbieter des sektoralen IDP MUSS nachweisen, dass er die aktuellen Empfehlungen des BSI bei der Standortwahl seiner Rechenzentren vollumfänglich umsetzt. Der Anbieter des sektoralen IDP MUSS Unterschreitungen der Empfehlungen des BSI begründen und die Abmilderung der Risiken begründet nachweisen. Der Anbieter des sektoralen IDP MUSS einen Prozess für die Umsetzung zukünftige Empfehlungen des BSI bei der Standortwahl seiner Rechenzentren nachweisen.**[<=]**

Hinweis: Weitere Informationen finden Sie unter: [https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/RZ-Sicherheit/Standort-Kriterien_Rechenzentren.pdf].

A_22250 -Schutz der Verbindung zum sektoralen Identity Provider
Der Anbieter eines sektoralen Identity Provider MUSS sicherstellen, dass die Schnittstellen des sektoralen Identity Provider nur über eine gegen Abhören, Manipulation und Replay-Angriffe geschützte Verbindung genutzt werden können.**[<=]**

Hinweis: Eine Übersicht zu den Schnittstellen findet sich in der Tabelle "Schnittstellenübersicht".

A_22512 -Schutz der Schnittstellen des sektoralen Identity Provider ins Internet
Der Anbieter eines sektoralen IDP MUSS sicherstellen, dass seine Schnittstellen ins Internet an allen Standorten durch einen DDoS-mitigierenden Dienstleister geschützt werden.**[<=]**

Hinweis: Die Informationen zu den Empfehlungen des BSI sind zu berücksichtigen:
[https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Cyber-Sicherheit/Themen/Dienstleister-DDos-Mitigation.html]
[https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Cyber-Sicherheit/Themen/Dienstleister-DDos-Mitigation-Liste.pdf]

A_23099 -Datenverarbeitung innerhalb der Europäischen Union
Der Anbieter eines sektoralen IDP MUSS im Sinne der vollständigen DSGVO-Konformität sicherstellen, dass die Datenverarbeitung innerhalb der Europäischen Union erfolgt und dieses auch nachweisen.**[<=]**

A_22694 -Georedundanz des sektoralen Identity Provider
Der Anbieter des sektoralen Identity Provider MUSS diesen an mindestens zwei Standorten betreiben.
Jeder Standort MUSS dabei die Performancevorgaben allein erfüllen.
Eine getrennte Adressierung durch zugreifende Anwendungsfrontends und Fachdiensten MUSS hierdurch möglich sein - alternativ ist diese Adressierung auch durch den DDoS-mitigierenden Dienstleister erlaubt.
[<=]

Hinweis: Ein Aktiv-Aktiv Betrieb der beiden Standorte ist nicht gefordert, entscheidend ist die Sicherstellung der Verfügbarkeit.

A_22695 -Mindestabstand für Georedundanz des sektoralen Identity Provider
Ab dem 31.12.2023 MUSS der Anbieter des sektoralen Identity Provider seinen Dienst an zwei Standorten gemäß A_22692 betreiben, wobei eine Unterschreitung des Abstandes von 100 km gemäß A_22692 nicht zulässig ist.**[<=]**

A_22506-01 -Unabhängiges Bedienpersonal pro Standort des sektoralen Identity Provider
Der Anbieter des sektoralen Identity Provider MUSS pro Standort ein unabhängiges Bedienpersonal vorhalten, um die Risiken der Standortvorgaben des BSI tragen zu können.**[<=]**

A_22508 -Ausschluss von nicht erlaubten Authenticator-Modul Versionen (Rohdatenerfassung v.02)
Der sektorale Identity Provider MUSS von ihm nicht erlaubte Authenticator-Module (anhand der Versionsnummern) ablehnen, von einer Kommunikation mit dem sektoralen Identity Provider ausschließen und diesen Verbindungsversuch mit dem Status-Code 79105 in den Rohdaten protokollieren.**[<=]**

A_22509 -Ausschluss bei fehlenden Authenticator-Modul Versionsnummern (Rohdatenerfassung v.02)
Der sektorale Identity Provider MUSS Authenticator-Module mit fehlenden Versionsnummern ablehnen, von einer Kommunikation mit dem sektoralen Identity Provider ausschließen und diesen Verbindungsversuch in den Rohdaten mit dem Error-Code 403 protokollieren.**[<=]**

A_22931 -Zu verwendende Produktversion in der Kommunikation zum IDP
Das Authenticator-Modul MUSS in Requests an den IDP seine Produktversion übermitteln. **[<=]**

A_22253 -Ausschluss bestimmter Authenticator-Modul Versionen von der Kommunikation
Der sektorale Identity Provider MUSS die vom Authenticator-Modul mitgeteilte Versionsnummer erkennen und festgelegte Versionsnummern über eine blockinglist von einer Kommunikation ausschließen können.**[<=]**

A_22254-01 -Ausschluss von Authenticator-Modul Versionen (Rohdatenerfassung v.02)
Der sektorale Identity Provider MUSS auf Anweisung der gematik Authenticator-Module mit bestimmten Versionsnummern von einer Kommunikation mit dem sektoralen Identity Provider ausschließen und diesen Verbindungsversuch in den Rohdaten protokollieren. **[<=]**

Hinweis: Im Regelprozess sichert der Betreiber in Eigenverantwortung zu, dass nur unterstützte und sichere Versionen des Authenticator-Moduls mit den Serverkomponenten des Sektoralen IDP kommunizieren dürfen.
Bei dieser Anforderung handelt es sich um eine betriebliche Eskalation im Notfall und nicht um einen Regelprozess.

A_23192 -Maximale Verwendungsdauer für Schlüssel
Der Anbieter des sektoralen Identity Provider MUSS Schlüsselpaare welche zur Signatur von Entity Statements bzw. ID Token oder zur TLS-Authentisierung verwendet werden, nach maximal398 Tagen austauschen.**[<=]**

Hinweis: Für TLS Schlüssel ist dies konsistent zu den aktuellen Vorgaben des CAB-Forum.

3.2 Vertrauenswürdige Ausführungsumgebung

In diesem Abschnitt werden die Anforderungen an den sektoralen IDP zur Umsetzung einer Vertrauenswürdigen Ausführungsumgebung (VAU) dargestellt. Die VAU dient der datenschutzrechtlich zulässigen und sicheren Verarbeitung von schützenswerten Klartextdaten innerhalb des sektoralen IDP sowie dem technischen Ausschluss einer Profilbildung durch den Anbieter bzw. Betreiber. Sie verhindert ein Eingreifen des Anbieters in den sicheren Betrieb und die Manipulation von Daten. Die VAU stellt dazu Verarbeitungskontexte (d. h. Instanzen der VAU) bereit, in denen die Verarbeitung sensibler Daten im Klartext erfolgen kann. Diese Verarbeitungskontexte sind entsprechend zu schützen. Durch diese Ausgrenzung des Betreibers von kritischen Operationen ist es nicht mehr notwendig Einschränkungen für den Umfang der weiteren durch den Anbieter bzw. Betreiber bereitgestellten Dienste umzusetzen, um möglichen Interessenkonflikten zu begegnen. Im Anhang C ist u.a. ein [Beispiel für eine RZ-Lösung einer VAU] beschrieben.

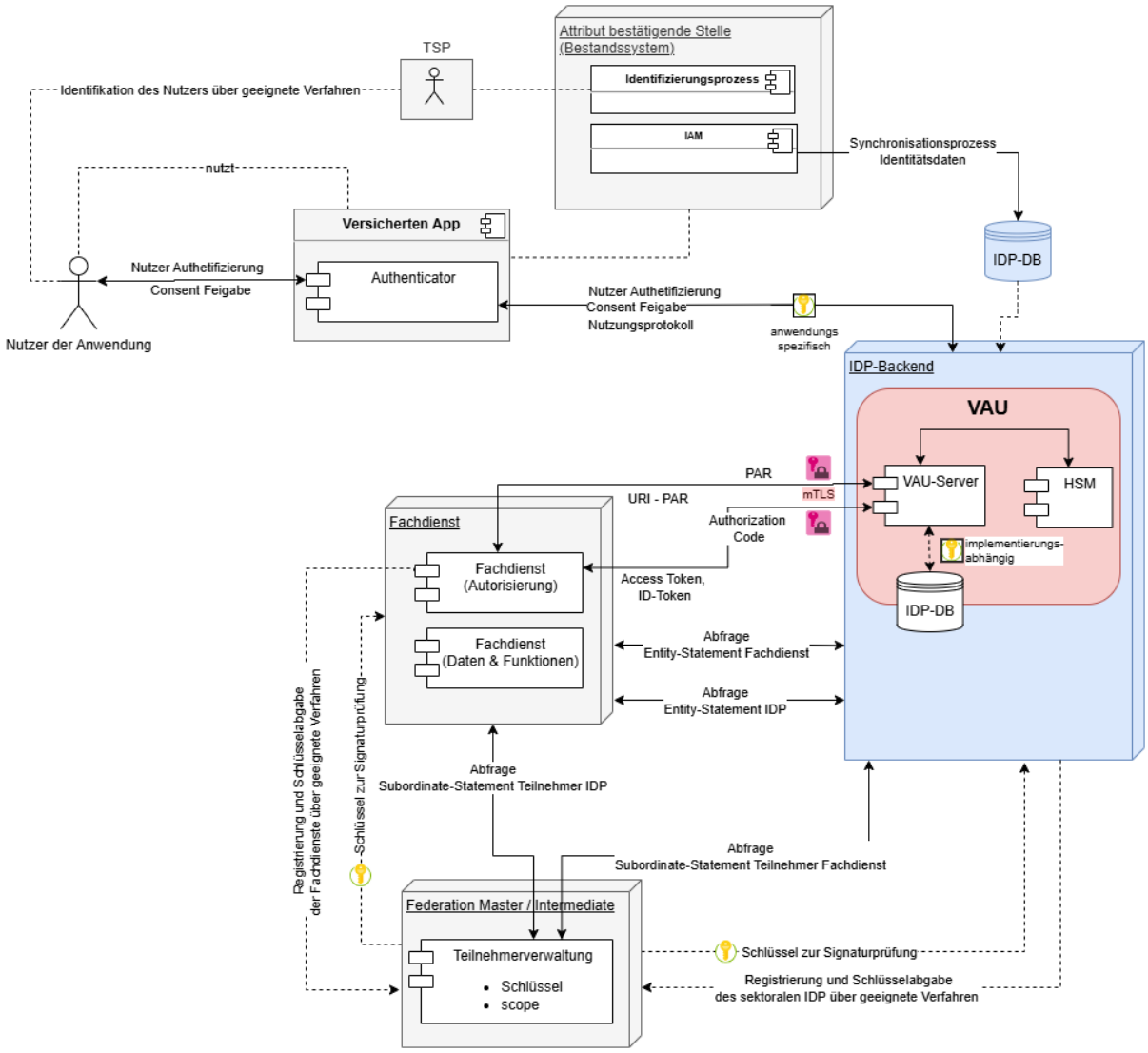


Abbildung 1: Schnittstellen der in der VAU laufenden Komponente des sektoralen IDP

Tabelle 1: Vorgaben für die im sektoralen IDP befindlichen Endpunkte zur Ausführung in einer VAU

Schnittstelle	Gegenstelle	Beschreibung	VAU Ausführung
Pushed Authorization Request (PAR)	Fachdienst Authorization Server	Der Pushed Authorization Request enthält Informationen zum anfragenden Fachdienst und zum Scope der angeforderten Daten des Nutzers.	zwingend
Einlösen des Authorization Code	Fachdienst Authorization Server	Der Token-Request zum Einlösen des Authorization Code enthält Informationen zum Fachdienst. Der Response auf den Request enthält Informationen zum Nutzer.	zwingend
Abruf selbstsigniertes Entity Statement	Fachdienst Authorization Server	Der Fachdienst bezieht die Konfigurationsparameter, Adressen und Schlüssel des sektoralen IDP	optional
Abruf Subordinate Statement zur Teilnehmerauskunft	Federation Master	Der Schlüssel des Federation Master zum Verifizieren der von diesem signierten Subordinate Statements wird sicher verwahrt.	optional
Authentifizierung	Authenticator-Modul auf Endgerät des Nutzers	Die Ausprägung der Schnittstelle kann anwendungsspezifisch gestaltet werden.	optional
Consent-Freigabe und Initialer Authorization Request	Authenticator-Modul auf Endgerät des Nutzers	Es muss nachprüfbar gewährleistet sein, dass der Betreiber des sektoralen IDP keinen Zugriff auf die über die Schnittstelle transportierten Inhalte bezüglich des Anfragenden Dienstes	zwingend

		erlangen kann.	
Aktualisierung der Identitätsdaten im sektoralen IDP	Anwendungssystem, welchen die Identitäten der Versicherten verwaltet (Attributbestätigende Stelle)	Die Aktualisierung des Datenbestandes des sektoralen IDP erfolgt durch das Bestandssystem der jeweiligen attributbestätigenden Stelle.	optional
Ablage und Abfrage der vom sektoralen IDP verwalteten schützenswerten Prozessdaten der Nutzerauthentifizierung	Datenbank für Prozessdaten der VAU	Die vom sektoralen IDP verwalteten schützenswerten Daten liegen verschlüsselt in einer Datenbank auf welche nur aus einer VAU zugegriffen werden kann. Die Datenbank kann innerhalb oder außerhalb der VAU betrieben werden. Bei einem Betrieb außerhalb der VAU muss gewährleistet sein, dass der Betreiber des sektoralen IDP keinen Zugriff auf die über die Schnittstelle transportierten Inhalte hat. *Hinweis: Schützenswerte Daten im Kontext der sektoralen IDP sind die Daten, welche innerhalb der VAU zum laufenden Authentifizierungsprozess erzeugt bzw. gespeichert werden (`client_id`, `state`, `redirect_uri`, `code_challenge`, `AUTHORIZATION_CODE`, `ID_TOKEN`), sowie die Daten für das Nutzerprotokoll.*	optional

3.2.1 Verarbeitungskontext

Die Gesamtheit aus der für eine Klartextverarbeitung erforderlichen Software, dem für eine Klartextverarbeitung genutzten physikalischen System sowie den für die Integrität einer Klartextverarbeitung erforderlichen organisatorischen und physischen Rahmenbedingungen bildet den Verarbeitungskontext der Vertrauenswürdigen

Ausführungsumgebung (VAU). Zur Vertrauenswürdigen Ausführungsumgebung gehören neben den Verarbeitungskontexten alle für ihre Erreichbarkeit und betriebliche Steuerung erforderlichen Komponenten. Der Verarbeitungskontext grenzt sich von allen weiteren, im betrieblichen Kontext beim Anbieter des sektoralen IDP vorhandenen Systemen und Prozessen dadurch ab, dass die sensiblen Klartextdaten von Komponenten innerhalb des Verarbeitungskontextes aus erreichbar sind oder sein können, während sie dies von außerhalb des Verarbeitungskontextes nicht sind. Sensible Daten verlassen den Verarbeitungskontext ausschließlich gemäß wohldefinierten (Zugriffs-)Regeln und in verschlüsselter Form.

Umsetzungsempfehlungen für die Realisierung einer Vertrauenswürdigen Ausführungsumgebung finden sich im Anhang C.

Offener Punkt: Die Prüfung der Anforderung an den Betrieb VAU und Umsetzungsvorschläge bzw. -hinweise in cloud-Infrastrukturen sind derzeit in Arbeit. Details dazu werden diesem Kapitel später hinzugefügt.

A_22864 -Umsetzung von Operationen in einer Vertrauenswürdigen Ausführungsumgebung (VAU)
Der sektorale IDP MUSS die Verarbeitung aller Operationen welche die Ziele gemäß [A_23018], [A_23019] und [A_22959] gewährleisten in einer Vertrauenswürdigen Ausführungsumgebung umsetzen. Die HTTP-Verbindungen zwischen Fachdiensten und sektoralem IDP MÜSSEN als mTLS-Verbindungen ausgelegt werden, welche innerhalb der VAU terminieren.**[<=]**

A_23002 -sicherer Betrieb der Vertrauenswürdigen Ausführungsumgebung (VAU)
Der Anbieter des sektoralen IDP MUSS sicherstellen, dass alle Operationen, welche die Ziele gemäß A_23018, A_23019 und A_22959 gewährleisten, in einer vertrauenswürdigen Ausführungsumgebung umgesetzt werden.**[<=]**

A_23018 -Anforderungen an den Schutz vor Profilbildung
- Aus den Daten, welche zum Zweck eines Reporting an die gematik erstellt werden, DARF es NICHT möglich sein, dass eine Zuordnung von Fachdiensten zu einzelnen Authentisierungen oder Nutzern durchgeführt werden kann.
- Die Verknüpfung einer Nutzeridentität / Authentisierung zu einem Fachdienst DARF sowohl für Dritte als auch den Betreiber selbst NICHT einsehbar sein.

[<=]

A_23019 -Anforderungen an den Schutz der Operationen in einer Vertrauenswürdigen Ausführungsumgebung (VAU)
- Sowohl Dritte als auch der Betreiber selbst DARF NICHT Zugriff auf das Schlüsselmaterial der TLS-Verbindungen haben.
- Sowohl Dritte als auch der Betreiber selbst DARF NICHT Zugriff auf die für die Signatur von ID Token verwendeten Schlüssel haben.
- Sowohl Dritte als auch der Betreiber selbst DARF NICHT Zugriff auf die im `AUTHORIZATION_CODE` und in der Request-URI kodierten Informationen haben.

[<=]

Hinweis: Siehe in diesem Zusammenhang auch A_23031 - TLS-Verbindung Authenticator-Modul - Vertrauenswürdige Ausführungsumgebung.

Hinweis: Ein Logging zur Betriebsüberwachung und Fehleranalyse ist zulässig, darf jedoch keine Identifikation des genutzten Fachdienstes zulassen.

A_22959 -Prozess zur Consent-Freigabe durch den Nutzer
Der Anbieter des sektoralen IDP MUSS dafür sorgen, dass der Prozess zur Freigabe des Consent durch den Nutzer verschlüsselt und nicht einsehbar für Dritte oder den Betreiber selbst erfolgt.**[<=]**

3.2.2 Ausschluss von nicht autorisierten Zugriffen aus dem Betriebsumfeld

Der Schutzbedarf der in der VAU verarbeiteten Klartextdaten erfordert den technischen Ausschluss von Zugriffen des Anbieters. Dies umfasst insbesondere Zugriffe durch Personen aus dem betrieblichen Umfeld des Anbieters.

A_22829-01 -Anbieter sektoraler IDP Speicherung Schlüsselmaterial in HSM
Der Anbieter des sektoralen IDP MUSS das private Schlüsselmaterial für kryptografische Verfahren in einem HSM speichern, dessen Eignung durch eine erfolgreiche Evaluierung nachgewiesen wurde. Als Evaluierungsschemata kommen dabei Common Criteria oder Federal Information Processing Standard (FIPS) in Frage.
Die Prüftiefe MUSS mindestens:

1. FIPS 140-2 Level 3 oder
2. FIPS 140-3 Level 3 oder
3. Common Criteria EAL 4+ erweitert um AVA_VAN.5

entsprechen.
[<=]

A_23205 -Prozesse für die Verwaltung des HSM
Der Anbieter des sektoralen IDP MUSS Prozesse für die Verwaltung der Systeme der VAU etablieren, welche die Authentizität und Integrität der Verarbeitungskontexte systematisch von einem kryptographischen Root-of-Trust ableiten, der in einem HSM gemäß A_22829 verwaltet wird.
Der Anbieter des sektoralen IDP MUSS bei der Ableitung ein Vertrauensniveau erreichen, welches für den Schutzbedarf der in der VAU verarbeiteten Daten angemessenen ist und das auf Attestation der genutzten Systeme sowie ggf. auf der Prüfung von Signaturen der geladenen Software inklusive ihrer Konfiguration basiert.
Der Anbieter des sektoralen IDP MUSS für die Verwaltung des Root-of-Trust ein Mehraugenprinzip umsetzen und - soweit für systematischen Ausschluss einseitig durch den Anbieter durchführbarer Manipulationen erforderlich - eine Einbeziehung der gematik vorsehen.
Der Anbieter des sektoralen IDP MUSS der gematik dabei eine Remote-Teilnahme an den erforderlichen Zeremonien ermöglichen.**[<=]**

A_22830 -sektoraler IDP – Verarbeitungskontext der VAU
Der Verarbeitungskontext des sektoralen IDP MUSS sämtliche physikalischen Systemkomponenten sowie sämtliche Softwarekomponenten umfassen, deren Sicherheitseigenschaften sich auf den Schutz der personenbezogenen Daten vor Zugriff durch Unbefugte bei ihrer Verarbeitung im Klartext auswirken können.**[<=]**

A_22840 -Verschlüsselung von außerhalb des Verarbeitungskontextes der VAU gespeicherten Daten

Der Verarbeitungskontext des sektoralen IDP MUSS sicherstellen, dass sämtliche schützenswerten Daten vor einer Speicherung außerhalb der VAU verschlüsselt werden. Dies betrifft auch Daten zu Logging und Protokollierung.**[<=]**

Hinweis: Schützenswerten Daten im Kontext der sektoralen IDP sind die Daten, welche innerhalb der VAU zum laufenden Authentifizierungsprozess erzeugt bzw. gespeichert werden(`client_id`, `state`, `redirect_uri`, `code_challenge`, `AUTHORIZATION_CODE`, `ID_TOKEN`), sowie die Daten für das Nutzerprotokoll.

A_22841 -Schutz der Persistenzschlüssel durch ein HSM
Schlüsselmaterial, dass zur Verschlüsselung von außerhalb des Verarbeitungskontextes der VAU gespeicherten Daten genutzt wird, MUSS entweder durch ein HSM geschützt in den Verarbeitungskontext der VAU eingebracht werden, oder in einem HSM verbleiben. **[<=]**

A_22842 -Bereitstellung Persistenzschlüssel
Das HSM der VAU des sektoralen IDP MUSS eine Schnittstelle zum Abruf symmetrischer Persistenzschlüssel bereitstellen. Erzeugte Schlüssel für die Persistierung der Daten MÜSSEN eineindeutig einem Nutzer zugeordnet sein.**[<=]**

A_22843 -Geschützte Weitergabe von Daten an autorisierte Nutzer durch die VAU
Der Verarbeitungskontext des sektoralen IDP MUSS sicherstellen, dass sämtliche schützenswerten Daten ausschließlich über TLS-gesicherte Verbindungen weitergegeben werden.**[<=]**

Hinweis: Schützenswerten Daten im Kontext der sektoralen IDP sind die Daten, welche innerhalb der VAU zum laufenden Authentifizierungsprozess erzeugt bzw. gespeichert werden (`client_id`, `state`, `redirect_uri`, `code_challenge`, `AUTHORIZATION_CODE`, `ID_TOKEN`), sowie die Daten für das Nutzerprotokoll.

A_22844 -Transportverschlüsselte Übertragung von Daten mit Fachdiensten
Der Verarbeitungskontext des sektoralen IDP MUSS sicherstellen, dass er nur mTLS-gesichert mit Fachdiensten kommuniziert.**[<=]**

Hinweis: Kommt es zum TLS Verbindungsaufbau und es besteht eine HTTP-Verbindung zwischen Fachdienst und sektoralen IDP, so muss der sektorale IDP gemäß Anforderung A_22649 den Fachdienst als unbekannt abweisen, wenn ihm das TLS-Zertifikat des Fachdienstes nicht bekannt ist oder es nicht mit dem im Entity Statement des Fachdienstes übermittelten TLS-Zertifikat übereinstimmt.

A_22847 -Authentisierung gegenüber Clients
Der Verarbeitungskontext des sektoralen IDP MUSS sich gegenüber Clients, welche mit ihm kommunizieren, mit einem TLS-Zertifikat ausweisen, auf dessen privaten Schlüssel der Betreiber des sektoralen IDP keinen Zugriff hat.**[<=]**

A_23006 -Subdomäne für Webservice-Endpunkte in der VAU
Der Verarbeitungskontext des sektoralen IDP MUSS diese Endpunkte anbieten:

- Endpunkt für Authorization Requests
- Endpunkt für Pushed Authorization Requests
- Token-Endpunkt

Für die Endpunkte der VAU MUSS eine eigene Subdomäne, welche keine Wildcard-Domäne ist, erstellt werden.**[<=]**

Hinweis: Die Erstellung einer eigenen Subdomäne für die VAU eines sektoralen IDP ist notwendig, um die Certificate Transparency TLS-Zertifikate im Federation Master effektiv prüfen zu können.

A_22943 -Richtlinien zum TLS-Verbindungsaufbau
Der Anbieter des sektoralen IDP MUSS dafür sorgen, dass der Verarbeitungskontext des sektoralen IDP sich beim TLS-Verbindungsaufbau über das Transportnetz gegenüber dem Client mit einem TLS-Zertifikat eines Herausgebers gemäß [CAB-Forum] authentisiert. Der Anbieter MUSS dafür sorgen, dass Clientsysteme beim TLS-Verbindungsaufbau eine vereinfachte Zertifikatsprüfung mit TLS-Standardbibliotheken durchführen können. **[<=]**

A_22980 -Grundlage zur Prüfung der TLS-Zertifikate mittels Certificate Transparency
Der Anbieter des sektoralen IDP MUSS die TLS-Zertifikate, welche in seinem Verarbeitungskontext terminieren, aus einer CA beziehen, welche Certificate Transparency gemäß RFC 6962 / RFC 9162 unterstützt und täglich prüfen und sicherstellen, dass für die zur Verbindungen in den Verarbeitungskontext der VAU vorgesehen Domänen keine unbekannten Zertifikate im Certificate Transparency Log gelistet werden. Im Fehlerfall MUSS ein "Security Incident" (gemäß 3.4 gemRL_Betr_TI) erstellt werden. **[<=]**

A_22981 -Grundlage zur Prüfung der TLS-Zertifikate mittels Certification Authority Authorization (CAA) Records
Der Anbieter des sektoralen IDP MUSS für die TLS-Zertifikate welche in seinem Verarbeitungskontext terminieren Certification Authority Authorization (CAA) DNS Resource Records nach RFC 6844 bereitstellen, welche die Validität der ausstellenden CA verifizieren. **[<=]**

A_22982 -Bereitstellung der öffentlichen Schlüssel der TLS-Zertifikate
Der Anbieter des sektoralen IDP MUSS die öffentlichen Schlüssel der TLS-Zertifikate, welche in seinem Verarbeitungskontext terminieren, dem Federation Master bereitstellen. Der organisatorische Prozess zur Schlüsselübergabe ist in [gemSpec_IDP_FedMaster] beschrieben.**[<=]**

Hinweis: Auf diesem Weg kann der Federation Master verifizieren, dass keine TLS-Zertifikate für diese Adressen erstellt werden deren privater Schlüssel nicht nachgewiesenermaßen im Verarbeitungskontext der VAU liegt. Der Federation Master bietet hierzu einen organisatorischen Prozess an.

A_22848 -Isolation zwischen Datenverarbeitungsprozessen mehrerer Verarbeitungskontexte der VAU
Die VAU des sektoralen IDP MUSS die in ihr ablaufenden Verarbeitungen für die Daten eines Verarbeitungskontextes von den Verarbeitungen für die Daten anderer Verarbeitungskontexte in solcher Weise trennen, dass mit technischen Mitteln ausgeschlossen wird, dass die Verarbeitungen eines Verarbeitungskontextes schadhaft auf die Verarbeitung eines anderen Verarbeitungskontextes einwirken können. Die VAU des sektoralen IDP MUSS dabei insbesondere verhindern, dass die Verarbeitungen von Daten innerhalb eines Verarbeitungskontextes zu fehlerhaften Ausstellungen von Identitätsbestätigungen bei einem Authentifizierungsvorgang in einem anderen Verarbeitungskontext führen könnte.**[<=]**

Hinweis: Da der Verarbeitungskontext der VAU des sektoralen IDP für jede fachliche Operation neu aufgebaut werden muss, ist ein Low-Level-Mechanismus zur Kontextseparation aus Gründen der Performance bzw. Skalierung nicht zwingend vorgeschrieben. Der hier geforderte Separationsmechanismus kann daher auch als

Server-Thread, Worker, o. Ä. ausgeführt sein, solange für den dadurch gebildeten Verarbeitungskontext die geforderte Separation nachgewiesen werden kann. Dies setzt voraus, dass die Umsetzung der Verarbeitungskontexte und der in ihnen ablaufenden Verarbeitungsvorgänge technisch möglichst einfach und nachvollziehbar gestaltet ist.

A_22849 -Isolation der VAU von Datenverarbeitungsprozessen des Anbieters
Die VAU des sektoralen IDP MUSS die in ihren Verarbeitungskontexten ablaufenden Datenverarbeitungsprozesse von allen sonstigen Datenverarbeitungsprozessen des Anbieters trennen und damit gewährleisten, dass sowohl Dritte als auch der Betreiber des sektoralen IDP selbst vom Zugriff auf die in der VAU verarbeiteten schützenswerten Daten ausgeschlossen ist.
[<=]

Hinweis: Schützenswerten Daten im Kontext der sektoralen IDP sind die Daten, welche innerhalb der VAU zum laufenden Authentifizierungsprozess erzeugt bzw. gespeichert werden (`client_id`, `state`, `redirect_uri`, `code_challenge`, `AUTHORIZATION_CODE`, `ID_TOKEN`), sowie die Daten für das Nutzerprotokoll.

Hinweis: Für die Separation zwischen Verarbeitungskontexten und Verarbeitungsprozessen des Anbieters, die der betrieblichen Steuerung des Systems dienen, ist eine Low-Level Separation anzustreben, da - im Unterschied zur Separation zwischen Verarbeitungskontexten - hier technisch sehr verschiedene Aspekte getrennt werden müssen.

A_22850 -Ausschluss von Manipulationen an der Software der VAU
Die VAU des sektoralen IDP MUSS eine Manipulation der eingesetzten Software erkennen und eine Ausführung der manipulierten Software verhindern.**[<=]**

A_22851 -Ausschluss von Manipulationen an der Hardware der VAU
Die VAU des sektoralen IDP MUSS die Integrität der eingesetzten Hardware schützen und damit insbesondere Manipulationen an der Hardware sowohl durch Dritte als auch der Betreiber des sektoralen IDP ausschließen.**[<=]**

A_22852 -Kontinuierliche Wirksamkeit des Manipulationsschutzes der VAU
Die VAU des sektoralen IDP MUSS den Ausschluss von Manipulationen an der Hardware und der Software sowohl durch Dritte als auch der Betreiber des sektoralen IDP mit Mitteln umsetzen, deren dauerhafte und kontinuierliche Wirksamkeit gewährleistet werden kann.**[<=]**

A_22853 -Ausschluss von Manipulationen über physische Angriffe
Die VAU des sektoralen IDP MUSS mit technischen und/oder organisatorischen Mitteln ausschließen, dass ein Angreifer aus dem betrieblichen Umfeld des IDP physische Angriffsmittel zur Kompromittierung der VAU zum Einsatz bringen kann.**[<=]**

A_22854 -Nutzdatenbereinigung vor physischem Zugang zu Systemen der VAU
Die VAU des sektoralen IDP MUSS mit technischen und/oder organisatorischen Mitteln sicherstellen, dass physischer Zugang zu Hardware-Komponenten der Verarbeitungskontexte nur erfolgen kann, nachdem gewährleistet ist, dass aus ihnen keine Nutzdaten extrahiert werden können.**[<=]**

A_22868 -Private Schlüssel im HSM
Der sektorale IDP MUSS folgende private Schlüssel in einem Hardware Security Module (HSM) erzeugen und anwenden:

- die Schlüssel zur Signatur von Token und Entity Statements
- die Schlüssel der TLS-Zertifikate für die sichere Verbindung zum Verarbeitungskontext

Die Prüftiefe des HSM MUSS dabei den in [A_22829] angegebenen Standards entsprechen.**[<=]**

A_22855 -HSM-Kryptographieschnittstelle verfügbar nur für Instanzen der VAU

Die VAU des sektoralen IDP MUSS mit technischen Mitteln die Manipulationen sowohl durch Dritte als auch den Betreiber des sektoralen IDP ausschließen und gewährleisten, dass nur Instanzen der VAU-Zugriff auf die Kryptographie Schnittstelle des HSM zur Nutzung des privaten Schlüsselmaterials für ihre TLS-Zertifikate und die Signaturschlüssel für die Token und Entity Statements erhalten können.**[<=]**

Hinweis: Falls die Verarbeitungskontexte als Threads, Workers, o. ä. umgesetzt sind und daher gemeinsam in einem übergreifenden Anwendungsprozess ausgeführt werden, kann dieser Anwendungsprozess eine authentisierte Verbindung zur Kryptographieschnittstelle des HSM herstellen und aufrechterhalten, um darüber die Kryptographieschnittstelle des HSM den Verarbeitungskontexten (und nur diesen) lokal zur Verfügung zu stellen. Das bedeutet auch, dass das HSM für mehrere Mandanten nutzbar ist. Dabei muss allerdings sichergestellt werden, dass der Schlüsselzugriff nur im Verarbeitungskontext des jeweiligen Mandanten möglich ist.

3.2.3 Konsistenz des Systemzustands, Logging und Monitoring

A_22856 -Konsistenter Systemzustand des Verarbeitungskontextes der VAU
Die VAU des sektoralen IDP MUSS sicherstellen, dass ein konsistenter Zustand des Verarbeitungskontextes auch bei Bedienfehlern oder technischen Problemen immer erhalten bleibt bzw. wiederhergestellt werden kann.**[<=]**

Hinweis: Eine Möglichkeit zur Wiederherstellung der Konsistenz kann im Rollback des Verarbeitungskontexts auf den letzten konsistenten Zustand vor dem Auftreten des Fehlers bestehen. Das Ziel der Anforderung ist in jedem Fall sicherzustellen, dass der besonders geschützte Verarbeitungskontext nicht durch eine Fehlersituation in einen nicht zu korrigierenden, nicht nutzbaren Zustand gelangen kann, der weitere Zugriffe des Nutzers unmöglich machen könnte.

3.3 Betriebliche Unterstützung des Probings

Zur Überprüfung der Erreichbarkeit des sektoralen IDP werden durch die gematik regelmäßig invalide Requests an diese Schnittstellen gemäß Entity Statement (siehe Tabelle: "Body Entity Statement des sektoralen IDP") gestellt.:

- `pushed_authorization_request_endpoint`
- `token_endpoint`

Als Ergebnis der Request wird ein Fehlercode gemäß [OpenID Federation 1.1] erwartet. Testidentitäten müssen demnach in der produktiven Umgebung nicht bereitgestellt werden.

A_22567-01 -Informationsverpflichtung über Mandanten des Anbieters sektoraler IDP KTR
Der Anbieter sektoraler IDP KTR MUSS der gematik initial zur Zulassung und danach jeweils bei Änderungen tagesaktuell die Liste der Mandanten (Versicherungen) mitteilen, für deren Versicherte er den Dienst anbietet.
Zusätzlich MUSS der Anbieter sektoraler IDP KTR für GKV-Kassen die gemIK gemäß [A_25078*] und die Telematik-ID der Kasse aus dem "Verfahren zur Herausgabe der SMC-B für Kostenträger" nennen, in welchem der GKV-SV die Echtheit der Kasse bereits

bestätigt hat und für Unternehmen nach §362 (1) SGB V (PKV-Kassen,Postbeamtenkrankenkasse, Bundeswehr ...) die gemIK gemäß [A_25078*] und die Telematik-ID des Unternehmens aus dem "Verfahren zur Herausgabe der SMC-B" nennen. Die Beauftragung der Kasse bzw. des Unternehmens ist der Meldung schriftlich als Erklärung beizufügen.

Hinweis: Die Benachrichtigung an die gematik kann per E-Mail (S/MIME) an transition@gematik.de erfolgen.
[<=]

4 Funktionsmerkmale

4.1 Allgemeine Anforderungen an Teilnehmer der TI-Föderation

Es gelten für den sektoralen IDP ebenfalls die in Kapitel 4.1 "Allgemeine Anforderungen an Teilnehmer der TI-Föderation" gemSpec_IDP_FedMaster festgehaltenen Anforderungen.

4.2 Entity Statement des sektoralen IDP

Das Entity Statement enthält die Metadaten und Adressen des sektoralen IDP, sowie seine verwendeten kryptographischen Identitäten.

A_28195 -Anbieter sektoraler IDP - Schlüssel-Identifier im JWK-Format
Der Anbieter des sektoralen IDP MUSS sicherstellen, dass bei der Bereitstellung neuer Schlüssel im JSON Web Key Set (JWKS) Format die Key Identifier der Schlüssel im UUID7-Format [RFC9562#name-uuid-version-7] vorliegen, die den Zeitpunkt der Schlüsselerzeugung widerspiegeln.**[<=]**

A_22643-02 -Entity Statement des sektoralen IDP
Der sektorale IDP MUSS ein selbst signiertes Entity Statement gemäß[OpenID Federation 1.1] ("Entity Statement") bereitstellen und im Internet verfügbar machen. Das Entity Statement MUSS mindestens die in der folgenden Tabelle aufgeführten Metadaten enthalten:

Tabelle 2: Header des Entity Statement des sektoralen IDP

Name	Werte / Wertebereich
`alg`	string, zulässiger Wert "ES256"
`kid`	string, UUID7-Format [RFC9562#name-uuid-version-7]
`typ`	string, zulässiger Wert "entity-statement+jwt"

Tabelle 3 : *Allgemeine Attribute im well-known-Dokument des sektoralen IDP*

Name	Werte / Wertebereich
`iss`	string, URL nach [RFC1738]
`sub`	string, URL nach [RFC1738]

iat	number, Alle time-Werte in Sekunden seit 1970,[RFC7519#section-2]
exp	number, Alle time-Werte in Sekunden seit 1970,[RFC7519#section-2]
jwks	Set von JWK [RFC7517]
authority_hints	[string] zulässige Werte gemäß [OpenID Federation 1.1] ("Claims that MUST or MAY Appear in Entity Configurations but Not in Subordinate Statements") - authority_hints
metadata	JSON Object, erforderlicher Wert: "openid_provider"

Tabelle 4 : Attribute des Metadatenblocks openid_provider im well-known-Dokument des sektoralen IDP

Name	Werte
issuer	string, URL nach [RFC1738] zulässiger Wert: identisch mit dem Wert des Claims iss
signed_jwks_uri(*)	string, URL nach [RFC1738]
jwks (*)	Set von JWK [RFC7517]
authorization_endpoint	string, URL nach [RFC1738]
token_endpoint	string, URL nach [RFC1738]
pushed_authorization_request_endpoint	string, URL nach [RFC1738]
organization_name	string (gemäß [OpenID-Federation 1.1 "Informational Metadata Extensions"] - organization_name) Wertebereich: ^[à-üÀ-Üß\w\ \-\.\+*\/]{1,128}$
keywords	[string] (gemäß [OpenID-Federation 1.1 "Informational Metadata Extensions"] - keywords) erforderliche Werte: "product_type_version:<von der

	gematik zugelassene Produkttyp-Version>" "product_type:<von der gematik zugelassener Produkttyp>"
contacts	[string] (gemäß [OpenID-Federation 1.1 "Informational Metadata Extensions"] - contacts) erforderlicher Wert in Liste: "<E-Mail-Adresse für Supportanfragen>"
logo_uri	string, URL nach [RFC1738] zulässiger Wert: <URL>*.png
client_registration_types_supported	[string] zulässiger Wert: "automatic"
subject_types_supported	[string] zulässiger Wert: "pairwise"
response_types_supported	[string] zulässiger Wert: "code"
scopes_supported	[string], Wertebereich: "openid", "<weitere Scopes nach A_22989*>"
claims_supported	[string], Wertebereich: "<Claims nach A_22989*>"
claims_parameter_supported	boolean, Wertebereich: true/false
response_modes_supported	[string] zulässiger Wert: "query"
grant_types_supported	[string] zulässiger Wert: "authorization_code"
require_pushed_authorization_requests	boolean, Wertebereich: true/false zulässiger Wert: true
token_endpoint_auth_methods_supported	[string] erforderlicher Wert: "self_signed_tls_client_auth"
id_token_signing_alg_values_supported	[string] erforderlicher Wert: "ES256"

`id_token_encryption_alg_values_supported`	[string] erforderlicher Wert: "ECDH-ES"
`id_token_encryption_enc_values_supported`	[string] erforderlicher Wert: "A256GCM"
`user_type_supported`	[string] zulässiger Wert: "IP" (Insured Person)
ti_features_supported {	
`id_token_version_supported`	[string] zulässige Werte in Liste: "1.0.0", "2.0.0"

(*) - gemäß [OpenID Federation 1.1] - "Usage of jwks, jwks_uri, and signed_jwks_uri in Entity Metadata" darf der Metadatenblock nur entweder `signed_jwks_uri` oder `jwks` `enthalten`.**[<=]**

A_24403 -Signalisierung der Unterstützung von Claims
Der sektorale IDP MUSS in seinem metadata Statement über den Parameter`claims_supported` signalisieren, welche Claims er unterstützt.**[<=]**

A_28196 -Anbieter sektoraler IDP - Schlüsselwechselphase - Nutzbarkeit der ENC-Schlüssel
Der Anbieter des sektoralen IDP MUSS sicherstellen, dass die privaten Schlüssel von Schlüsselpaaren, deren Zweck die Verschlüsselung ist, systemintern so lange zur Entschlüsselung verwendet werden können, bis der Ablaufzeitpunkt ("exp" claim) des signierten Dokuments (Enitity Statement bzw. jwks) erreicht wurde, in dem der Schlüssel zuletzt bekannt gemacht wurde.**[<=]**

Hinweis: Nicht betroffen von dieser Anforderung sind kurzfristig notwendige Schlüsselwechsel, z. B. aufgrund von Sicherheitsvorfällen. Diese Maßnahmen sind beispielsweise über security incidents abzuwickeln.

A_22711 -Regelmäßige Erneuerung des Entity Statement des sektoralen IDP
Das Entity Statement des sektoralen IDP MUSS täglich neu ausgestellt werden.**[<=]**

A_23010 -Maximale Gültigkeitsdauer eines Entity Statement des sektoralen IDP
Die maximale Gültigkeitsdauer eines Entity Statement des sektoralen IDP (Attributwerte `iat` und `exp` im Entity Statement) DARF 24 Stunden NICHT überschreiten.**[<=]**

A_22644 -Entity Statement - Prüfung angebotener URLs
Der sektorale IDP MUSS alle von ihm im Entity Statement angebotenen URL stündlich auf bloße Erreichbarkeit prüfen.**[<=]**

Hinweis: Die Anforderung gilt sowohl für die Entity Statements der Fachdienste als auch für die Entity Statements des Federation Master über diese Fachdienste. Ist der Federation Master oder der Fachdienst ggf. temporär nicht erreichbar, so sollte das Herunterladen der Entity Statements über die Fachdienste weiter (z.B. stündlich) versucht werden.

Hinweis: Das Verwerfen des Entity Statements eines bekannten Fachdienstes dient der Aktualisierung des Status des Fachdienstes und bedeutet nicht eine automatische Deregistrierung des Dienstes beim IDP.

A_27506 -Signalisierung der unterstützten TI-Features durch einen sektoralen IDP der TI-Föderation

Ein sektoraler IDP MUSS in seinem Entity Statement im Metadatenblock `openid_provider` in einem Claim `ti_features_supported` signalisieren, welche spezifischen Versionen der TI-Föderation unterstützt werden. Im Claim`ti_features_supported` MUSS der sektoraler IDP aktuell die Unterstützung der in Tabelle "Durch einen sektoralen IDP unterstützte TI-Features" genannten Claims signalisieren.

Tabelle 5 : Durch einen sektoralen IDP unterstütze TI-Features

claim	Wertebereich	Beschreibung
`id_token_version_supported`	[string], zulässige Werte in Liste: "1.0.0", "2.0.0"	Mit A_22867-* und A_23207-* ändert sich die Syntax des vom sektoralen IDP ausgestellten ID Token nicht abwärtskompatibel. Für einen Übergangszeitraum muss ein sektoraler IDP die beiden Versionen: • 1.0.0 nach A_22867-01 und A_23207-02, • 2.0.0 nach A_27591 und A_27592, unterstützen.

[<=]

Hinweis: Ist id_token_version_supported im Entity Statement eines sektoralen IDP nicht gesetzt, so unterstützt dieser nur ID Token Version "1.0.0" gemäß A_23129, A_22867-01, A_23207-02 (default).*

4.3 API-Endpunkte des sektoralen IDP

4.3.1 Anforderung an die Schnittstelle zum Authorization Server des Fachdienstes

A_22649 -Anfragen unbekannter Clients
Der Produkttyp sektoraler IDP MUSS Pushed Authorization Request von Clients mit dem http-Statuscode 401 (Unauthorized) ablehnen, wenn diese nicht in der Föderation oder direkt beim sektoralen IDP registriert sind. Ist der Fachdienst dem sektoralen IDP nicht bekannt, so stößt dieser intern die automatische Registrierung [OpenID Federation 1.1] an damit nachfolgende Anfragen angenommen werden können.**[<=]**

A_22922 -Anfragen veralteter Authenticator Versionen
Der Produkttyp sektoraler IDP MUSS Authorization Request von veralteten Authenticator Versionen ablehnen, wenn diese aus Kompatibilitätsgründen durch die gematik gesperrt wurden.**[<=]**

A_22650-01 -Automatische Registrierung von Fachdiensten
Der sektorale IDP MUSS eine automatische Registrierung eines Fachdienstes Authorization Servers bei Übermittlung eines Authorization Request

mit`self_signed_tls_client_auth` gemäß [OpenID Federation 1.1] durchführen, sofern dieser Dienst nicht bereits am IDP registriert wurde. Der sektorale IDP MUSS das Entity Statement des Fachdienst Authorization Server abrufen und gemäß A_28848* validieren.Anschließend registriert der sektorale IDP den Fachdienst Authorization Server und importiert dessen Schlüssel für die Authentisierung und Verschlüsselung von Token. **[<=]**

Hinweis: Wenn eine `signed_jwks_uri` im Entity Statement des Fachdienstes angegeben ist, müssen auch diese Schlüssel importiert werden. Sowohl dies als auch die Nutzung eines jwks im Statement selbst muss unterstützt werden.

4.3.2 PAR - Endpunkt

Am PAR-Endpunkt des sektoralen IDP werden Anfragen der Authorization Servern eines Fachdienstes eingereicht und verifiziert. Inhalt der Anfrage ist unter anderem:

- Die `client_id` des anfragenden Fachdienstes sowie dessen öffentlicher Authentisierungsschlüssel.
- Die `redirect_uri`, an welche der Authorization Request beantwortet werden soll.
- Der über das eigene `CODE_VERIFIER` [RFC7636#section-4.1] gebildete HASH `CODE_CHALLENGE` [RFC7636#section-4.2] mit Angabe des Algorithmus `code_challenge_method` [RFC7636#section-4.3] entsprechend dem gewählten Authorization Code Flow (response_type=code).
- Der `state`-Parameter [RFC8252#section-8.9] wird genutzt, um CSRF (Cross-Site-Request-Forgery) zu verhindern.
- Der Scope und die Claims der Anfrage, welcher einen definierten Satz von benötigten Attributen für die entsprechende Anwendung beinhaltet.

Der PAR-Endpunkt des sektoralen IDP nimmt den Pushed Authorization Request [RFC9126] des Authorization Server eines Fachdienstes entgegen. Der am PAR-Endpunkt des sektoralen IDP eingehende Request wird validiert, um frühzeitig unautorisierte Abfragen zu verhindern.

Ist der Pushed Authorization Request geprüft und valide, erstellt der PAR-Endpunkt des sektoralen IDP eine Request-URI. Diese wird im weiten Ablauf für die Nutzerauthentifizierung benötigt. Die Request-URI und deren Gültigkeitsdauer sind Parameter der Antwort des sektoralen IDP auf den eingegangenen Request.

4.3.2.1 PAR-Endpunkt Eingangsdaten

A_22651 -Parameter des Pushed Authorization Request durch den sektoralen IDP

Der sektorale IDP MUSS die Annahme von Pushed Authorization Request gemäß [OAuth 2.0 Pushed Authorization Requests#section-2] unterstützen und den Endpoint für Pushed Authorization Request im Entity Statement des sektoralen IDP`pushed_authorization_request_endpoint` bekanntgeben.

Der sektorale IDP MUSS mindestens die in der ~~*ML-132850 - Missing cross-reference*~~*Tabelle Parameter Pushed Authorization Request* dargestellten Parameter im Pushed Authorization Request des Authorization Server eines Fachdienstes annehmen. **[<=]**

A_24404 -Unterstützung von Claims im Authorization Request

Der sektorale IDP MUSS den Parameter Claims im Pushed Authorization Request verarbeiten können und dies in seinem metadata Statement über den Parameter `claims_parameter_supported` signalisieren.**[<=]**

A_22966-02 -Prüfung eingehender Pushed Authorization Request durch den sektoralen IDP
Der sektorale IDP MUSS eingehende Pushed Authorization Requests validieren und invalide Requests gemäß [OAuth 2.0 Pushed Authorization Requests#section-2.3] mit einer Fehlermeldung ablehnen.
Die Validierung eines eingegangenen Pushed Authorization Request MUSS die Prüfung der im Request enthaltenen Werte für `redirect_uri`, `scope` und `claims` beinhalten.
Dabei müssen`redirect_uri`, `scope` und `claims` aus dem Pushed Authorization Request eine Teilmenge der Werte sein, die der Federation Master für diesen Fachdienst in der Teilnehmerauskunft liefert.
[<=]

Hinweis: Nach [OpenID Connect Core 1.0# AuthRequest] ist es zulässig, dass ein Client mehrere `redirect_uri` bei der Registrierung hinterlegt. der sektorale IDP muss laut der OIDC-Spezifikation prüfen, ob die im Request gelieferte `redirect_uri` mit exakt einer der hinterlegten `redirect_uri` übereinstimmt. Die Prüfung muss über eine 'Simple String Comparison' nach [Uniform Resource Identifier (URI)#section-6.2.1] erfolgen.

A_22991 -Prüfung des TLS Clientzertifikates am PAR-Endpunkt des sektoralen IDP
Der PAR-Endpunkt des sektoralen IDP MUSS das im Rahmen der`self_signed_tls_client_auth`übertragene Zertifikat des Fachdienstes wie folgt überprüfen:

- Das Zertifikat ist über das Entity Statement des Fachdienstes zu verifizieren.
- Das Zertifikat ist zeitlich gültig.

[<=]

Hinweis: Der Fachdienst gegen dessen Entity Statement geprüft werden muss wird durch die client-id im Request identifiziert.

4.3.2.2 PAR-Endpunkt Ausgangsdaten

A_22992 -Antwort auf einen eingehenden Pushed Authorization Request durch den sektoralen IDP
Der sektorale IDP MUSS auf einen validen Pushed Authorization Request mit einem http-Statuscode 201 gemäß [RFC9126#section-2.2] antworten.**[<=]**

A_22993 -Gültigkeit der vom sektoralen IDP erstellten Request-URI
Die Gültigkeit der vom sektoralen IDP erstellten Request-URI DARF NICHT 90 Sekunden überschreiten.**[<=]**

4.3.3 Authorization-Endpunkt

Am Authorization-Endpunkt des sektoralen IDP wird in Kommunikation mit dem Authenticator-Modul die Authentisierung des Nutzers durchgeführt.

4.3.3.1 Schnittstelle Authorization-Endpunkt

A_22312-02 -Einhaltung der Standards bei der Realisierung des Authorization-Endpunkts
Der sektorale Identity Provider MUSS die Schnittstelle Authorization-Endpunkt gemäß [RFC6749#section-3.1], [RFC8252] und [RFC9126#section-4] sowie weitere darin festgelegte Standards implementieren. Hierbei MÜSSEN nur im Rahmen der [gemSpec_IDP_Sek] relevante Aspekte berücksichtigt werden.
[<=]

4.3.3.2 Authorization-Endpunkt Ausgangsdaten

Sind alle in Scope bzw. Claims geforderten Attribute vorhanden und die Gültigkeit der Attribute geprüft sowie eine erfolgreiche Authentifizierung des Nutzers erfolgt, erstellt der Authorization-Endpunkt des sektoralen IDP einen `AUTHORIZATION_CODE` und sendet diesen an den Authorization Server eines Fachdienstes.

A_22324 -Verwendung des Attributes "state" durch sektoralen IDP
Der Authorization-Endpunkt des sektoralen Identity Provider MUSS den `state`-Parameter [RFC6749#section-10.12] der Anfrage in allen darauf basierenden Responses verwenden.
[<=]

A_22325-01 -Übermitteln des "AUTHORIZATION_CODE" an den Sender des Requests
Der sektorale Identity Provider MUSS den `AUTHORIZATION_CODE` und den `state` auf demselben Kanal beantworten, auf dem er den Authorization Request empfangen hat.
[<=]

Hinweis: Im Fall des App-App-Flow [☐~~ML-132454 - Missing cross-reference~~] und des Web-App-Flow [☐~~ML-132462 - Missing cross-reference~~] wird der Request durch das Authenticator-Modul angenommen und an den sektoralen IDP gestellt. Im Fall des Zwei-Geräte-Flow [☐~~ML-132463 - Missing cross-reference~~] wird der Request direkt über den Browser gestellt und damit auch an diesen zurückgeliefert.

4.3.4 Token-Endpunkt

Der Token-Endpunkt des sektoralen IDP nimmt die Anfrage des Authorization Server eines Fachdienstes entgegen und prüft neben deren Integrität, ob der eingereichte `CODE_VERIFIER` bei Nutzung des Hash-Verfahrens S256 (nach [RFC7636#section-4.2]) zum bitgleichen Hash-Wert führt. Stimmt der Hash-Wert aus dem initialen Aufruf über das Authenticator-Modul - die Code-Challenge - mit dem gebildeten Hash-Wert überein, ist sichergestellt, dass Aufrufer und Initiator identisch sind. Der Token-Endpunkt gibt daraufhin das `ID Token` an den Authorization Server des Fachdienstes heraus.

4.3.4.1 Token-Endpunkt Eingangsdaten

A_22653 -Annahme von "AUTHORIZATION_CODE" und "CODE_VERIFIER"
Der Token-Endpunkt des sektoralen IDP MUSS die vom Authorization Server eines Fachdienstes übertragenen `AUTHORIZATION_CODE` und `CODE_VERIFIER` annehmen. **[<=]**

A_23007 -Gültigkeit des "AUTHORIZATION_CODE"

Die Gültigkeitsdauer eines`AUTHORIZATION_CODE` DARF 90 Sekunden NICHT überschreiten.
[<=]

A_23162 -Invalidisierung des "AUTHORIZATION_CODE"
Der `AUTHORIZATION_CODE` MUSS nach einmaliger Verwendung invalidiert werden.**[<=]**

A_22321 -Prüfung des "CODE_VERIFIER"
Der Token-Endpunkt des sektoralen Identity Provider MUSS die Überprüfung des`CODE_VERIFIER` gegen die `CODE_CHALLENGE` mit S256 (Algorithmus nach [RFC7636#section-4.2]) durchführen.**[<=]**

A_22654 -Prüfung des TLS Clientzertifikates am Token-Endpunkt des sektoralen IDP
Der Token-Endpunkt des sektoralen IDP MUSS das im Rahmen der`self_signed_tls_client_auth`übertragene Zertifikat des Fachdienstes wie folgt überprüfen:

- Das Zertifikat ist über das Entity Statement des Fachdienstes zu verifizieren.
- Das Zertifikat ist zeitlich gültig.

[<=]

Hinweis: Der Fachdienst gegen dessen Entity Statement geprüft werden muss wird durch die client-id im Request identifiziert.

A_22323 -Protokollierung der Token-Ausgabe in allen Fällen
Der Token-Endpunkt des sektoralen Identity Provider MUSS im Positivfall die Herausgabe der Token und im Negativfall die Token-Anfrage protokollieren.**[<=]**

Das Protokoll wird intern und ggf. für Audits verwendet.

4.3.4.2 Token-Endpunkt Ausgangsdaten

A_22316 -Maximale Gültigkeitsdauer von ID Token
Der sektorale Identity Provider DARF ID Token mit einer Gültigkeitsdauer von mehr als 300 Sekunden (5 Minuten) NICHT ausstellen.**[<=]**

A_22706-02 -"ID Token" des sektoralen IDP
Der sektorale IDP MUSS nach erfolgreicher Prüfung des erhaltenen`AUTHORIZATION_CODE` dem aufrufenden Authorization Server des Fachdienstes ein ID Token gemäß OIDC-Standard [OpenID Connect Core 1.0#IDToken] mit den angefragten Scope und Claims zurückgeben.
[<=]

Hinweis: Nicht vorhandene oder zur Weitergabe nicht zugestimmte Claims werden nicht in den ID Token übernommen.

A_22983 -Signaturverfahren für Signatur des "ID Token" des sektoralen IDP
Das für die Signatur der ID Token zu verwendende Verfahren MUSS ECDSA auf Basis der NIST-Kurve P-256 sein. (vergleiche [draft-jones-json-web-signature-04.html#DefiningECDSA]).**[<=]**

A_22655-03 -Signatur des "ID Token" des sektoralen IDP
Der sektorale IDP MUSS die ID Token unter Verwendung eines privaten Schlüssels, der zu einem direkt unter `openid_provider.jwk` im Entity Statement stehenden oder unter `openid_provider.signed_jwks_uri` referenzierten öffentlichen Schlüssel gehört, signieren [OpenID Federation 1.1].

Zum öffentlichen Schlüssel des verwendeten Schlüsselpaares MUSS es ein Signaturzertifikat des Typs C.FD.SIG und der technischen Rolle „oid_idpd_sek“ gemäß

[gemSpec_Krypt#Abschnitt 3.7] aus der Komponenten-PKI der TI geben, welches im Parameter x5c des ID Token Headers enthalten ist.**[<=]**

A_23193-01 -Verschlüsseln der "ID Token"
Der sektorale IDP MUSS einen Verschlüsselungsschlüssel des Fachdienstes über den use Parameter ("use = enc") aus dessen jwks wählen und mit diesem das ID Token verschlüsseln. Im JWE-Header des Token referenziert der sektorale IDP über den Parameter `kid` einen Hinweis auf den verwendeten Verschlüsselungsschlüssel. Als Verschlüsselungsverfahren MUSS hierbei ECDH-ES verwendet werden.**[<=]**

A_27598 -Unterstütze Versionen der von sektoralen IDPs ausgestellten ID Token
Der sektorale IDP MUSS den Claim `metadata.openid_relying_party.ti_features_supported.id_token_version_supported` aus dem Entity Statement des anfragenden Fachdienstes auswerten und die jeweils höchste von beiden Seiten unterstützte Version für das auszugebendeID Token auswählen. Gibt es keine passende Übereinstimmung der unterstützten ID Token Versionen, so MUSS der IDP am PAR-Endpunkt den Request mit dem Fehlercode HTTP-400 "Invalid_metadata" (gemäß [OpenID Federation 1.1]) ablehnen. Aus der error_description der Fehlermeldung MUSS eindeutig der Grund der Ablehnung hervorgehen.**[<=]**

Hinweis: Wird vom anfragenden Fachdienst nur die Version "1.0.0" supportet, so muss der sektorale IDP bei der Ausstellung desID Token A_22867- berücksichtigen. Wird vom anfragenden Fachdienst die Version"2.0.0" supportet, so muss der sektorale IDP bei der Ausstellung des ID Token A_27591 berücksichtigen.*

Hinweis: Ist id_token_version_supported im Entity Statement einer Relying Party nicht gesetzt, so unterstützt diese nur ID Token Version "1.0.0" gemäß A_23129, A_22867-01, A_23207-02 (default).*

A_27713-01 -Signalisierung der vom sektoralen IDP ausgestellten ID Token-Version
Der sektorale IDP MUSS die Version des ausgestellten ID Token im custom Claim "version" im JWE Protected Header angeben.
[<=]

Hinweis 1: Zur Sicherstellung der Interoperabilität kann der Claim für ID Token1.0.0 (default) entfallen.

Hinweis 2: Beispiel siehe Tabelle "Header Claims des ID Token des sektoralen IDP".

A_22989-02 -"Scope" und "Claims" Werte des sektoralen IDP für Versicherte
Ein sektoraler IDP, welcher die Identitäten für Versicherte verwaltet, MUSS mindestens die folgenden Scope und Claims Werte unterstützen:

Tabelle 6: Scope und Claims

Scope	Claim	Wert	Beschreibung
urn:telematik:geburtsd	birthdate	strin	Die Angaben des Geburtsdatums des

atum		g	Nutzers erfolgt im Format [ISO 8601:2004] YYYY-MM-DD. Ist das Geburtsdatum nicht bekannt, so wird es (analog einer Festlegung für diesen Fall bei Ausstellung einer eGK) durch folgende Regeln definiert. (dabei wird davon ausgegangen, dass das Geburtsjahr immer vorhanden ist): • Ist der Monat aber nicht der Tag des Geburtsdatums bekannt, so wird der 15. des Monat als Geburtsdatum festgelegt (TT.03.1975 ->15.03.1975) • Sind Tag und Monat des Geburtsdatums nicht bekannt, so wird der 01.07. des Jahres als Geburtsdatum festgelegt (TT.MM.1975 ->01.07.1975)
urn:telematik:alter	urn:telematik:claims:alter	string	Alter der Person in Jahren zum Zeitpunkt der Erstellung des Tokens
urn:telematik:display_name	urn:telematik:claims:display_name	string	Analog zu name gemäß [OpenID Connect Core 1.0] Vollständiger Name des Versicherten in anzeigbarer Form inklusive aller Namensbestandteile und ggf. vorhandener Titel oder Namenszusätze.
urn:telematik:family_name	urn:telematik:claims:family_name	string	Nachname des Versicherten kodiert als UTF8 String [RFC3629]
urn:telematik:given_na	urn:telematik:claims:given_n	strin	Vorname des

me	ame	g	Versicherten, kodiert als UTF8 String [RFC3629]
urn:telematik:geschlecht	urn:telematik:claims:geschlecht	string	Geschlecht des Nutzers. Kodierung analog VSDM M =männlich, W = weiblich, X = unbestimmt, D = divers
urn:telematik:email	urn:telematik:claims:email	string	E-Mail-Adresse des Versicherten, wenn bekannt
urn:telematik:versicherter	urn:telematik:claims:profession	string	Für Versicherte 1.2.276.0.76.4.49
	urn:telematik:claims:id	string	Für Versicherte der unveränderliche Anteil der KVNR
	urn:telematik:claims:organization	string	ID oder Name der attributsbestätigenden Stelle (IK-Nummer der Kasse)

[<=]

Hinweis: Die angefragten Scopes werden so mit Werten belegt, wie sie zum Abfragezeitpunkt beim sektoralen IDP (bzw. dessen Quellsystem) vorliegen.

Hinweis: Hinweis: Die Regel zur Festlegung des Geburtsdatums bei unbekanntem Tag bzw. Monat basiert auf den [Datensätze und Datenbausteine sowie Fehlerkatalog] (https://www.informationsportal.de/wp-content/uploads/GemRS_Anlage_09.4_Vers-8.00.pdf)

Hinweis: Die über den Scope urn:telematik:email angefragte Adresse ist vor der Verwendung durch den Fachdienst zu verifizieren. Eine Verifikation durch den IDP ist nicht vorgesehen, da diese ohnehin nur eine begrenzte zeitliche Gültigkeit haben kann.

Hinweis: Da ein Wechsel des E-Mail-Provider durch den Nutzer jederzeit möglich ist und die E-Mail-Adresse bei sektoralen IDPs nicht für alle Versicherten zuverlässig und vorhanden vorausgesetzt werden kann, wird von der Verwendung der E-Mail als "essential Claim" abgeraten, um keine Nutzer ungewollt auszuschließen. Fachdienste sind angehalten, ggf. angeforderte E-Mail-Adressen selbständig vor deren Verwendung auf Gültigkeit zu überprüfen.

A_23197-01 -Nutzung eines pairwise Subject als Pseudonym des Versicherten
Der sektorale IDP MUSS das Attributsub gemäß [openid-connect-core-1_0.html#PairwiseAlg] als pairwise Subject Identifiers bilden. Dieses wird als pseudonyme ID des Versicherten verwendet:

- Der Subject Identifier MUSS je Versichertem und Fachdienst fest und eineindeutig sein.
- Der Subject Identifier MUSS sich für einen Versicherten gegenüber jedem Fachdienst unterscheiden.

Abweichend hiervon MUSS der sektorale IDP das Attribut `sub` bei jeder Gastanmeldung mittels eGK+PIN nach [A_25239*] mit einem zufälligen, nicht rückverfolgbaren Wert belegen. Dieser Zufallswert DARF NICHT gespeichert werden und MUSS für jeden Anmeldevorgang neu berechnet werden.
[<=]

A_22990-01 -Umgang mit fehlenden oder verwehrten Informationen
Ein sektoraler IDP MUSS, wenn ihm der Wert eines Scopes nicht vorliegt und es keine Regel für eine Alternativbelegung gibt (siehe z. B. Belegungsregel "birthday" in A_22989*) oder ein Scope vom Nutzer verwehrt wurde, diesem Scope entsprechende Claims im ID Token unterdrücken. Explizit (durch einen Request-Parameter `claims`) angefragte Claims DARF ein IDP NICHT im ID Token zurückliefern, wenn der Claim keinen Wert enthält oder die Nutzer-Zustimmung zur Weitergabe nicht erteilt wurde.**[<=]**

4.4 Identifizierung und Authentifizierung des Nutzers

Die Durchführungsverordnung (EU) 2015/1502 [eIDAS 2015/1502] gemäß Artikel 8 Absatz 3 der Verordnung (EU) Nr. 910/2014 [eIDAS 910/2014] legt die Mindestanforderungen an technische Spezifikationen und Verfahren für Vertrauensniveaus elektronischer Identifizierungsmittel fest.

Die Identifikation des Nutzers muss immer Angreifern mit hohem Angriffspotential standhalten.

Im Rahmen der Anbieterzulassung prüft der unabhängige Sicherheitsgutachter, dass die vom Anbieter verwendeten Mechanismen die Mindestanforderungen [A_23024] bzw. [A_23025] des jeweiligen Vertrauensniveaus erfüllen.

A_23024 -Definition "gematik-ehealth-loa-substantial"
Der Anbieter des sektoralen IDP MUSS `gematik-ehealth-loa-substantial` wie folgt interpretieren:
Der Wert `gematik-ehealth-loa-substantial` entspricht der Widerstandsfähigkeit des Authentisierungsmittels und Protokolls gegen das Angriffspotential "moderate" nach [ISO18045].
Zertifizierungen, Notifizierung oder Bestätigungen von Prozessen oder Prozessbestandteilen vergleichbarer Normen und Richtlinien, z. B. nach Verordnung (EU) Nr. 910/2014 in Verbindung mit (EU) 2015/1502 an elektronische Identifizierungsmittel, BSI TR-03107-1 oder vergleichbar, können nachgenutzt werden.**[<=]**

Hinweis: Beim Vorliegen von Zertifizierungen, welche kein Vertrauensniveau ausweisen oder keine unterschiedlichen Angriffspotentiale berücksichtigen, ist eine Nachnutzung möglich, soweit eine Eignung zum Widerstand gegen das Angriffspotential im Sicherheitsgutachten nachgewiesen wird.

A_23025 -Definition "gematik-ehealth-loa-high"
Der Anbieter des sektoralen IDP MUSS `gematik-ehealth-loa-high` wie folgt interpretieren:
Der Wert `gematik-ehealth-loa-high` entspricht der Widerstandsfähigkeit des Authentisierungsmittels und Protokolls gegen das Angriffspotential "high" nach [ISO18045].
Zertifizierungen, Notifizierung oder Bestätigungen von Prozessen oder Prozessbestandteilen vergleichbarer Normen und Richtlinien, z. B. nach Verordnung (EU) Nr. 910/2014 in Verbindung mit (EU) 2015/1502 an elektronische Identifizierungsmittel, BSI TR-03107-1 oder vergleichbar, können nachgenutzt werden.**[<=]**

Hinweis: Beim Vorliegen von Zertifizierungen, welche kein Vertrauensniveau ausweisen oder keine unterschiedlichen Angriffspotentiale berücksichtigen, ist eine Nachnutzung möglich, soweit eine Eignung zum Widerstand gegen das Angriffspotential im Sicherheitsgutachten nachgewiesen wird.

Hinweis: Im Folgenden wird an den relevanten Stellen ausschließlich`gematik-ehealth-loa-high` oder/und`gematik-ehealth-loa-substantial` verwendet.

A_22987 -Claim "acr" für eine "gematik-ehealth-loa-substantial" Authentisierungsstärke
Der Anbieter des sektoralen IDP MUSS sicherstellen das der Claim`acr` nur auf den Wert`gematik-ehealth-loa-substantial` gesetzt wird, wenn der Nutzer mindestens auf dem Niveau "substanziell" authentisiert wurde (siehe A_23024 - Definition "gematik-ehealth-loa-substantial").**[<=]**

A_22988 -Claim "acr" für eine "gematik-ehealth-loa-high" Authentisierungsstärke
Der Anbieter des sektoralen IDP MUSS sicherstellen das der Claim`acr` nur auf den Wert`gematik-ehealth-loa-high` gesetzt wird, wenn der Nutzer auf dem Niveau "hoch" authentisiert wurde (siehe A_23025 - Definition "gematik-ehealth-loa-high").**[<=]**

Hinweis: weitere Werte des Claims `acr` sind zulässig aber werden nicht spezifiziert und auch nicht im Rahmen von Anwendungen der Telematikinfrastruktur genutzt.

Im Rahmen von Anwendungen der TI kommt aktuell nur das Niveau`gematik-ehealth-loa-high` zum Einsatz.

4.4.1 Identifikation des Nutzers

Eine Notifizierung des elektronischen Identifizierungssystems, welches die elektronischen Identifizierungsmittel ausstellt, ist nicht gefordert. Ebenso ist nicht gefordert, dass der Anbieter ein qualifizierter oder nicht-qualifizierter Vertrauensdiensteanbieter gemäß Verordnung (EU) Nr. 910/2014 ist.

A_22865-01 -Verpflichtende Verfahren zur Identifikation von Nutzern
Der Anbieter des sektoralen IDP MUSS einen Prozess zur Identifikation von Nutzern mit mindestens diesen Identifikationsverfahren zur Nutzeridentifikation anbieten:

- Identifikation mittels elektronischen Identitätsnachweises (online Ausweisfunktion)
- Identifikation mittels eGK und PIN
- Identifikation mittels PID aus einer zertifizierten EUDI-Wallet

[<=]

Hinweis: Ist bei einer Identifikation des Nutzers mittels Online-Ausweisfunktion keine eindeutige Zuordnung zu einer natürlichen Person im Bestandssystem (z. B. auf Basis der dort für eine Identifikation nach [GKV-SV Richtlinie "Kontakt mit Versicherten] hinterlegten Daten) möglich, so kann die Aufklärung derDiskrepanzen bis zum Erreichen einer klaren Zuordnung, außerhalb des Kontextes des sektoralen IDP erfolgen.

A_22334-01 -Verifikation des Versicherten vor erster Nutzung
Der Anbieter des sektoralen IDP MUSS sicherstellen, dass der Zuordnungsprozess zwischen einer natürlichen Person und den Daten der Attributbestätigenden Stelle

eindeutig ist.
[<=]

A_23102 -Weitere Verfahren zur Identifikation von Nutzern
Alle Verfahren zur Identifikation des Nutzers müssen dem Angriffspotential high nach ISO 18045 standhalten. Die Bewertung der Zulässigkeit der Identifikationsverfahren erfolgt in Einzelprüfung durch die gematik.**[<=]**

Hinweis: Zertifizierungen, Notifizierung oder Bestätigungen von Prozessen oder Prozessbestandteilen vergleichbarer Normen und Richtlinien, z. B. nach Verordnung (EU) Nr. 910/2014 in Verbindung mit (EU) 2015/1502 an elektronische Identifizierungsmittel, BSI TR-03107-1 oder vergleichbar, können nachgenutzt werden.

Hinweis: Die Einzelfallprüfung erfolgt durch die gematik in Abstimmung mit dem BSI.

Hinweis: Die gematik veröffentlicht und aktualisiert regelmäßig eine Liste der zugelassenen Identifikationsverfahren im Fachportal [Zulässigkeit von Identifikationsverfahren].

4.4.2 Authentifizierungsverfahren

Nach [TR-03107-1] "*Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1#Tabelle 2: Grundlegende Kriterien für die Vertrauensniveaus*" werden je nach Vertrauensniveau unterschiedliche Anforderungen an die Authentifizierung von Nutzern gestellt. Diese bilden für die gematik die Grundlage für die folgenden Anforderungen.

A_22712 -Unterstützung von NFC eGK und PIN
Der Hersteller eines sektoralen IDP MUSS ein Authentifizierungsverfahren über NFC mittels eGK und PIN unterstützen.**[<=]**

A_22713 -Unterstützung des elektronischen Identitätsnachweis (online-Ausweisfunktion)
Der Hersteller eines sektoralen IDP MUSS ein Authentifizierungsverfahren mittels elektronischem Identitätsnachweis (Online-Ausweisfunktion) unterstützen.**[<=]**

A_28990 -Unterstützung der EUDI-Wallet
Der Hersteller eines sektoralen IDP MUSS ein Authentifizierungsverfahren mittels PID aus einer zertifizierten EUDI-Wallet unterstützen.**[<=]**

A_23026 -Entfernen von Authentifizierungsverfahren, welche die Vorgaben nicht mehr erfüllen
Der Anbieter eines sektoralen IDP MUSS sicherstellen, dassAuthentifizierungsverfahren entfernt/ausgeschlossen werden, wenn sie das entsprechende Sicherheitsniveau`gematik-ehealth-loa-high` bzw. `gematik-ehealth-loa-substantial` nicht mehr erfüllen. **[<=]**

A_24547-01 -Anfrage spezifischer Authentisierungsmittel (amr) durch Relying Parties
Ein sektoraler IDP MUSS die Anfrage von Relying Parties zum Einsatz bestimmter Authentisierungsmittel im Claims-Parameter des Authorization Request durch Verwendung des `amr` (`authentication_method_reference`) Claims (gemäß [OpenID Connect Core 1.0#IDToken] ein JSON Array) unterstützen.

- Signalisiert eine Relying Party im Authorization Request die `amr`-Präferenz ohne das Attribut `essential` oder mit dem Attribut `essential` und dem Wert `false`, so SOLL der sektorale IDP diese Authentisierungsmittel in absteigender Reihenfolge der Auflistung bei der Authentisierung des Nutzers berücksichtigen. Wurde ein

aufgelistetes Authentisierungsmittel erfolgreich verwendet, so ist auf die Prüfung weiterer Authentisierungsmittel zu verzichten. Konnte kein angefordertes Authentisierungsmittel erfolgreich verwendet werden, so liegt es im Ermessen des sektoralen IDP, unter Berücksichtigung der Nutzerpräferenzen, welches Authentisierungsmittel zur Erfüllung des Authorization Request erforderlich ist.

- Signalisiert eine Relying Party im Authorization Request die `amr`-Präferenz mit dem Attribut `essential` und dem Wert `true`, so MUSS der sektorale IDP diese Authentisierungsmittel in absteigender Reihenfolge der Auflistung bei der Authentisierung des Nutzers berücksichtigen. Wurde ein aufgelistetes Authentisierungsmittel erfolgreich verwendet, so ist auf die Prüfung weiterer Authentisierungsmittel zu verzichten. Konnte kein angefordertes Authentisierungsmittel erfolgreich verwendet werden, so ist die Authentisierung mit einem Fehler (siehe [OpenID Connect Core 1.0#AuthError]) abzubrechen.

Bei der Auswahl des zu verwendenden Authentisierungsmittels MUSS der sektorale IDP sicherstellen, dass dieses für das im Authorization Request angeforderte `acr` nach [A_23129*] zulässig ist. Angeforderte `amr`, die dem `acr` nicht genügen, MÜSSEN ignoriert werden.
[<=]

Hinweis: ein Beispiel für den Aufbau der amr Präferenz ist der Tabelle "Parameter Pushed Authorization Request" in der Zeile "Claims" zu entnehmen

A_25753 -Verfahren zum Erzwingen einer Authentisierung des Nutzers
Der sektorale IDP MUSS mindestens die Verfahren "max_age=0" und "prompt=login" zur Durchsetzung der Benutzerauthentifizierung unterstützen. Verpflichtende Parameter, die sich daraus ergeben (z.B. auth_time), MÜSSEN gemäß [https://openid.net/specs/openid-connect-core-1_0.html] berücksichtigt werden.**[<=]**

A_23129-06 -Identifikation des Authentisierungsverfahren
Der sektorale IDP MUSS den Claim`amr` im ID_TOKENentsprechend dem durchgeführten Authentisierungsverfahren nach folgender Tabelle befüllen.

Tabelle 7: Codierung der Authentisierungsverfahren

Authentisierungsverfahren	**Wert des`amr` Claim**	**zulässiges Niveau (`acr`)**
Authentisierung mittels eGK und PIN	urn:telematik:auth:eGK	gematik-ehealth-loa-high
Authentisierung mittels elektronischem Identitätsnachweis (Online-Ausweisfunktion)	urn:telematik:auth:eID	gematik-ehealth-loa-high
Authentisierung mittels eGK und PIN ohne Prüfung Gerätebindung (Gastzugang)	urn:telematik:auth:guest:eGK	gematik-ehealth-loa-high
Authentisierung mittels PID einer zertifizierten EUDI-Wallet	urn:telematik:auth:eudiWallet	gematik-ehealth-loa-high
Anderes Authentisierungsverfahren	urn:telematik:auth:other	gematik-

		ehealth-loa-high und gematik-ehealth-loa-substantial
Authentisierungsverfahren mit Einwilligung für ein Single Sign-On (SSO) (deprecated)	urn:telematik:auth:sso	gematik-ehealth-loa-high gematik-ehealth-loa-substantial
Authentisierungsverfahren mit Einwilligung zum Zugriff auf Daten mit hohem Schutzbedarf (deprecated)	urn:telematik:auth:mEW	gematik-ehealth-loa-substantial

*Hinweis: Die Authentisierungsverfahren "urn:telematik:auth:sso" und "urn:telematik:auth:mEW"werden nach vollständiger Umsetzung der Anforderungen A_27591, A_27592 und A_27593 durch alle Teilnehmer der TI-Föderation aus der Anforderung entfernt.***[<=]**

Hinweis: Das Claim`amr` wird generell von sektoralen IDP im ID Tokengemäß der AnforderungA_23129- mitgeliefert. Bei dem Claim handelt es sich gemäß [OpenID Connect Core 1.0#IDToken]um ein JSON Array.*

Hinweis: Um ein bestimmtes Authentisierungsmittel bei der Nutzerauthentifizierung durch den sektoralen IDP zu erzwingen, fordert die Relying Party dies im Authorization Request mittels Claims Parameter an. Ein Beispiel kann der Tabelle "Parameter Pushed Authorization Request" in der Zeile zu Claims entnommen werden.

A_25239-01 -Authentifizierung mit eGK+PIN ohne Prüfung Gerätebindung (Gastzugang)
der sektorale IDP MUSS über sein Authenticator-Modul die Authentifizierung eines Nutzers mit eGK+PIN ohne Prüfung oder Anlegen einer Gerätebindung unterstützen, wenn eine Relying Party eine Nutzer-Authentifizierung `urn:telematik:auth:guest:eGK` beim sektoralen IDP anfordert. In diesem Fall MUSS, nach Übertragung des Zertifikates durch das Authenticator-Modul an den sektoralen IDP, dieser:

- die Gültigkeit und Signatur des AUT-Zertifikats der eGK prüfen,
- das Authentisierungsverfahren gegen Replay-Angriffe schützen,
- mittels Signaturanforderung das Vorliegen der korrekten PIN sicherstellen,
- sicherstellen, dass der öffentliche Schlüssel des AUT-Zertifikats dem öffentlichen Schlüssel aus der angeforderten Signatur entspricht,
- die Attribute des AUT-Zertifikats für die Erstellung des ID Token verwenden.

Hinweis: Ist der Nutzer bei der Krankenkasse versichert, bei dessen sektoralen IDP die Authentifizierung durchgeführt wird, so kann der sektorale IDP einen Nutzeraccount zu diesem Nutzer anlegen, wenn dieser noch nicht existiert.

Hinweis: Ist der Nutzer bei einer anderen Krankenkasse versichert als der, bei deren sektoralen IDP die Authentifizierung durchgeführt wird, so kann der sektorale IDP im

ausgestellten ID Token nur Scopes/Claimsbestätigen, die aus dem Zertifikat der eGK ermittelt, werden können.

[<=]

A_22867-01 -Signalisierung der Verwendung des Authentisierungsverfahrens "gematik-ehealth-loa-substantial" beim Zugriff auf Daten mit hohem Schutzbedarf (befristet)
Der sektoraler IDP MUSS den Claim`amr` um den Wert "urn:telematik:auth:mEW" erweitern, wenn der Fachdienst eine Authentifizierung des Nutzers auf dem Niveau`gematik-ehealth-loa-high` angefragt hat, der Nutzer jedoch ein Authentisierungsverfahren auf dem Niveau `gematik-ehealth-loa-substantial` verwendet hat. Die Einwilligung des Anwenders zur Nutzung dieses Verfahrens zum Zugriff auf Daten mit hohem Schutzbedarf MUSS vorliegen.**[<=]**

Hinweis: Die Anforderung gilt noch befristet bis zur vollständigen Umsetzung der Anforderungen A_27591, A_27592 und A_27593 durch alle Teilnehmer der TI-Föderation.

A_27591 -Signalisierung der Einwilligung durch den Nutzer in "gematik-ehealth-loa-substantial" beim Zugriff auf Daten mit hohem Schutzbedarf
Der sektorale IDP MUSS in den Custom Claim `urn:telematik:auth:consent` den Wert `loa-substantial` ergänzen, wenn der Fachdienst eine Authentisierung des Nutzers auf dem Niveau `gematik-ehealth-loa-high` angefragt, der Nutzer jedoch ein Authentisierungsverfahren auf dem Niveau `gematik-ehealth-loa-substantial` verwendet hat und die Einwilligung des Anwenders zur Nutzung dieses Verfahrens zum Zugriff auf Daten mit hohem Schutzbedarf vorliegt.**[<=]**

A_23103-01 -Einwilligung zur Verwendung des Authentisierungsverfahrens "gematik-ehealth-loa-substantial" beim Zugriff auf Daten mit hohem Schutzbedarf
Vor der Nutzung von Authentisierungsverfahren mit substantiellem Schutzniveau beim Zugriff auf Daten mit hohem Schutzbedarf nach A_22867 MUSS der sektorale IDP sicherstellen, dass die Einwilligung des Nutzers vollständig freiwillig erfolgt. Dabei müssen alternative Verfahren mit Sicherheitsniveau `gematik-ehealth-loa-high` hervorgehoben und die Möglichkeit des Widerrufs der Einwilligungserklärung aufgezeigt werden. Der Nutzer muss insbesondere über die Risiken einer Absenkung des Vertrauensniveaus informiert werden und der Verwendung eines Verfahrens mit einem anderen angemessenen Sicherheitsniveau zum Zugriff auf Daten mit hohem Schutzbedarf aktiv zustimmen.
[<=]

A_25248 -Protokollierung der Einwilligung zur Verwendung von Authentisierungsverfahren "gematik-ehealth-loa-substantial"
Der sektorale IDP MUSS dieEinwilligung des Nutzers zur Verwendung des Authentisierungsverfahrens `gematik-ehealth-loa-substantial`protokollieren.**[<=]**

Hinweis: Für die Protokollierung gilt "A_22236 - Auskunft an Versicherten".

A_22744 -Authenticator auf Zweitgerät
Der Hersteller eines sektoralen IDP MUSS ein technisches Verfahren für den Fall etablieren, dass ein Nutzer das Authenticator-Modul auf einem anderen Gerät betreibt als die Frontend Komponente des Fachdienstes, welcher eine Authentifizierung beim sektoralen IDP angefragt hat. In diesem Fall MUSS der sektorale IDP für den Auth-

Endpunkt ein WebFrontend bieten, welches die weitere Authentisierung über einen Authenticator auf einem anderen Gerät ermöglicht. **[<=]**

Hinweis: Für das Veranlassen zum Öffnen des Authenticator-Moduls durch den Nutzer gibt es unterschiedliche technische Möglichkeiten (z. B. scannen eines QR-Code von Web-Seite und Codeeingabe im Authenticator, 1-Faktor Login auf Web-Seite und push an Authenticator, u. a.). Diesbezüglich werden keine Anforderungen formuliert, es können auch mehrere Verfahren angeboten werden. Es müssen vom Hersteller jedoch Maßnahmen ergriffen werden, die klassische Angriffsszenarien auf den Authentisierungsvorgang wie z.B. Remote Phishing und/oder Session Spying verhindern bzw. erschweren.

A_22306-01 -Information des Nutzers bei fehlender Installation des gewählten Authenticator-Moduls
Der Hersteller eines sektoralen IDP MUSS ein technisches Verfahren für den Fall etablieren, dass ein Nutzer das Authenticator-Modul nicht installiert hat. In diesem Fall MUSS der sektorale IDP für den Auth-Endpunkt ein WebFrontend anbieten und dort darstellen, aus welcher Quelle das jeweilige Authenticator-Modul des sektoralen Identity Provider zu beziehen ist, auf welchen Geräten/Plattformen es installiert werden kann und welche Voraussetzungen für die Verwendung zur Authentifizierung zu erfüllen sind (z. B. erforderliche Registrierungsprozeduren beim Anbieter des sektoralen Identity Provider).**[<=]**

A_22257 -Operationsaufruf erfordert erfolgreiche Authentifizierung
Der sektorale Identity Provider MUSS sicherstellen, dass Authorization Request nur nach vorheriger erfolgreicher Authentifikation des Nutzers mit einem `AUTHORIZATION_CODE` beantwortet werden.**[<=]**

A_22235 -Information des Versicherten über Änderungen an Authentifizierungsfaktoren
Der Anbieter des sektoralen Identity Provider MUSS den Versicherten über Änderungen an Authentifizierungsfaktoren informieren.
Die Information des Versicherten kann dabei auch über die Attributbestätigende Stelle erfolgen, welche den Anbieter des sektoralen Identity Provider mit der Erstellung des elektronischen Identifizierungsmittels beauftragt hat.**[<=]**

Hinweis: Dies könnten z. B. Änderungen von E-Mail-Adressen, Mobilfunknummern, registrierten Geräten oder Kennwörtern sein. Die Informationen sollen über entsprechende Anzeige im Authenticator-Modul erfolgen.

A_22236-01 -Auskunft an Versicherten
Der Anbieter des sektoralen Identity Provider MUSS dem Versicherten auf dessen Verlangen Auskunft geben über:

- erfolgte Zugriffe auf das elektronische Authentisierungsmittel des Versicherten
- Änderungen der Authentifizierungsfaktoren des Versicherten
- Einwilligungen zur Verwendung des Authentisierungsverfahrens `gematik-ehealth-loa-substantial`

[<=]

Hinweis: Die Minimalinformationen bestehen aus Datum/Uhrzeit des Zugriffs, Authentisierungsmittel, Gerät. Weitere Informationen, die für die Nutzer sinnvoll sind optional.

Hinweis: Die Auskunft könnte z. B. über eine Protokollfunktion im Authenticator-Modul erfolgen. Die Auskunft des Versicherten kann auch über die Attributbestätigende

Stelle erfolgen, der den Anbieter des sektoralen IDP mit der Erstellung des elektronischen Identifizierungsmittels beauftragt hat.

A_23623 -Wahlfreiheit des Authentisierungsverfahren für TI-Anwendungen
Wenn der sektorale IDP neben dem elektronischen Identitätsnachweis (Online-Ausweisfunktion) und eGK+PIN weitere Authentisierungsverfahren auf dem Niveau `gematik-ehealth-loa-high` anbietet, so MUSS dem Nutzer die Möglichkeit gegeben werden auszuwählen, welche Verfahren (Online-Ausweisfunktion, eGK+PIN, weitere) für die Authentisierung bei TI-Fachanwendungen verwendet werden dürfen.
Dabei MUSS der sektorale IDP eine beliebige Auswahl (mindestens einer) der bereitgestellten Authentisierungsmethoden ermöglichen. Der Nutzer MUSS die Möglichkeit haben diese Auswahl zu ändern sowie ein bevorzugtes Verfahren festzulegen.
[<=]

4.4.2.1 Gerätenutzung

Die unterschiedliche Ausstattung der mobilen Geräte erfordert unterschiedliche Anforderung hinsichtlich der Authentifizierungsverfahren. Unterschieden werden:

- Geräte ohne Hardware Keystore
- Geräte mit Hardware Keystore
- Geräte mit zertifiziertem Secure Element.

Das Vorhandensein eines Hardware Keystore wird hierbei wie folgt definiert:

- Apple - Entscheidend ist das Vorhandensein eines "Secure Enclave" [support.apple.com/guide/security]. Diese ist Bestandteil der A7 und neueren Chips von Apple. Die A7 Serie wurde erstmals 2013 mit dem iPhone 5s eingeführt.
- Android - Ab Android 9 gibt es den Systemaufruf [KeyInfo#getSecurityLevel()], um die Speicherung eines Schlüssels im Hardware Keystore abzufragen. Die Rückgabewerte `KeyProperties.SECURITY_LEVEL_TRUSTED_ENVIRONMENT` , `KeyProperties.SECURITY_LEVEL_UNKNOWN_SECURE` oder `KeyProperties.SECURITY_LEVEL_STRONGBOX` sind zulässig. Ältere Systeme bieten die Schnittstelle [KeyInfo#isInsideSecureHardware()] an. Hier ist der Rückgabewert `true` zulässig.

A_22750-02 -Gerätebindung und Authentisierung für "gematik-ehealth-loa-high" und "gematik-ehealth-loa-substantial" (befristet bis 02.01.2027)

Abhängig von der Geräteausstattung des Nutzers ist eine Gerätebindung für einen festgelegten Zeitraum ohne Erneuerung gültig. Der Anbieter des sektoralen IDP MUSS, wenn er eine Gerätebindung im Rahmen eines Authentisierungsverfahren nutzt, die Zeitrahmen der Gültigkeit für die Gerätebindung gemäß Tabelle "Übersicht Gerätebindung" berücksichtigen. Beim Zugriff auf Daten mit hohem Schutzbedarf gelten die Zeiträume der maximalen Gerätebindung`gematik-ehealth-loa-high` in der Tabelle. Nach Einwilligung des Nutzers gemäß A_23103* gelten beim Zugriff auf Daten mit hohem Schutzbedarf, unter Verwendung von Authentisierungsverfahrens `gematik-ehealth-loa-substantial` die Zeiträume der maximalen Gerätebindung`gematik-ehealth-loa-substantial` in Tabelle "Übersicht Gerätebindung".
Die Gerätebindung MUSS durch den Nutzer nach Ablauf dieser Frist dementsprechend erneuert werden.
Der Anbieter des sektoralen IDP MUSS mit den zur Verfügung stehenden Plattformmechanismen, einen kryptographischen Nachweis der Gerätebindung auf dem Endgerät erzeugen und auf Serverseite prüfen (z.B. Android: Key & ID Attestation; iOS: DCAppAttestService).
Die Gerätebindung kann:

1. durch Identifikation, welche dem Niveau `gematik-ehealth-loa-high` entspricht oder
2. mit einer 2FA, welche dem Niveau `gematik-ehealth-loa-high` entspricht,

angelegt werden.

Tabelle 8: Übersicht Gerätebindung

Schlüsselspeicher	Gültigkeit der Gerätebindung
ohne Hardware Keystore	Die Gerätebindung kann mit einem Faktor aus den Bereichen Wissen oder Inhärenz genutzt werden: • 24h auf dem Niveau "gematik-ehealth-loa-high" • 48h auf dem Niveau "gematik-ehealth-loa-substantial"
mit Hardware Keystore	Die Gerätebindung kann mit einem Faktor aus den Bereichen Wissen oder Inhärenz genutzt werden: • 6 Monate auf dem Niveau "gematik-ehealth-loa-high" • 12 Monate auf dem Niveau "gematik-ehealth-loa-substantial"
mit zertifiziertem Secure Element	Die Gerätebindung kann mit einem Faktor aus den Bereichen Wissen oder Inhärenz genutzt werden: • unbegrenzt auf dem Niveau "gematik-ehealth-loa-high" • unbegrenzt auf dem Niveau "gematik-ehealth-loa-substantial

[<=]

Hinweis: Die Überprüfung, zu welcher der in der Tabelle aufgeführten Kategorien das Gerät mit dem Authenticator-Modul gehört, kann im Authenticator-Modul selbst erfolgen

oder alternativ beim sektoralen IDP durch Übermittlung der notwendigen Informationen vom Authenticator-Modul an den sektoralen IDP. Die Überprüfung der in der Tabelle je Kategorie genannten Gültigkeitszeiträume für eine Gerätebindung erfolgt beim sektoralen IDP.

Hinweis: In der Praxis erlaubt dieses Vorgehen primär die Nutzung von nicht zertifizierten Hardware Keystores für eine Authentisierung auf dem formalen Sicherheitsniveau`gematik-ehealth-loa-high` bzw. `gematik-ehealth-loa-substantial`.

Hinweis: Die Tabelle "Übersicht Gerätebindung für`gematik-ehealth-loa-high` bzw. `gematik-ehealth-loa-substantial`weicht ab von den Anforderungen A_23025 und A_23024. Die Kriterien für die in der Tabelle angegebene Gerätebindung genügen der Verwendung als Authentisierungsfaktor für`gematik-ehealth-loa-high`, der in A_23025 und A_23024 geforderten Angriffswiderstand muss nicht nachgewiesen werden.

A_23700-01 -Verwendung der Gerätesperre als Faktor zur Nutzerauthentifizierung
Ein sektoraler IDP KANN als Wissensfaktor für Android- und iOS-Geräte die vom Nutzer vergebene System-PIN oder das System-Passwort verwenden. Für die Nutzung der System-PIN MUSS die Einwilligung des Nutzers zur Verwendung des Authentisierungsverfahrens gematik-ehealth-loa-substantial beim Zugriff auf Daten mit hohem Schutzbedarf [A_23103] vorliegen.**[<=]**

A_25138-01 -Erneuerung der Gerätebindung für "gematik-ehealth-loa-high"
Nach Ablauf der Gültigkeitsdauer einer Gerätebindung DARF die bestehende Gerätebindung NICHT als Authentisierungsfaktor für die Erneuerung der Gerätebindung für `gematik-ehealth-loa-high` verwendet werden.
[<=]

A_23699 -Erstellung oder Erneuerung einer Gerätebindung an eine Nutzeridentität
Der Hersteller des sektoralen IDP MUSS zur Erstellung oder Erneuerung der Gerätebindung eine Identifizierung oder Authentifizierung des Nutzers auf dem Vertrauensniveau "gematik-ehealth-loa-high" durchführen. Die Nutzung einer bestehenden Gerätebindung zur Erneuerung einer Gerätebindung an eine Nutzeridentität ist gemäß A_25138 ausgeschlossen.**[<=]**

Hinweis: Eine Liste der zugelassenen Identifikationsverfahren ist von der gematik im Fachportal [Zulässigkeit von Identifikationsverfahren] veröffentlicht und wird regelmäßig aktualisiert.

Hinweis: Zulässige Authentifizierungsverfahren sind eGK+PIN sowie die Online-Ausweisfunktion.

A_25969 -Keine Nutzung einer Gerätebindung zur Einrichtung einer Gerätebindung
Eine Gerätebindung DARF NICHT mittels einer bestehenden Gerätebindung neu eingerichtet werden.**[<=]**

Hinweis: Dies gilt auch, wenn die bestehende Gerätebindung zum Zeitpunkt der Einrichtung der Vertrauensniveau `gematik-ehealth-loa-high` erfüllt.

4.4.2.2 Nutzung von Biometrie

A_23701-02 -Verwendung von Biometrie als Faktor zur Nutzerauthentifizierung
Der Anbieter des sektoralen IDP MUSS für die Nutzung von biometrischen Sensoren zur Nutzerauthentifizierung die in der Tabelle "Biometrie" aufgeführten Einschränkungen berücksichtigen. Für die Nutzung eines biometrischen Faktors MUSS, wenn damit eine Herabstufung des Vertrauensniveaus verbunden ist, die Einwilligung des Nutzers zur Verwendung des Authentisierungsverfahrens`gematik-ehealth-loa-substantial` beim Zugriff auf Daten mit hohem Schutzbedarf [A_23103] vorliegen.

Tabelle 9: Biometrie

LoA	Nutzung der biometrischen Sensoren der mobilen Plattformen als biometrischer Faktor	**Einschränkungen**
gematik-ehealth-loa-high	• Biometrische Sensoren, welche den Anforderungen mit BAL/LoA high (vgl. BSI TR-03107-1, TR-03166) genügen	keine
gematik-ehealth-loa-substantial	• Biometrische Sensoren, welche den Anforderungen mit BAL/LoA high (vgl. BSI TR-03107-1, TR-03166) genügen • Biometrische Sensoren, welche den Anforderungen mit BAL/LoA substantial (vgl. BSI TR-03107-1, TR-03166) genügen (Apple-FaceID)	keine
	• Biometrie Android - Nutzung eingeschränkt auf die Erfüllung Biometric.STRONG oder Class-3 • Apple-TouchID	Als Voraussetzung zur Verwendung dieser Übergangslösung ist es erforderlich, dass der Risikoträger im Rahmen einer "Risiko-Meldung" angemessen über die in Teilen leichte Überwindbarkeit dieser biometrischen Verfahren in leicht verständlicher Sprache und barrierearm informiert wird. Nach Einwilligung in die Übernahme des Risikos durch den Risikoträger dürfen die entsprechenden

		Verfahren angeboten werden.

[<=]

Hinweis: Apple-FaceID genügt gemäß BSI TR-03107-1/TR-03166 dem Vertrauensniveaus *gematik-ehealth-loa-substantial*

A_26591 -Einwilligung zur Verwendung biometrischer Sensoren
Der sektorale IDP MUSS die explizite Einwilligung zur Verwendung der in Tabelle "Biometrie" zugelassenen biometrischen Sensoren einholen, wenn diese Sensoren nicht die erforderliche Güte für die uneingeschränkte Nutzung auf dem Vertrauensniveau gematik-ehealth-loa-substantial beziehungsweise gematik-ehealth-loa-high erfüllen. Dabei MUSS der sektorale IDP sicherstellen, dass der Nutzer über die damit verbundenen Risiken hinreichend informiert wurde, die Einwilligung des Nutzers vollständig freiwillig erfolgt und die Einwilligung kryptografisch abgesichert ist.
Diese Einwilligung MUSS durch den sektoralen IDP für jedes Endgerät eingeholt werden, auf dem biometrische Sensoren verwendet werden, unabhängig von bereits erfolgten Einwilligungen auf anderen Endgeräten. Der sektorale IDP MUSS sicherstellen, dass erteilte Einwilligungen auf den jeweiligen Geräten durch den Nutzer für dieses Gerät widerrufen werden können.
[<=]

Hinweis: Unter "kryptographisch abgesichert" ist hierbei zu verstehen, dass mit technischen Mitteln (der Kryptographie) die Authentizität (ist dies die Einwilligung des Nutzers XYZ?) und Integrität (ist die Einwilligung unverändert bzw. originär?) der Einwilligung gewährleistet werden muss, um Risiken der Manipulation oder Falsch-Zuordnung dieser Einwilligungen entgegenzuwirken. Beispielsweise kann ein Schutzmechanismus unter Einsatz der System-PIN umgesetzt werden, der diese Eigenschaften implementiert.

4.4.2.3 Unterstützung Single-Sign-On (SSO) auf Anwendungsebene

A_23207-02 -Single-Sign-On (SSO) als Authentifizierungsverfahren (befristet)
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS im Claim `acr` das Niveau beauskunften, welcher dem der vorhergehenden Authentisierung entspricht. Der Claim `amr` MUSS um den Wert urn:telematik:auth:sso gemäß der Tabelle "Codierung der Authentisierungsverfahren" erweitert werden.**[<=]**

Hinweis: Die Anforderung gilt noch befristet bis zur vollständigen Umsetzung der Anforderungen A_27591, A_27592 und A_27593 durch alle Teilnehmer der TI-Föderation.

A_27592 -Signalisierung Single-Sign-On (SSO) als Authentifizierungsverfahren im ID Token
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS das Niveau im ID Token im Claim `acr` bestätigen, welches dem der vorhergehenden Authentifizierung entspricht. Der Custom Claim `urn:telematik:auth:interactive` MUSS im ID Token auf den Wert `silent` gesetzt werden, wenn eine SSO-Authentisierung ohne Benutzerinteraktion durchgeführt wurde.
[<=]

A_23208-03 -Zustimmung des Nutzer für SSO
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS, sofern die SSO-Präferenzen im Authenticator-Modul verwaltet werden, vor der Aktivierung eines SSO sicherstellen, dass die Einwilligung des Nutzers hierzu insbesondere aufgeklärt, vollständig freiwillig, unter Hervorhebung sichererer Verfahren und widerrufbar erfolgte. Der Nutzer MUSS über die Risiken des SSO ausreichend aufgeklärt werden und der Verwendung für jeden einzelnen Fachdienst aktiv zustimmen.
Hinweis 1: Die Anforderung gilt für die zeitlich befristete Übergangslösung. Diese wird von einer ePA-FdV unabhängigen SSO-Lösung nach Abnahme durch das BSI abgelöst.
Hinweis 2: SSO für TI-Anwendungen in einem ePA-FdV wird dort verwaltet und ist nicht Gegenstand dieser Anforderung.
*Hinweis 3: Diese Anforderung soll sicherstellen, dass z.B. für Funktionen einer Kasse ein sicheres SSO ermöglicht wird.***[<=]**

A_24721-02 -Ausstellen einer SessionID zu einem Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS zur Absicherung des SSO im Ablauf der ersten erfolgreichen Nutzerauthentisierung eine SessionID zum laufenden Nutzerkontext generieren und dem Authenticator-Modul des Anwendungskontextes übertragen. Der Hersteller MUSS sicherstellen, dass eine ausgestellte SessionID nur nach erfolgreicher Authentisierung und ausschließlich für den jeweiligen Nutzerkontext verwendet werden kann und spätestens nach der in A_23212 festgelegten Zeitspanne nach der letzten Nutzerinteraktion am Authenticator-Modul oder durch explizite Signalisierung der Beendigung des Anwendungskontextes durch die Anwendung gelöscht wird.**[<=]**

Hinweis: Unter Nutzerkontext sind die Informationen zu einem Nutzer zu verstehen, die mit der SessionID nach erfolgreicher Nutzerauthentifizierung mittels Authenticator durch den IDP assoziiert sind. Deshalb spricht man auch von einer Subject-Session, die durch die SessionID identifiziert ist. Der Anwendungskontext hingegen erstreckt sich über die Anwendung, also alle Komponenten und Dienste, die funktional für diese Anwendung benötigt werden.

A_24725-01 -Prüfung der SessionID zu einem Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS zur Absicherung des SSO jede Nutzerauthentisierung ohne Nutzerinteraktion die Gültigkeit, der vom Authenticator-Modul übertragenen SessionID überprüfen indem:

- die Signatur der SessionID mit dem zum Nutzer und zur SessionID gespeicherten public Key validiert wird,
- die SessionID mit der zum Nutzer gespeicherten SessionID verglichen wird,
- der Gültigkeitszeitraum der SessionID überprüft wird.

Ist die Prüfung nicht erfolgreich, so MUSS der sektorale IDP eine Nutzerauthentisierung mit Nutzerinteraktion durchführen.**[<=]**

A_23212-02 -Gültigkeitsdauer einer SessionID
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS sicherstellen, dass die vom sektoralen IDP zu einem Anwendungskontext ausgestellte SessionID ungültig wird und gelöscht werden muss, wenn:

- der Anwendungskontext, zu dem die SessionID erstellt wurde, beendet wurde
- der Nutzer bei offenem Anwendungskontext mindestens 10 Minuten inaktiv war
- die SessionID die maximale Gültigkeitsdauer von 1h überschreitet

In diesen Fällen ist eine erneute Nutzerauthentisierung mit aktiver Nutzerinteraktion notwendig.
[<=]

Hinweis: Unter iOS wird die Anwendung automatisch geschlossen, wenn der Nutzer 3 min inaktiv war.

5 Anforderungen an Authenticator-Module sektoraler IDP

5.1 Funktionsmerkmale Authenticator-Modul

Die folgende Beschreibung in diesem Kapitel gilt für Authenticator-Module sektoraler Identity Provider im Rahmen der Föderation. Entsprechende Vorgaben für die Authenticator-Modul des IDP-Dienstes finden sich in [gemSpec_IDP_Dienst].

Das Authenticator-Modul ist ein Modul, welches in einer Applikation für mobile Endgeräte wie Smartphones bereitgestellt wird.

Für Desktop-Plattformen kann der Hersteller eines sektoralen IDP ein Authenticator-Modul z.B. als SDK zur Integration in Desktop-Anwendungen anbieten.

Bei Nutzung eines Primärsystems wird die Funktionalität des Authenticator-Moduls vom Primärsystem selbst realisiert.

Die Bereitstellung desAuthenticator-Moduls für mobile Endgeräte erfolgt über die dem jeweiligen Betriebssystem üblicherweise zur Verfügung stehenden Portale in einer sicheren, für den Nutzer kostenfreien Form.

Aufgabe des Authenticator-Moduls ist die Nutzerauthentifizierung gegenüber dem sektoralen IDP, bei welchem der Nutzer als Identität hinterlegt ist. Eine weitere Aufgabe ist das Einholen der Zustimmung des Nutzers (Resource Owner) für den Zugriff durch Fachdienste auf Attribute des Nutzers (Consent-Freigabe).

Es können je sektoralem IDP ein oder mehrere Authenticator-Module existieren, welche die Authentisierung des Benutzers durchführen. Über die generellen Vorgaben zum Authentifizierungsverfahren hinaus werden hier keine funktionalen Vorgaben gemacht.

Der Anbieter des sektoralen IDP ist für seine Authenticator-Module zuständig. Eine organisatorische Zuständigkeitstrennung zwischen Authenticator-Modulen und Anbietern sektoraler IDP ist möglich. Ansprechpartner und verantwortlich bleibt in jedem Fall der Anbieter des sektoralen IDP - auch für Produkte von anderen Herstellern.

Aufgabe des Authenticator-Moduls ist, den zum Abruf der ID Token und Access Token benötigten `AUTHORIZATION_CODE`, mit Zustimmung des Nutzers (Resource Owner) und nach eingehender Überprüfung dessen Identität, zu beantragen. Dazu nimmt das Authenticator-Modul die Authentifizierungs-Anfrage des Anwendungsfrontends entgegen und reicht diese am Authorization-Endpunkt des sektoralen IDP ein. Der Authorization-Endpunkt des sektoralen IDP antwortet – nach positiver Validierung der Anfrage – mit einem`AUTHORIZATION_CODE`. Das Authenticator-Modul nimmt den`AUTHORIZATION_CODE` und leitet diesen an den Authorization Server bzw. an das Anwendungsfrontend weiter. Durch Übergabe des`AUTHORIZATION_CODE` erhält der Authorization Server bzw. Anwendungsfrontend am Token-Endpunkt das ID Token und Access Token (siehe auch [~~*ML-132465 - Missing cross-reference*~~]).

Schnittstellen des Authenticator-Moduls sind diejenigen, an welchen es Anfragen durch das Anwendungsfrontend oder Web-Frontend empfängt und jene, welche das Authenticator-Modul selbst verwendet, um mit dem Authorization-Endpunkt des sektoralen IDP in Kontakt zu treten.

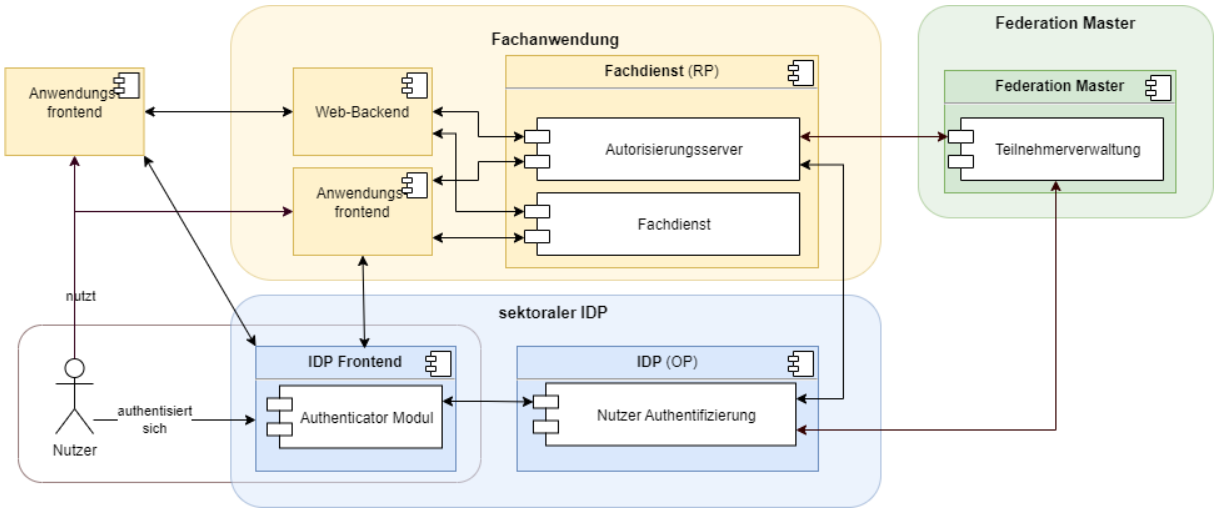


Abbildung 2: Systemkontext Authenticator-Modul

A_22939-01 -Widerspruch zur Weitergabe einzelner Claims
Authenticator-Module des sektoralen IDP MÜSSEN dem Nutzer die Möglichkeit geben, einem Dienst einzelne Claims nicht zu übermitteln. Für die Diensterbringung unbedingt erforderliche Claims ("essential claims") sollen dabei als nicht abwählbar dargestellt werden.
[<=]

Hinweis: Handelt es sich um eine dem sektoralen IDP bekannte Anwendung (z.B. durch direkte Registierung eines Kassendienstes im Rahmen der A_23044) ist es zulässig dem Nutzer nur das Annehmen/Ablehnen aller geforderten Scopes anzubieten.

A_22832 -Authenticator-Modul: Anzeige des "user_consent"
Das Authenticator-Modul des sektoralen IDP MUSS die Willenserklärung des Nutzers zur Übermittlung seiner in den Claims angeforderten Daten an den anfragenden Fachdienst über ein für den Betreiber des sektoralen IDP nicht einsehbares Verfahren einholen.**[<=]**

Hinweis: Die erfolgte Zustimmung des Nutzers darf gespeichert werden und weitere Abfragen können entfallen.

Hinweis: Stellt der Anbieter des sektoralen Identity Provider das Authenticator-Modul nicht als eigene Anwendung, sondern z. B. über ein SDK für die Integration in andere Anwendungen zur Verfügung, so muss er lediglich die Schnittstellen zur Anzeige des "user_consent" bereitstellen.

A_23051 -Authenticator-Module für Android und iOS
Der Anbieter des sektoralen Identity Provider MUSS den Nutzern Authenticator-Module für Android (im Google Play Store) und iOS (imApp Store) bereitstellen. Weitere Verbreitungswege sind zulässig aber nicht verpflichtend.**[<=]**

A_22277-01 -Authenticator-Modul: Schutz vor überalterter Software
Der Anbieter des sektoralen Identity Provider MUSS dafür Sorge tragen, dass die in App Stores veröffentlichten Authenticator-Module schnellstmöglich aktualisiert und die Nutzer über Updates informiert werden.**[<=]**

Hinweis: Stellt der Anbieter des sektoralen IDP das Authenticator-Modul als SDK zur Verfügung (z.B. für die Integration in die kasseneigenen Apps) so sind A_23051 und A_22277-01 unwirksam. Das sollte dann in der Anbietererklärung zum Ausdruck kommen. Eine Notwendigkeit zur Prüfung der integrierenden Apps ist nicht gegeben.

A_23389-01 -Authenticator-Modul: Schutz vor Missbrauch
Das Authenticator-Modul für mobile Endgeräte des sektoralen IDP MUSS

- Geräte mit Jailbreak oder Root-Zugriff entsprechend dem aktuellen Stand der Technik erkennen. Das Authenticator-Modul MUSS dem Nutzer darstellen, welche Risiken für die Daten des Nutzers bestehen (z. B., dass diese offengelegt werden könnten) und die Fortsetzung unterbinden.
- den Start in einer Entwicklungs-/Debug-Umgebung sicher erkennen und unterbinden.
- den Start abbrechen, falls es unter ungewöhnlichen Benutzerrechten gestartet wird (z. B. root oder nobody).
- Zertifikats-Pinning für die Verbindung zum sektoralen IDP unterstützen. Es DARF Zertifikate NICHT akzeptieren, deren Zertifikatskette dem Hersteller nicht vertrauenswürdig erscheint [RFC746].

[<=]

Hinweis: Die Anforderung orientiert sich an Prüfaspekt 11 (Resilienz) der TR-03161 des BSI.

A_22659 -Realisierung der App2App-Kommunikation im Fall Android
Im Kontext von Android-Anwendungen MÜSSEN Authenticator-Module zu sektoralen IDP für die wechselseitige Verlinkung den unter [ANDROIDAPPLINKS] beschriebenen App-Link-Mechanismus verwenden und damit Aufrufe an die Adresse des Authorization-EP ermöglichen.**[<=]**

A_22660 -Realisierung der App2App-Kommunikation im Fall Apple/iOS
Im Kontext von iOS-Anwendungen MÜSSEN Authenticator-Module zu sektoralen IDP für die wechselseitige Verlinkung den unter [APPLEUNIVERSAL] beschriebenen Universal-Link-Mechanismus verwenden und damit Aufrufe an die Adresse des Authorization-EP ermöglichen.**[<=]**

A_22661 -Serverseitige Registrierungsdaten
Anbieter von sektoralen IDP MÜSSEN sicherstellen, dass die durch das Betriebssystem notwendigen Voraussetzungen für die Funktionsfähigkeit ihres Authenticator-Moduls erfüllt sind (z. B. Registrierung der Anwendung zur App2App-Kommunikation entsprechend der Mechanismen unter [ANDROIDAPPLINKS] bzw. [APPLEUNIVERSAL] zur Verknüpfung der Anwendung mit einer Webseite).**[<=]**

A_23203-01 -Zu unterstützende Betriebssystemversionen
Der Anbieter des sektoralen Identity Provider MUSS dafür Sorge tragen, dass seine Authenticator-Module für mobile Endgeräte jederzeit:

- iOS Betriebssystem: Die noch offiziell von Apple mit OS-Updates versorgten Geräte
- Android-Betriebssystem: Versionen mindestens der letzten zwei Jahre

unterstützen.
[<=]

Hinweis: Der Anbieter des IDP kann bei Sicherheitsbedenken von A_23203 abweichend Betriebssystemversionen ausschließen.

A_22308-01 -Beschränkung des Authenticator-Moduls eines sektoralen IDP auf die Authentifizierung
Das Authenticator-Modul beim Aufruf durch das Anwendungsfrontend DARF NICHT weitere/andere Funktionalitäten anbieten als solche, die direkt oder indirekt zur Authentifizierung des Nutzers dienen (z. B. Einrichtung, Registrierung, dafür relevante

Informationen). Insbesondere Werbung für andere Leistungen oder Funktionen DARF NICHT angezeigt werden.**[<=]**

A_22311 -Verwendung der ursprünglichen Adresse zur Übergabe des "AUTHORIZATION_CODE"
Authenticator-Module von sektoralen Identity Provider MÜSSEN die bei der Übergabe des Authorization Request erhaltene`redirect_uri`für die Übergabe des `AUTHORIZATION_CODE` verwenden. Außer für diesen Aufruf DARF er NICHT an andere Anwendungen übergeben werden.**[<=]**

A_22978-01 -Aufbereiten von Geräteinformationen
Authenticator-Module von sektoralen IDP für mobile Endgeräte SOLLEN Informationen zum verwendeten Endgerät des Nutzers erheben können welche die Inhalte des Datentyps "Device_Type" abbilden.
Um die Authentizität des Datensatzes zu gewährleisten, muss die Vertrauenswürdigkeit zum Zeitpunkt der Erhebung des Datensatzes geprüft und nachgewiesen werden. Hierfür müssen geeignete und zur Verfügung stehende Plattformmechanismen genutzt werden (z. B. Android: SafetyNet Attestation / Integrity API, Key & ID Attestation; iOS: DCAppAttestService).**[<=]**

Der Datentyp "Device_Type" wird perspektivisch zur Übertragung von Informationen über einen Gerätetyp vom Authenticator-Modul zum sektoralenIDP verwendet. Der Datensatz wird vom Authenticator-Modul produziert und soll dem sektoralen IDP dazu dienen, TI-Weite Vorgaben zur Zulässigkeit von mobilen Endgeräten bei der Authentisierung umzusetzen. Der Datentyp umfasst die Elemente des folgenden Schemas:

Tabelle 10: Schema Datentyp "Device_Type"

Name	Type	Hinweise
`device_type_data_version`	JSON/String, konstant "1.1"	-
`manufacturer`	JSON/String	Name des Herstellers eines Geräts
`product`	JSON/String	Produktname des Geräts gegenüber dem Endkunden
`model`	JSON/String	Name des Modells
`keystore`	JSON/Boolean	Ist ein Hardware Keystore vorhanden?
`os`	JSON/String	Betriebssystem
`os_version`	JSON/String	Version des Betriebssystems
`security_patchlevel`	JSON/String	Format "YYYY-MM-DD"

Hinweis: Die in Tabelle Schema Datentyp "Device_Type" aufgeführten Parameter sind nach aktuellem Kenntnisstand für eine Geräteprüfung notwendig. Die Tabelleninhalte können sich in späteren Releases aufgrund neuer Erkenntnisse oder geänderter sicherheitstechnischer Anforderungen ändern.

A_23031 -Authenticator-Modul: OAuth 2.0 Pushed Authorization Request (PAR)
Das Authenticator-Modul MUSS mittels App2App-Kommunikation übertragene Anfragen entsprechend [RFC9126#section-4] annehmen und gewährleisten, dass der Request TLS-gesichert in die vertrauenswürdige Ausführungsumgebung des sektoralen IDP übermittelt wird.**[<=]**

A_27586 -Authenticator-Modul: Widerruf von Nutzerpräferenzen
Das Authenticator-Modul eines sektoralen IDP MUSS den Nutzern die Möglichkeit zum Widerruf einer erteilten gespeicherten Willenserklärung zur Freigabe seiner Daten für die Nutzung durch Fachdienste bieten.
[<=]

5.2 Single-Sign-On (SSO) auf Anwendungsebene

Verwenden Versicherte innerhalb einer Anwendung mehrere TI-Fachdienste, so müssten sie sich bei jeder Ausführung eines Fachdienstes jeweils gegenüber des sektoralen IDP authentifizieren. Bei einem Single-Sign-On für alle TI-Fachdienste innerhalb einer Anwendung wird es dem Versicherten ermöglicht, nach einmaliger Authentifizierungmit aktiver Nutzeraktion alle TI-Fachdienste in der Anwendung ohne weitere Authentifizierung zu nutzen. Die Verwendung mehrerer Fachdienste nach einmaliger Authentisierung innerhalb einer Anwendung wird hier als "Single-Sign-On auf Anwendungsebene" bezeichnet.

Ein Beispiel für die Verwendung von SSO auf Anwendungsebene:

Der Nutzer bewegt sich in der APP seinem ePA-FdV (in der Regel in der App seiner Krankenkassen). Neben den kassenspezifischen Funktionen bietet die APP auch Fachdienste der TI-Föderation wie ePA und TIM an. Möchte der Nutzer einen Fachdienst der TI-Föderation in der APP nutzen, so muss er sich gegenüber des sektoralen IDP der Krankenkasse authentisieren. Der Anwender möchte diesen Authentisierungsablauf nur einmal (z.B. beim Start der Anwendung) durchführen müssen (SSO auf Anwendungsebene).

5.2.1 Überblick

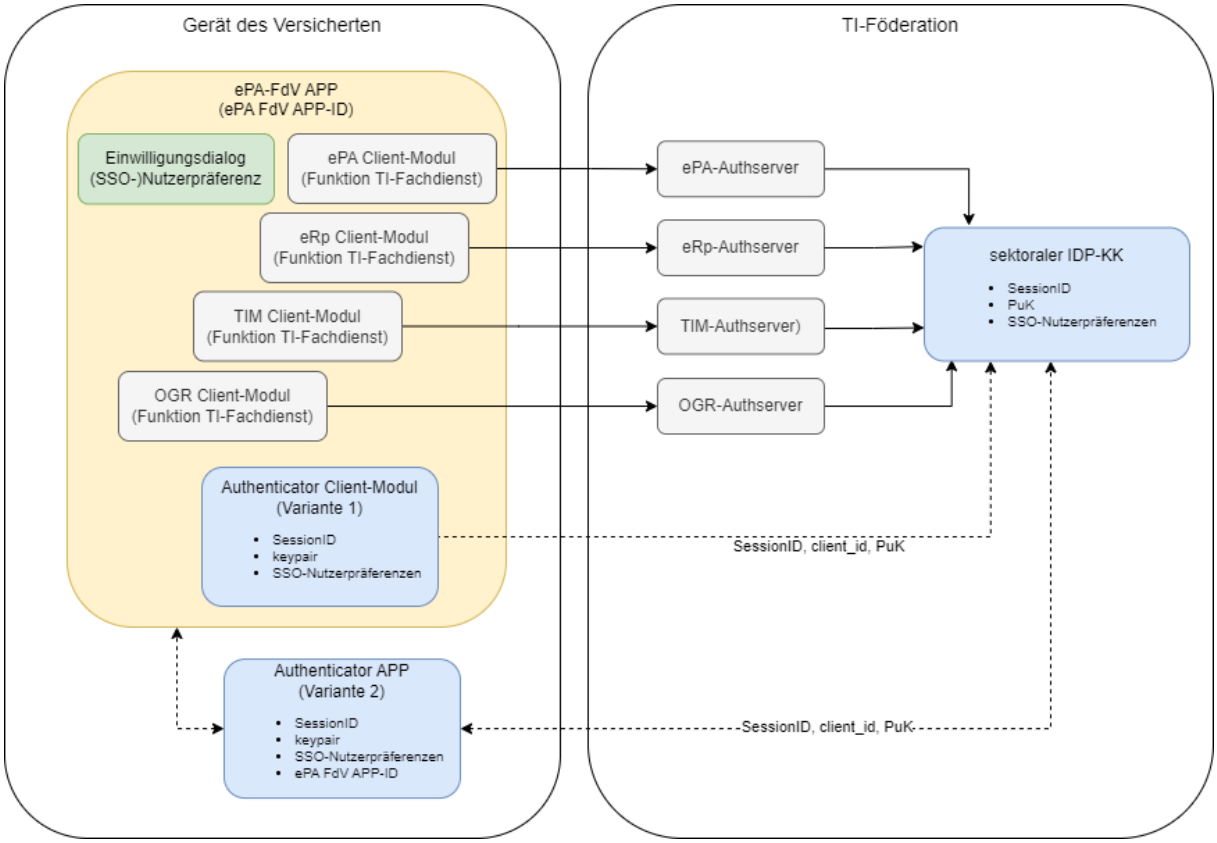


Abbildung 3 : Überblick

5.2.2 Rahmenbedingungen

Unter folgenden Rahmenbedingungen ist ein Single-Sign-On möglich:

- Ein SSO erstreckt sich ausschließlich über die TI-Fachdienste, die innerhalb eines Anwendungskontextes (ePA-FdV) vom Nutzer aufgerufen werden können.
- Ist das Authenticator-Modul des sektoralen IDP, über welchen der Nutzer sich authentisiert, ebenfalls Teil des Anwendungskontextes, so muss sein Frontend im Ablauf der Nutzerauthentisierung eine vom Authenticator-Modul bereitgestellt API-Schnittstelle aufrufen.
- Ist das Authenticator-Modul des sektoralen IDP, über welchen der Nutzer sich authentisiert, eine Authenticator APP, so muss im Ablauf der Nutzerauthentisierung sichergestellt werden, dass das Authenticator-Modul immer vom gleichen Anwendungskontext (ePA-FdV) aufrufen wird.
- Der Nutzer muss sich im Anwendungskontext mindestens einmal aktiv auf dem Vertrauensniveau "gematik-loa-high" authentifizieren.
- Für die Laufzeit eines Anwendungskontextes (Laufzeit der Anwendung) wird vom sektoralen IDP eine SessionID generiert.
- Zu einem Anwendungskontext wird durch das Authenticator-Modul ein Schlüsselpaar im systemeigenen Schlüsselspeicher erzeugtund der SessionID zugeordnet.
- Der Nutzer muss innerhalb des Anwendungskontextes konfigurieren können, welcher Fachdienst an einem SSO-Verfahren teilnehmen darf.

Die Anforderungen in diesem Kapitel und die zusätzlichen Informationen im [~~ML-154741 - Missing cross-reference~~] betreffen nur Hersteller, die ein SSO auf Anwendungsebene implementieren. Für Hersteller, die kein SSO auf Anwendungsebene umsetzen, gelten die Anforderungen dieses Kapitels nicht.

A_24722-01 -Ausstellen eines Schlüssels zu einem Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS zur Absicherung des SSO nach der ersten erfolgreichen Nutzerauthentisierung im Schlüsselspeicher des Nutzergerätes ein Schlüsselpaar generieren und an den laufenden Anwendungskontext sowie an der vom sektoralen IDP erhaltenen SessionID binden. Das Authenticator-Modul MUSS nach der ersten erfolgreichen Nutzerauthentisierung den öffentlichen Schlüssel und die mit dem privaten Schlüssel signierte SessionID zum Anwendungskontext an den sektoralen IDP übertragen. Der Hersteller von sektoralen IDP MUSS sicherstellen, dass das zu einem Anwendungskontext generierte Schlüsselpaar und SessionID nach dem Schließen des Anwendungskontextes aus dem Schlüsselspeicher des Geräts gelöscht wird.
[<=]

A_24768-02 -Schutz vor Replay-Attacken innerhalb eines Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS ein geeignetes Verfahren zum Schutz vor Replay-Attacken implementieren.
[<=]

Hinweis: Ein solches Verfahren kann beispielsweise durch eine Erneuerung des im Authenticator-Modul zum laufenden Anwendungskontext generierten Schlüsselpaares nach spätestens 3 Minuten und eine geschützte Übertragung des öffentlichen Schlüssels zum IDP umgesetzt werden.

Hinweis: Die beispielhaften Ablaufsequenzen (Key-Rotation und Server-Nonce) sind informativ im Anhang dargestellt.

A_24723-01 -Signieren der SessionID zu einem Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS zur Absicherung des SSO bei jeder Nutzerauthentisierung ohne Nutzerinteraktion im Authenticator-Modul die vom sektoralen IDP übertragenen SessionID zur laufenden Anwendungsinstanz mit dem zur SessionID auf dem Gerät des Versicherten gespeicherten Schlüssel signieren und an den sektoralen IDP übertragen.
[<=]

A_24748-01 -SSO-Unterstützung auf Anwendungsebene innerhalb einer APP
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS in seinem Authenticator-Modul eine Schnittstelle anbieten, der das Client-Modul bzw. Frontend eines TI-Fachdienstes die vom sektoralen IDP als Ergebnis des Pushed Authorization Request ausgestellte URI-PAR übergeben kann (siehe [gemSpec_IDP_Sek#Tabelle Ablaufbeschreibung App-App-Flow] Schritt 5). Die Schnittstelle MUSS als Ergebnis des Aufrufs den vom sektoralen IDP nach erfolgreicher Nutzerauthentisierung ausgestellten AUTH_CODE an das aufrufende Client-Modul zurückgeben.**[<=]**

Hinweis: Weitere Parameter des OAuth2 Authorization Code Flow mit PKCE wie `client_id`, `state`, `code_challenge` oder `code_verifier` werden konform zu [RFC7636] bzw. [RFC6749#section-4.1] in den jeweiligen Requests/Responses übertragen.

Hinweis: Ein Beispielablauf für SSO-Unterstützung auf Anwendungsebene innerhalb einer APP ist im [~~ML-154739 - Missing cross-reference~~] dargestellt.

A_25870 -SSO-Unterstützung auf Anwendungsebene bei separater Authenticator-APP
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS in seinem Authenticator-Modul sicherstellen, dass ein Authorization Request mit SSO-Anforderung von einem Anwendungsfrontend kommt, bei dem der Versicherte sich bereits authentifiziert hat, um SSO-Anforderungen von nicht berechtigten Anwendungen erkennen und ablehnen zu können.**[<=]**

Hinweis: Ein Beispielablauf für SSO-Unterstützung auf Anwendungsebene bei separater Authenticator-APP ist in [~~ML-154740 - Missing cross-reference~~] dargestellt.

A_24749-01 -Validierung gegen Nutzerzustimmung
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS vor einer Nutzerauthentisierung ohne Nutzerinteraktion prüfen, ob für den Fachdienst, welche die Nutzerauthentisierung angefordert hat, die Zustimmung zum SSO-Verfahren durch den Nutzer vorliegt. Eine Nutzerauthentisierung ohne Nutzerinteraktion darf nur bei Zustimmung durchgeführt werden.
[<=]

Hinweis: Die Information, ob der Nutzer dem SSO-Verfahren für einen Fachdienst zugestimmt hat, kann über technische unterschiedliche Implementierungen dem Authenticator-Modul zur Verfügung gestellt werden.

A_25238 -Nachnutzung SSO für kasseneigene Dienste im FdV
Ein Anbieter eines sektoralen IDP KANN das Verfahren SSO innerhalb eines Anwendungskontextes für anbieterspezifische Dienste nachnutzen, wenn diese Dienste im gleichen Anwendungskontext genutzt werden und durch geeignete sicherheitstechnische Maßnahmen eine Beeinflussung der TI-Dienste ausgeschlossen werden kann.**[<=]**

Hinweis: Ein Beispiel für die Nachnutzung von SSO sind kasseneigene Dienste, welche in das ePA-FdV integriert sind.

A_25875-01 -Aktive Nutzerauthentifizierung im Anwendungskontext
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS vor einer Nutzerauthentisierung ohne Nutzerinteraktion prüfen, ob der Nutzer sich im laufenden Anwendungskontext bereits aktiv auf dem Vertrauensniveau `gematik-ehealth-loa-high`oder auf dem Vertrauensniveau `gematik-ehealth-loa-substantial` zu welchem eine Einwilligung des Anwenders zur Nutzung dieses Verfahrens zum Zugriff auf Daten mit hohem Schutzbedarf vorliegt, authentifiziert hat.**[<=]**

5.2.3 SSO auf Anwendungsebene ePA-FdV

A_27567 -Beschränkung der Fachdienst für ein SSO (befristet)

Der sektorale IDP MUSS sicherstellen, dass ein Single-Sign-On nur für im ePA-FdV gebundene Fachdienste erfolgen kann.
Hinweis 1: Die Client-ID (iss) der im ePA-FdV gebundenen Fachdienste können beispielsweise als allow-list im sektoralen IDP hinterlegt sein.
Hinweis 2: Die Anforderung gilt für die zeitlich befristete Übergangslösung. Diese wird von einer ePA-FdV unabhängigen SSO-Lösung nach Abnahme durch das BSI abgelöst. **[<=]**

A_27568-01 -Widerruf und Reaktivierung der SSO-Präferenzen bei separater Authenticator-APP (befristet)
Ein Hersteller von sektoralen IDP, der ein SSO auf Anwendungsebene implementiert, MUSS sicherstellen, dass ein Nutzer Präferenzen zur SSO-Nutzung ausschließlich über sein Authenticator-Modul widerrufen und reaktivieren kann, sofern die verwalteten Anwendungen nicht Anwendungen der TI sind.
Hinweis 1: Die Anforderung gilt für die zeitlich befristete Übergangslösung. Diese wird von einer ePA-FdV unabhängigen SSO-Lösung nach Abnahme durch das BSI abgelöst.
Hinweis 2: SSO für TI-Anwendungen in einem ePA-FdV wird dort verwaltet und ist nicht Gegenstand dieser Anforderung.
Hinweis 3: Diese Anforderung soll sicherstellen, dass z.B. für Funktionen einer Kasse ein sicheres SSO ermöglicht wird.
[<=]

A_27570 -Annahme des Parameters Instance-ID im URI-PAR bei separater Authenticator-App (befristet)
Für eine SSO-Unterstützung auf Anwendungsebene bei separater Authenticator-App MÜSSEN Authenticator-Module von sektoralen IDPs für mobile Endgeräte den Parameter `sso_instance_id` bei Vorhandensein aus einem URI-PAR-Aufruf entgegennehmen und auswerten können. Wird ein`sso_instance_id` übergeben, so MUSS der Authenticator eine Nutzerauthentifizierung über Single-Sign-On beim sektoralen IDP initiieren.

Hinweis: Die Anforderung gilt für die zeitlich befristete Übergangslösung. Diese wird von einer ePA-FdV unabhängigen SSO-Lösung nach Abnahme durch das BSI abgelöst.
[<=]

5.3 Verwaltung eGK

Das Authenticator-Modul des sektoralen IDP stellt im Rahmen der Anwendungsübergreifenden GesundheitsID den einzigen Kontaktpunkt zur elektronischen Gesundheitskarte dar. Daher soll dieses anstelle von Anwendungsspezifischen Funktionen im Rahmen des ePA und/oder E-Rezept Frontend eine Möglichkeit zur Verwaltung der eGK-PIN bereitstellen.

5.3.1 PIN der eGK ändern

Mit diesem Anwendungsfall kann der Nutzer das Geheimnis der PIN einer eGK ändern.

A_15497-04 -Authenticator-Modul: PIN der eGK ändern
Das Authenticator-Modul von sektoralen IdPs gesetzlicher Krankenkassen KANN den Anwendungsfall "PIN der eGK ändern" gemäß TAB_FdV_156 umsetzen.

Tabelle 11: TAB_FdV_156 – PIN der eGK ändern

Name	PIN der eGK ändern
Auslöser	• Auswahl des Anwendungsfalls in der GUI
Akteur	Versicherter oder berechtigter Vertreter
Vorbedingung	Die eGK des Nutzers ist mit dem Kartenlesegerät verbunden.
Nachbedingung	PIN wurde geändert
Standardablauf	Die Umsetzung ist in TAB_FdV_157 beschrieben 1. PL_TUC_CARD_CHANGE_PIN nutzen 2. PL_TUC_CARD_CHANGE_PIN Ergebnis verarbeiten 3. Ergebnis anzeigen

Tabelle 12: TAB_FdV_157 – Ablaufaktivitäten – PIN der eGK ändern

1. PL_TUC_CARD_CHANGE_PIN nutzen	
Plattformoperation	PL_TUC_CARD_CHANGE_PIN
Eingangsdaten	
Identifikator	MRPIN.home
Benutzerhinweis am Kartenterminaldisplay (Sicherheitsklasse 3) bzw. im FdV-Benuzterinterface bei Aufruf der Umgebungsoperation ENV_TUC_SECRET_INPUT	Alte PIN: "Eingabe alte PIN: " bzw. Neue PIN: "Eingabe neue PIN: "
Beschreibung	Der Plattformbaustein wird zur Änderung den PIN genutzt.
2. Rückgabewert von PL_TUC_CARD_CHANGE_PIN verarbeiten	
Rückgabedaten	
OK	PIN erfolgreich geändert
Fehlerfälle	Siehe Beschreibung PL_TUC_CARD_CHANGE_PIN

Beschreibung	Das Ändern einer PIN auf der eGK basiert auf der parametrierten Plattformbaustein PL_TUC_CARD_CHANGE_PIN. Diese liefert einErgebnis zurück. Zur Änderung muss zwingend die Eingabe der alten PIN erfolgen. Wird durch den Versicherten ein falsches altes PIN-Geheimnis eingegeben, wird die verbleibende Anzahl der Eingabeversuche bis zur Sperrung des PINs zurückgemeldet. Im Fehlerfall wird eine Fehlermeldung entsprechenden Details zurückgegeben.
3. Ergebnis anzeigen	
Hinweis an den Versicherten	Die Rückgabedaten des Plattformbausteins enthalten Informationen über den Erfolg der Operation auf der eGK des Versicherten. Im Fehlerfall wird der Versicherte in verständlicher Form über den Fehler informiert. Im Erfolgsfall ist dem Versicherten eine Bestätigung zur Anzeige zu bringen. Falls eine Warnung aufgetreten ist, wird diese dem Versicherten in verständlicher Form angezeigt. Bei einer Fehleingabe der PIN des Versicherten wird dem Versicherten die verbleibende Anzahl der Eingabeversuche bis zur Sperrung der PIN zurückgemeldet.

[<=]

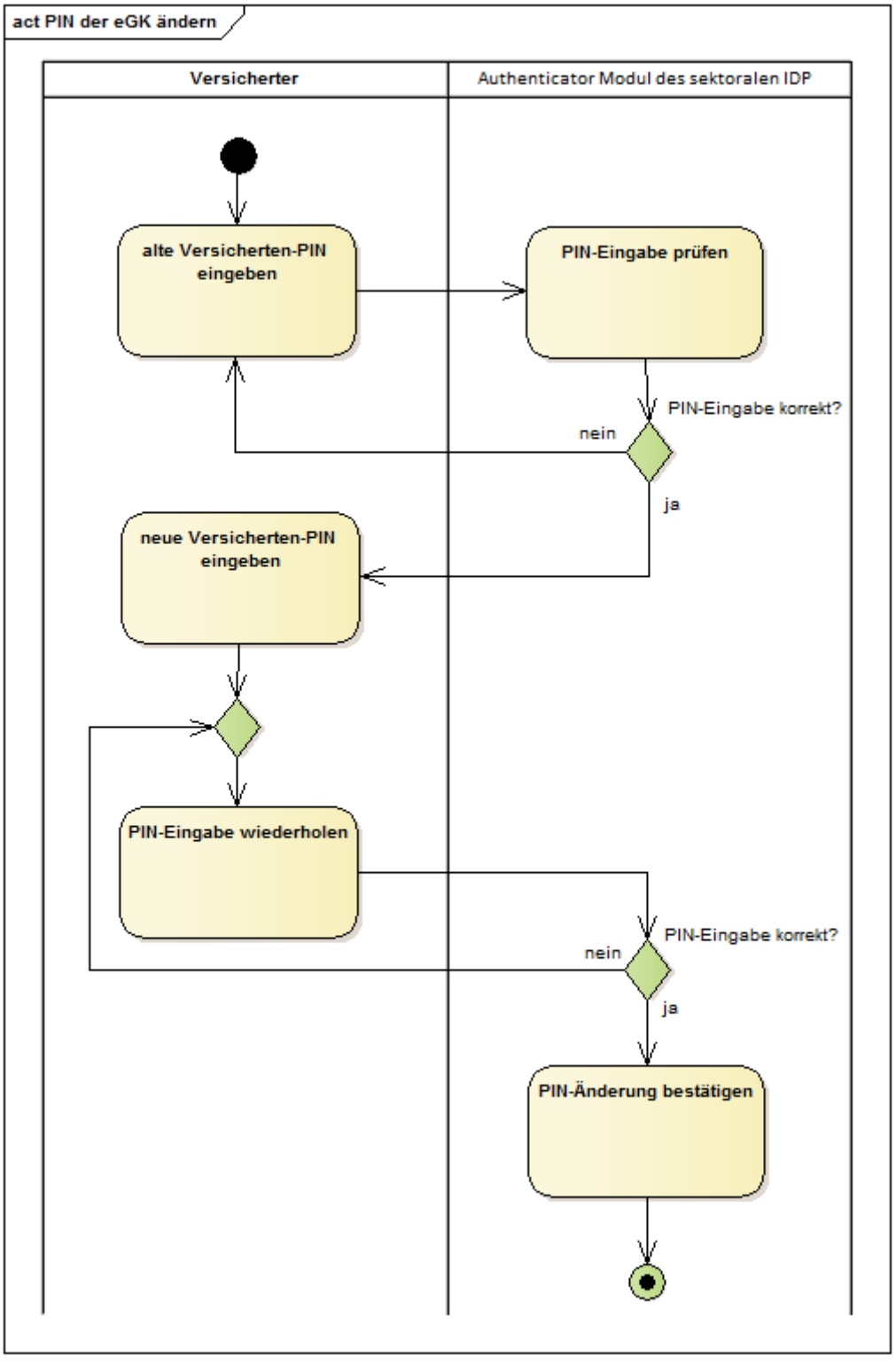


Abbildung 4: Aktivitätsdiagramm "PIN der eGK ändern"

5.3.2 PIN der eGK entsperren

Mit diesem Anwendungsfall kann der Nutzer den gesperrten PIN einer eGK mit der PUK entsperren.

A_15498-04 -Authenticator-Modul: PIN der eGK entsperren
Das Authenticator-Modul von sektoralen IdPs gesetzlicher Krankenkassen KANN den Anwendungsfall "PIN der eGK entsperren" gemäß TAB_FdV_158 umsetzen.

Tabelle 13: TAB_FdV_158 – PIN der eGK entsperren

Name	PIN der eGK entsperren
Auslöser	• Auswahl des Anwendungsfalls in der GUI
Akteur	Versicherter oder berechtigter Vertreter
Vorbedingung	Die eGK des Nutzers ist mit dem Kartenlesegerät verbunden. Die PIN der eGK (MRPIN.home) ist gesperrt.
Nachbedingung	PIN des Versicherten wurde entsperrt.
Standardablauf	Die Umsetzung ist in TAB_FdV_159 beschrieben 1. PL_TUC_CARD_UNBLOCK_PIN nutzen 2. PL_TUC_CARD_UNBLOCK_PIN Ergebnis verarbeiten 3. Ergebnis anzeigen

Tabelle 14: TAB_FdV_159 – Ablaufaktivitäten – PIN der eGK entsperren

1. PL_TUC_CARD_UNBLOCK_PIN aufrufen	
Plattformbaustein	PL_TUC_CARD_UNBLOCK_PIN
Eingangsdaten	
Identifikator	MRPIN.home
Benutzerhinweis am Kartenterminaldisplay (Sicherheitsklasse 3) bzw. im FdV-Benuzterinterface bei Aufruf der Umgebungsoperation ENV_TUC_SECRET_INPUT	PUK: "Eingabe PUK: " bzw. Neue PIN: "Eingabe neue PIN: "
Beschreibung	Für das Entsperren der PIN wird ein Plattformbaustein genutzt.
2. PL_TUC_CARD_UNBLOCK_PIN Ergebnis verarbeiten	
Rückgabedaten	

0K	PIN wurde entsperrt.
PasswordBlocked	Die PUK wurde wegen zu häufiger Nutzung gesperrt. Der Versicherte muss darüber in verständlicher Form informiert und auf die Notwendigkeit einer neuen eGK hingewiesen werden.
Weitere Fehlerfälle	Siehe Beschreibung PL_TUC_CARD_UNBLOCK_PIN
Beschreibung	Das Entsperren einer PIN auf der eGK basiert auf dem parametrierten Plattformbaustein PL_TUC_CARD_UNBLOCK_PIN. Zum Entsperren muss zwingend die Eingabe einer PUK erfolgen. Wird durch den Versicherten ein falsches PUK-Geheimnis eingegeben, wird die verbleibende Anzahl der Eingabeversuche bis zur Sperrung des PUKs zurückgemeldet. Im Fehlerfall wird eine Fehlermeldung mit entsprechenden Details zurückgegeben.
3. Ergebnis anzeigen	
Hinweis an den Versicherten	Die Rückgabedaten des Plattformbausteins enthalten Informationen über den Erfolg der Operation auf der eGK des Versicherten. Im Fehlerfall wird der Versicherte in verständlicher Form über den Fehler informiert. Im Erfolgsfall ist dem Versicherten eine Bestätigung zur Anzeige zu bringen. Falls eine Warnung aufgetreten ist, wird diese dem Versicherten in verständlicher Form angezeigt.

[<=]

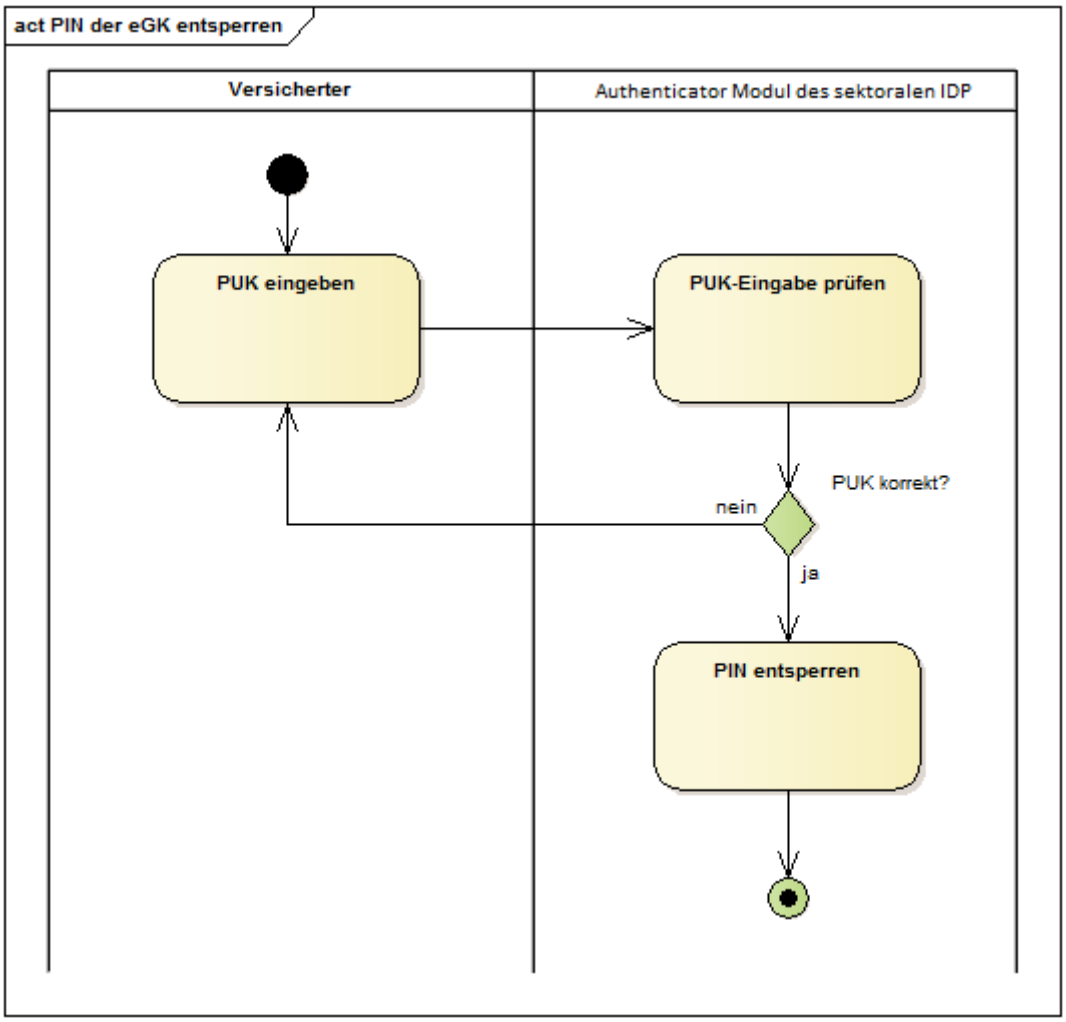


Abbildung 5: Aktivitätsdiagramm "PIN der eGK entsperren"

5.4 Authenticator-Modul für Desktop-Plattformen Anwendungen

A_26133 -Authenticator-Modul für Desktop-Plattformen: Integration in Anwendung
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS in die Anwendung integriert sein, die eine Authentifizierung des Nutzers erfordert.**[<=]**

A_26134 -Authenticator-Modul für Desktop-Plattformen: Authentifizierungsmittel eGK+PIN
Der Hersteller eines sektoralen IDP MUSS für sein Authenticator-Modul für Desktop-Plattformen ein Authentifizierungsverfahren mittels eGK und PIN über Kartenleser unterstützen.**[<=]**

A_26135 -Authenticator-Modul für Desktop-Plattformen: Unterstützung von Kartenlesern ab Sicherheitsklasse 2
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS es dem Nutzer ermöglichen, für eine Authentifizierung mit eGK+PIN einen Kartenleser einer

höheren Sicherheitsklasse als Sicherheitsklasse 1 (Sicherheitsklasse 2 oder höher) zu nutzen.**[<=]**

A_26136 -Authenticator-Modul für Desktop-Plattformen: Hinweis bei Kartenlesern der Sicherheitsklasse 1
Falls das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen mit einem Kartenleser der Sicherheitsklasse 1 genutzt wird, MUSS das Authenticator-Modul für Desktop-Plattformen den Nutzer in einer für den Nutzer verständlichen Form darauf hinzuweisen:

- dass Kartenleser der Sicherheitsklasse 1 geringere Sicherheitsleistungen als Kartenleser der Sicherheitsklassen 2 oder 3 erbringen und welche handelsüblichen Kartenleser der Sicherheitsklassen 2 und 3 vom Nutzer für Desktop-Plattformen genutzt werden könnten,
- welche Risiken bei einer Nutzung von Kartenlesern der Sicherheitsklasse 1 für den Nutzer bestehen und welche Maßnahmen der Versicherte auf seinem Gerät treffen sollte, um diese Risiken zu verringern.

Das Authenticator-Modul für Desktop-Plattformen MUSS es dem Nutzer ermöglichen, auf die Anzeige des Hinweises bei einer zukünftigen Nutzung des Kartenlesers der Sicherheitsklasse 1 zu verzichten, sofern der Nutzer dies explizit bestätigt und die Bestätigung so gestaltet ist, das eine versehentliche Bestätigung vermieden wird. **[<=]**

Hinweis: Nutzer müssen vor dem entstehenden Risiko in für sie verständlicher Form gewarnt werden.

A_26137 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 1: PIN-Eingabe
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS, wenn ein Kartenterminal der Sicherheitsklasse 1 verwendet wird, die PIN-/PUK-Eingabe über ein angeschlossenes Eingabegerät entgegennehmen und in ein an die Karte adressiertes Kommando einbetten.**[<=]**

A_26138 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 1: PIN-Eingabe Geheimnis
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen DARF die eingegebene PIN/PUK-Ziffernfolge NICHT im Klartext auf dem Bildschirm darstellen, wenn ein Kartenterminal der Sicherheitsklasse 1 verwendet wird.**[<=]**

A_26139 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 1: PIN-Eingabe Eingabefeedback
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS ein eingegebenes Zeichen einer Geheimniseingabe mit dem Zeichen "*" (Wildcard) quittieren, wenn ein Kartenterminal der Sicherheitsklasse 1 verwendet wird.**[<=]**

A_26140 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 1: PIN-Eingabe Validierung
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS, wenn das PIN-Geheimnis durch einen Anwendungsfall geändert werden soll und wenn ein Kartenterminal der Sicherheitsklasse 1 verwendet wird, ein eingegebenes, neues PIN-Geheimnis durch eine erneute Abfrage des neuen PIN-Geheimnisses verifizieren.**[<=]**

A_26141 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 2: PIN-Eingabe
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS ein angeschlossenes Kartenterminal der Sicherheitsklasse 2 so ansteuern, dass ein Kartenkommando, das eine PIN-/PUK-Eingabe erfordert, an einem Kartenterminal um die Benutzereingabe ergänzt und anschließend direkt an die adressierte Karte weitergeleitet wird.**[<=]**

A_26143 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 2: PIN-Eingabe Eingabefeedback
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS während der Abfrage einer PIN/PUK an einem Kartenterminal der Sicherheitsklasse 2 einen Benutzerhinweis zur PIN-Eingabe auf der Bildschirmanzeige des Kartenterminals ausgeben.**[<=]**

A_26144 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 3: PIN-Eingabe
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS ein angeschlossenes Kartenterminal der Sicherheitsklasse 3 so ansteuern, dass ein Kartenkommando, das eine PIN-/PUK-Eingabe erfordert, an einem Kartenterminal um die Benutzereingabe ergänzt und anschließend direkt an die adressierte Karte weitergeleitet wird.**[<=]**

A_26146 -Authenticator-Modul für Desktop-Plattformen: Kartenterminal der Sicherheitsklasse 3: PIN-Eingabe Eingabefeedback
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen MUSS während der Abfrage einer PIN/PUK an einem Kartenterminal der Sicherheitsklasse 3 einen Benutzerhinweis zur PIN-Eingabe am Display des Kartenterminals ausgeben.**[<=]**

A_27501 -Authenticator-Modul für Desktop-Plattformen: Verpflichtende Verfahren zur Identifikation von Nutzern
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen KANN abweichend von A_22865* nur eGK und PIN zur Nutzerauthentisierung anbieten, wenn vom Nutzer ausschließlich eine Authentifizierung für Desktop-Plattformen verwendet wird.**[<=]**

A_27502 -Authenticator-Modul für Desktop-Plattformen: weitere Authentifizierungsverfahren
Das Authenticator-Modul eines sektoralen IDP für Desktop-Plattformen KANN weitere Authentifizierungsverfahren unterstützen. Insbesondere KANN der sektoralen IDP die Authentifizierung des Nutzers mit seinem Authenticator-Modul auf dem Smartphone des Nutzers unterstützen (2-Geräte-Flow).**[<=]**

A_27503 -Authenticator-Modul für Desktop-Plattformen: Auskunft an Versicherte
Der Hersteller eines sektoralen IDP KANN abweichend zu A_22236* auf die Bereitstellung der Auskunft an die Versicherten verzichten, wenn Versicherte sich ausschließlich über das Authenticator-Modul für Desktop-Plattformen mit eGK und PIN authentisieren und keine GesundheitsID im sektoralen IDP persistent angelegt wird.**[<=]**

6 Anhang A – Verzeichnisse

6.1 Abkürzungen

Kürzel	Erläuterung
ACR	Authentication Context Class Reference
AVS	Apothekenverwaltungssystem (ein Primärsystem)
IDP	Identity Provider
JWT	JSON Web Token
KVS	Krankenhausverwaltungssystem (ein Primärsystem)
mTLS	mutual TLS
OAuth 2	Open Authorization 2.0
OIDC	OpenID Connect
OP	OpenID Provider
PAR	Pushed Authorization Request
PKCE	Proof Key for Code Exchange
PVS	Praxisverwaltungssystem (ein Primärsystem)
sektoraler IDP KTR	Sektoraler Identity Provider Kostenträger
SGB	Sozialgesetzbuch
TI	Telematikinfrastruktur
VAU	Vertrauenswürdige Ausführungsumgebung

6.2 Glossar

Das Glossar wird als eigenständiges Dokument (vgl. [gemGlossar]) zur Verfügung gestellt.

6.3 Abbildungsverzeichnis

Abbildung 1: Schnittstellen der in der VAU laufenden Komponente des sektoralen IDP...15
Abbildung 2: Systemkontext Authenticator-Modul....53
Abbildung 3 : Überblick....57
Abbildung 4: Aktivitätsdiagramm "PIN der eGK ändern"....63
Abbildung 5: Aktivitätsdiagramm "PIN der eGK entsperren"....66
Abbildung 6: 3.2.6 Umsetzungsempfehlungen für die Vertrauenswürdige Ausführungsumgebung....76

6.4 Tabellenverzeichnis

Tabelle 1: Vorgaben für die im sektoralen IDP befindlichen Endpunkte zur Ausführung in einer VAU....15
Tabelle 2: Header des Entity Statement des sektoralen IDP....25
Tabelle 3 : *Allgemeine Attribute im well-known-Dokument des sektoralen IDP*....25
Tabelle 4 : Attribute des Metadatenblocks openid_provider im well-known-Dokument des sektoralen IDP....26
Tabelle 5 : Durch einen sektoralen IDP unterstütze TI-Features....29
Tabelle 6: Scope und Claims....35
Tabelle 7: Codierung der Authentisierungsverfahren....41
Tabelle 8: Übersicht Gerätebindung....46
Tabelle 9: Biometrie....48
Tabelle 10: Schema Datentyp "Device_Type"....55
Tabelle 11: TAB_FdV_156 – PIN der eGK ändern....61
Tabelle 12: TAB_FdV_157 – Ablaufaktivitäten – PIN der eGK ändern....61
Tabelle 13: TAB_FdV_158 – PIN der eGK entsperren....64
Tabelle 14: TAB_FdV_159 – Ablaufaktivitäten – PIN der eGK entsperren....64

6.5 Referenzierte Dokumente

6.5.1 Dokumente der gematik

Die nachfolgende Tabelle enthält die Bezeichnung der in dem vorliegenden Dokument referenzierten Dokumente der gematik zur TI.

[Quelle]	Herausgeber: Titel
[gemGlossar]	gematik - Glossar der Telematikinfrastruktur

[gemSpec_Krypt]	gematik - Übergreifende Spezifikation Verwendung kryptographischer Algorithmen in der Telematikinfrastruktur https://gemspec.gematik.de/docs/gemSpec/gemSpec_Krypt/
[gemSpec_PKI]	gematik - Übergreifende Spezifikation PKI https://gemspec.gematik.de/docs/gemSpec/gemSpec_PKI/
[gemSpec_IDP_FedMaster]	gematik -Spezifikation Federation Master https://gemspec.gematik.de/docs/gemSpec/gemSpec_IDP_FedMaster/
[gemSpec_IDP_Dienst]	gematik - Spezifikation Identity Provider-Dienst https://gemspec.gematik.de/docs/gemSpec/gemSpec_IDP_Dienst/
[gemSpec_IDP_FD]	gematik - Spezifikation Identity Provider – Nutzungsspezifikation für Fachdienste
[gemSpec_IDP_Frontend]	gematik - Spezifikation Identity Provider - Frontend https://gemspec.gematik.de/docs/gemSpec/gemSpec_IDP_Frontend/
[gemSpec_OM]	gematik - Übergreifende Spezifikation Operations und Maintenance https://gemspec.gematik.de/docs/gemSpec/gemSpec_OM/
[gemSpec_SST_LD_BD]	gematik - Spezifikation Logdaten- und Betriebsdatenerfassung https://gemspec.gematik.de/docs/gemSpec/gemSpec_SST_LD_BD/
[gemKPT_Test]	gematik - Testkonzept der TI https://gemspec.gematik.de/docs/gemKPT/gemKPT_Test/
[Zulässigkeit von Identifikationsverfahren]	Festlegung der gematik bzgl. der Zulässigkeit von Identifikationsverfahren für das Level of Assurance (LoA) gematik-ehealth-loa-high https://fachportal.gematik.de/schnelleinstieg/smartcards-und-identitaeten-in-der-ti/identitaeten

6.5.2 Weitere Dokumente

[Quelle]	Herausgeber (Erscheinungsdatum): Titel
[ANDROIDAPPLINKS]	https://developer.android.com/studio/write/app-link-indexing
[APPLEUNIVERSAL]	https://developer.apple.com/ios/universal-links/
Verordnung (EU) Nr.	VERORDNUNG (EU) Nr. 910/2014 DES EUROPÄISCHEN

910/2014 auch eIDAS Verordnung genannt	PARLAMENTS UND DES RATES vom 23. Juli 2014 über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt und zur Aufhebung der Richtlinie 1999/93/EG
Durchführungsverordnung (EU) 2015/1502	DURCHFÜHRUNGSVERORDNUNG (EU) 2015/1502 DER KOMMISSION vom 8. September 2015 zur Festlegung von Mindestanforderungen an technische Spezifikationen und Verfahren für Sicherheitsniveaus elektronischer Identifizierungsmittel gemäß Artikel 8 Absatz 3 der Verordnung (EU) Nr. 910/2014 des Europäischen Parlaments und des Rates über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt
[GKV-SV Richtlinie "Kontakt mit Versicherten"]	Richtlinie des GKV-Spitzenverbandes zu Maßnahmen zum Schutz von Sozialdaten der Versicherten vor unbefugter Kenntnisnahme nach § 217f Absatz 4b SGB V (GKV-SV Richtlinie Kontakt mit Versicherten) vom 14.12.2018
[OpenID Connect Core 1.0]	OpenID Connect Core 1.0 (OpenID Connect Core 1.0 incorporating errata set 2) https://openid.net/specs/openid-connect-core-1_0.html
[OpenID Federation 1.1]	OpenID Federation1.0 (5. Mai 2026) https://openid.net/specs/openid-federation-1_1.html
[OpenID Connect Discovery 1.0]	OpenID Connect Discovery 1.0 (incorporating errata set 2, 15. Dezember 2023) https://openid.net/specs/openid-connect-discovery-1_0.html
[OpenID Connect Native SSO for Mobile Apps 1.0]	OpenID Connect Native SSO for Mobile Apps 1.0 - draft 03 (Juli 2019) https://openid.net/specs/openid-connect-native-sso-1_0.html
[RFC746]	The SUPDUP Graphics Extension https://datatracker.ietf.org/doc/html/rfc746
[RFC2119]	Key words for use in RFCs to Indicate Requirement Levels https://www.rfc-editor.org/rfc/rfc2119.html
[RFC3986]	Uniform Resource Identifier (URI): Generic Syntax (Januar 2005) https://datatracker.ietf.org/doc/html/rfc3986
[RFC6749]	The OAuth 2.0 Authorization Framework (Oktober 2012) https://datatracker.ietf.org/doc/html/rfc6749
[RFC7231]	Hypertext Transfer Protocol (HTTP/1.1): Semantics and Content (Juni 2014) https://datatracker.ietf.org/doc/html/rfc7231
[RFC7517]	JSON Web Key (JWK) (Mai 2015) https://www.rfc-editor.org/rfc/rfc7517

[RFC7519]	JSON Web Token (JWT) (Mai 2015) https://datatracker.ietf.org/doc/html/rfc7519
[RFC7636]	Proof Key for Code Exchange by OAuth Public Clients (September 2015) https://datatracker.ietf.org/doc/html/rfc7636
[RFC8252]	Auth 2.0 for Native Apps (Oktober 2017) https://datatracker.ietf.org/doc/html/rfc8252
[RFC9126]	OAuth 2.0 Pushed Authorization Requests (September 2021) https://datatracker.ietf.org/doc/html/rfc9126
[RFC9396]	OAuth 2.0 Rich Authorization Requests https://datatracker.ietf.org/doc/rfc9396/
[ISO18045]	Publicly Available Standards (iso.org)
[TR-03107-1]	Technische Richtlinie TR-03107-1 Version 1.1.1, 07.05.2019 https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.pdf;jsessionid=FFBC05B6EE23EE8461127AC755D621FC.internet461?__blob=publicationFile&v=1
[KeyInfo#getSecurityLevel()]	https://developer.android.com/reference/android/security/keystore/KeyInfo#getSecurityLevel()
[KeyInfo#isInsideSecureHardware()]	https://developer.android.com/reference/android/security/keystore/KeyInfo#isInsideSecureHardware()
[support.apple.com/guide/security]	https://support.apple.com/de-de/guide/security/sec59b0b31ff/web
[DiGA-Kriterien]	Datenschutzkriterien nach § 139e Absatz 11 SGB V und § 78a Absatz 8 SGB XI https://www.bfarm.de/DE/Medizinprodukte/Aufgaben/DiGA-und-DiPA/Datenschutzkriterien/_node.html
[OWASP Top Ten]	OWASP Top Ten https://owasp.org/www-project-top-ten/
[CAB-Forum]	CA/Browser Forum https://cabforum.org/

7 Anhang B - Abläufe

Abläufe und Beispiele sind in gemKPT_TI-Föderation dokumentiert.

8 Anhang C - Möglicher Aufbau einer VAU (informativ)

Anhang C trägt informativen Charakter und stellt Möglichkeiten zum Aufbau einer Vertrauenswürdigen Ausführungsumgebung VAU vor. Die Standalone-Lösung [8.1-Standalone] orientiert sich in weiten Teilen an der Umsetzung der VAU wie es aktuell erfolgreich für das E-Rezept im Einsatz ist. Im Kapitel 8.2 soll perspektivisch ein Umsetzungsvorschlag einer VAU für eine Cloudinfrastruktur erstellt werden. Hier sind allerdings noch grundlegende Vorarbeiten notwendig.

Der Schutzbedarf der durch den sektoralen IDP verarbeiteten Daten und der Zugriff auf personenbezogene medizinische Daten der durch ihn ermöglicht wird erfordert einen spezifischen Systemaufbau des Dienstes, durch den ein unberechtigter Zugriff auf diese Daten nicht nur über das Internet, sondern auch aus dem Betriebsumfeld des Betreibers (z. B. durch einen oder mehrere Mitarbeiter des Betreibers), technisch ausgeschlossen wird.

Der Systemaufbau des sektoralen IDP ist darüber hinaus dadurch bestimmt, dass die Verfügbarkeit des Dienstes für einzelne Mandanten (Kostenträger) erhalten bleiben muss, auch wenn die Verfügbarkeit für andere Mandanten z. B. durch unerwartet hohe Aktivität eingeschränkt wird.

Zum Ausschluss von Software-Manipulationen muss das ausführende System für den Verarbeitungskontext der VAU attestiert werden. Es wird davon ausgegangen, dass die in der VAU eingesetzte Software im Rahmen der Zulassung und anschließend mit jeder Änderung durch unabhängige Begutachtung abgesichert ist. Bekannte Software-Stände werden registriert und damit attestierbar. Die Systeme bieten Hardware-basierte Unterstützung für die authentifizierbare Messung aller geladenen Software (Firmware, Bootloader, OS, Anwendungssoftware, Enklaven-Software) und lassen sich auf der Grundlage so ermittelter Messungen attestieren. Die Attestation als Teil des Boot-Vorgangs und als Voraussetzung zur Erlangung einer gültigen Service-Identität stellt damit sicher, dass nur aktuelle und geprüfte Systeme von Nutzern angesprochen werden können.

Die Nutzung von Technologien wie Intel SGX dient der Verkleinerung der Angriffsfläche gegen die Software durch Hardware-basierte Mechanismen, z. B. zur individuellen Verschlüsselung des Arbeitsspeichers eines Prozesses, um Angriffe abzuwehren, die aus einer fehlerbehafteten Speicherverwaltung resultieren können. Leider decken diese Mechanismen nicht alle denkbaren Angriffe gegen den geschützt ausgeführten Code zuverlässig ab. Es werden immer wieder neue Side Channel Angriffe entdeckt, die aus dem Kontext des Betriebssystems auch gegen Enklaven eingesetzt werden könnten. Daher wird auch sämtliche Software außerhalb der Enklave in den Attestationsprozess eingebunden, sodass zur Laufzeit kein Angriffscode eingeschleust werden kann. Dies reduziert den für die Erkennung von möglichen Schwachstellen erforderlichen Aufwand im Rahmen der Begutachtung.

8.1 Standalone

Der Betreiber des sektoralen IDP stellt pro Instanz eine dedizierte Hardware-Umgebung zur Ausführung des Dienstes bereit. Empfehlungen der gematik zum Aufbau dieser Instanzen sind im Folgenden beschrieben.

Eine Instanz besteht aus:

1. einem Load Balancer, der die Rolle der in [4.3- API-Endpunkte des sektoralen IDP], festgelegten Eingangspunkte erfüllt:
   - Endpunkt für Pushed Authorization Requests
   - Endpunkt für Authorization Request
   - Token-Endpunkt
   - Endpunkt für Datensynchronisation mit Bestandssystem
2. einer Konfiguration von Servern, die eine Vertrauenswürdige Ausführungsumgebung gemäß [3.2- Vertrauenswürdige Ausführungsumgebung] bilden – dies umfasst ein HSM für die Attestation der Server und die Handhabung des privaten Schlüssels der Identität der VAU - und
3. einem Datenbanksystem zur Aufnahme sämtlicher persistenter Daten der Anwendung in verschlüsselter Form.

Der Betreiber des sektoralen IDP wird sämtliche Systeme unterbrechungsfrei mit Strom versorgen.

Die folgende Abbildung zeigt den Aufbau einer Instanz der sektoralen IDP im Überblick:

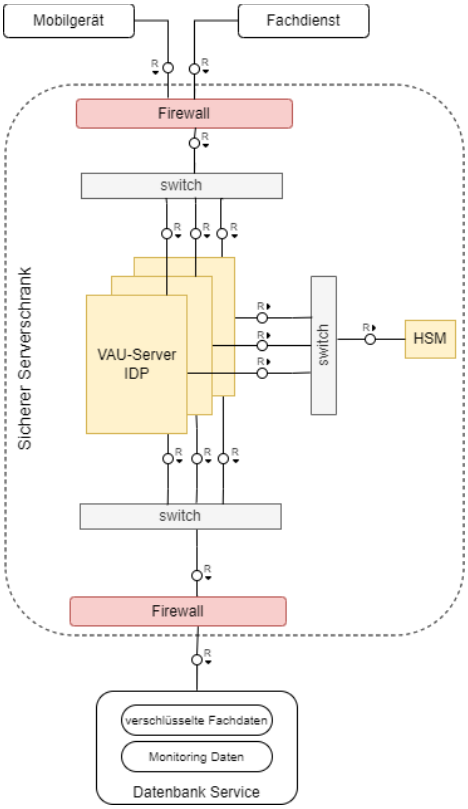


Abbildung 6: 3.2.6 Umsetzungsempfehlungen für die Vertrauenswürdige Ausführungsumgebung

8.1.1 Load Balancer

Der Anbieter des sektoralen IDP realisiert die Netzanbindung der Server-Systeme des sektoralen IDP über einen Load Balancer mit folgenden Geräte- und Konfigurationseigenschaften:

- Netzanbindung: Der Load Balancer verfügt über öffentlich adressierbaren IP-Adressen. Die Anzahl der jeweils konfigurierten IP-Adressen ist so gewählt, dass die maximale Anzahl gleichzeitiger Client-Verbindungen, die sich aus dem angegebenen Mengengerüst ableitet, ermöglicht wird.
- Abwehr von DDoS-Angriffen: Der Load Balancer kann in die Abwehr von DDoS-Angriffen eingebunden sein (z. B. für die Abwehr von Syn-Flooding) und als Teil einer umfassenden (vorgelagerten) Infrastruktur zur Abwehr solcher Angriffe an der Limitierung von Netzverkehr mitwirken bzw. zur Angriffserkennung Meldungen über ungültige Aufrufe an die vorgelagerte Abwehr-Infrastruktur senden.
- Protokollierung: Der Load Balancer protokolliert alle für die Überwachung seines betrieblichen Zustands durch den Anbieter erforderlichen Daten.
- Stromversorgung: Der Load Balancer ist mit einer zweifach redundanten Stromversorgung ausgestattet.

8.1.2 Anwendungsserver und zugehörige Infrastruktur

Dem Schutzbedarf der im sektoralen IDP unverschlüsselt verarbeiteten Daten wird durch den Einsatz einer Vertrauenswürdigen Ausführungsumgebung (VAU) gemäß [3.2-Vertrauenswürdige Ausführungsumgebung], Rechnung getragen. Das in diesem Abschnitt beschriebene Subsystem des sektoralen IDP stellt die vertrauenswürdige Ausführungsumgebung dar.
Der Anbieter des sektoralen IDP stellt sämtliche Anwendungsserver auf denen die fachliche Logik des sektoralen IDP ausgeführt wird (VAU-Server), das HSM zur Attestation dieser Anwendungsserver und zur Bereitstellung und Anwendung des privaten Schlüssels der Dienstidentität des sektoralen IDP sowie sämtliche Komponenten zur Vernetzung der VAU-Server und des HSM in einem oder mehreren Serverschränken (VAU-Serverschränken) bereit. Ein VAU-Serverschrank ist ein Serverschrank der Schutzklasse WK 4, der zusätzlich mit folgenden Sicherheitsvorkehrungen ausgestattet ist:

- einer Abschirmung gegen elektromagnetische Abstrahlung insoweit diese geeignet ist, Daten aus der Verarbeitung innerhalb des Serverschranks von außerhalb des Serverschranks zu extrahieren,
- einem verstärkten Türschloss zur gegenüber Schutzklasse WK 4 verbesserten Abwehr bzw. Verzögerung von Versuchen zum gewaltsamen Eindringen in den Schrank,
- einem Türsensor, der im Falle eines unautorisierten Öffnens der Schranktür die Stromzufuhr aller im Schrank verbauten Systeme sofort unterbricht,
- einem Mechanismus zur Alarmierung bei unautorisierter Öffnung sowie
- ein Zugang von Mitarbeitern des Anbieters des sektoralen IDP zum Schrank kann nicht unkontrolliert erfolgen.
  Der Anbieter des sektoralen IDP richtet die VAU-Serverschränke so ein, dass mehrere Gruppen von VAU-Servern verfügbar sind, wie im Folgenden beschrieben.
  Jede Gruppe von VAU-Servern besteht aus mindestens 2 physisch separaten VAU-Servern. Die Anzahl der VAU-Server für jede Gruppe wird darüber hinaus durch die Lastanforderungen (für die jeweilige Gruppe) bestimmt. Die verschiedenen Gruppen von VAU-Servern sind jeweils verschiedenen Mandanten des sektoralen IDP zugeordnet.

- Die physische Trennung der VAU-Server dient der Sicherstellung der Verfügbarkeit des sektoralen IDP für die verschiedenen Mandanten im Falle einer (z. B. überlastbedingten) Einschränkung der Verfügbarkeit des sektoralen IDP.

8.1.3 Vernetzung Load-Balancer/VAU-Server

Der Anbieter des sektoralen IDP vernetzt die VAU-Server mit dem Load Balancer wie im Folgenden beschrieben:
Die Zuführung der Netzwerkverbindungen für Zugriffe aus dem Internet zu den VAU-Servern erfolgt über den Load Balancer und von diesem ausgehend über einen Switch und eine Firewall (Eingangs-Switch, bei mehreren VAU-Serverschränken Eingangs-Switches und Firewalls) innerhalb des VAU-Serverschranks. Der Eingangs-Switch, die Firewall und die VAU-Server sind so konfiguriert, dass jede der VAU-Servergruppen ein eigenes Subnetz bildet, dass VAU-Server keine Netzverbindungen untereinander aufbauen können und dass sämtlicher nicht vorgesehener Netzverkehr blockiert wird.
Den VAU-Servern sind die für die Anwendungsfunktionalität erforderlichen mandantenspezifischen URLs zugeordnet. Der Load Balancer ist so konfiguriert, dass er die Verteilung der Requests auf die VAU-Server aufgrund der URLs der Requests vornehmen kann. Der Load Balancer ist weiterhin so konfiguriert, dass er die Verteilung der Requests auf die einzelnen VAU-Server im Round-Robin-Verfahren vornehmen kann.

8.1.4 Vernetzung VAU-Server/HSM

Der Anbieter des sektoralen IDP vernetzt die VAU-Server mit dem HSM im VAU-Serverschrank wie im Folgenden beschrieben:
Alle VAU-Server sind individuell (über ein zweites Netzwerk-Interface der VAU-Server und einen zweiten Switch (HSM-Switch) innerhalb des VAU-Serverschranks) mit dem HSM vernetzt. Diese Vernetzung innerhalb des VAU-Serverschranks darf physisch und logisch nur VAU-Server und das HSM umfassen.
Falls mehr als ein VAU-Serverschrank für eine Instanz des sektoralen IDP erforderlich ist, darf ein einzelnes HSM in nur einem der VAU-Serverschränke von VAU-Servern in den weiteren VAU-Serverschränken mit genutzt werden. In diesem Fall muss die Vernetzung zwischen den Serverschränken als eine Switch-zu-Switch-Verbindung zwischen den dedizierten VAU-Server/HSM Netzen in den einzelnen VAU-Serverschränken ausgeführt sein. Der physische Aufbau der VAU-Serverschränke muss es dabei ausschließen, dass das Verbindungkabel von außerhalb der VAU-Serverschränke manipulierbar ist.
Der HSM-Switch (bei mehreren VAU-Serverschränken die HSM-Switches) und die VAU-Server sind so konfiguriert, dass VAU-Server keine Netzverbindungen untereinander aufbauen können.

8.1.5 Vernetzung VAU-Server/Datenbankserver

Der Anbieter des sektoralen IDP vernetzt die VAU-Server mit der außerhalb der VAU betriebenen Datenbank wie im Folgenden beschrieben:
Alle VAU-Server sind über ein drittes Netzwerk-Interface der VAU-Server und einen dritten Switch (Ausgangs-Switch) und eine Firewall innerhalb des VAU-Serverschranks mit dem Datenbankserver vernetzt.
Der Ausgangs-Switch und die Firewall (bei mehreren VAU-Serverschränken die Ausgangs-Switches und die Firewalls) und die VAU-Server sind so konfiguriert, dass VAU-Server keine Netzverbindungen untereinander aufbauen können und sämtlicher nicht vorgesehene Netzverkehr blockiert wird.

8.1.6 Vernetzung des Management Interface mit dem internen Netz des Anbieters des sektoralen IDP

Der Anbieter des sektoralen IDP stattet alle VAU-Serverschränke mit einem Management Interface mit niedriger Bandbreite (56kbps) aus, dass alle VAU-Server sowie das HSM erreichbar macht und nur die zwingend notwendigen betrieblichen Steuerungsmöglichkeiten zur Abfrage des elementaren Betriebszustands und für einen Start, Neustart sowie das kontrollierte Herunterfahren der Systeme anbietet.

8.1.7 VAU-Server

Die VAU-Server bilden den Kern der Vertrauenswürdigen Ausführungsumgebung. Neben ihrer grundsätzlichen Eignung als Anwendungsserver im Rechenzentrumsbetrieb, müssen VAU-Server zur Vertrauenswürdigkeit der Datenverarbeitung im sektoralen IDP beitragen. Der Anbieter des sektoralen IDP wird VAU-Server einsetzen, die folgende Sicherheitseigenschaften aufweisen:

- Ein VAU-Server ist frei von Komponenten zur persistenten Speicherung von Daten mit Ausnahme der Firmware (Diskless Server).
- Ein VAU-Server verfügt über einen Boot Loader, der Boot Images über das Netzwerk laden und ihre Signatur gegen ein vorgegebenes, d. h. manipulationssicher konfiguriertes, Zertifikat prüfen kann.
- Ein VAU-Server unterstützt Measured Boot über die gesamte geladene Software sowie über sämtliche sicherheitsrelevanten Plattform-Konfigurationswerte (z. B. mittels eines TPM-Moduls).
- Ein VAU-Server unterstützt Remote Attestation in einer Form, die keine regelmäßige (d. h. bei jedem Systemstart notwendige) Einbindung von Diensten des Herstellers erfordert (z. B. dadurch, dass ein Sealing möglich ist, oder dass eine Attestation unabhängig von Diensten des Herstellers umgesetzt werden kann).
- Ein VAU-Server bietet Hardware-Unterstützung für die Speicherverwaltung (MMU und IOMMU) und die benötigten kryptographischen Primitiven.
  Der Einsatz des Boot Loaders mit Signaturprüfung der Boot Images dient primär dazu, das Laden ungeprüfter Softwarekomponenten zu verhindern, während die Attestation zur Sicherstellung der Integrität der Gesamtheit aus geprüfter Software und Systemkonfiguration dient.

8.1.8 VAU-Server Software Stack

Der Anbieter des sektoralen IDP wird die Software auf den VAU-Servern darauf auslegen, die Sicherheitsziele für die Server zu erreichen, indem der Software Stack (d. h. die Gesamtheit aller auf den Servern geladenen Software) minimalistisch ausgelegt ist (Minimal Trusted Computing Base). Die Software ist gehärtet und bietet einen robusten Mechanismus zur Separation, mittels dessen verschiedene Aspekte der Verarbeitung auf den VAU-Servern gegeneinander isoliert werden.
Der Anbieter des sektoralen IDP nutzt den Separationsmechanismus mindestens dazu, die System Management Funktionen zur Steuerung des Systems durch den Betreiber von der Verarbeitung der schützenswerten Daten zu trennen. Darüber hinaus soll der Anbieter des sektoralen IDP über den Separationsmechanismus eine Partitionierung umsetzen, die potenziell angreifbare Treiber und Protokolle von der Verarbeitung der schützenswerten Daten isoliert sowie die an die einzelnen Hardware-Netzwerkschnittstellen gebundenen Netzwerkfunktionen voneinander und vom Rest der Software trennt. Die Separation soll zudem dazu genutzt werden, die verschiedenen Funktionsmodule zur Ausführung der

Fachlogik voneinander zu trennen. Zu beachten ist, dass trotz der Separationsmechanismen die Attestation der gesamten geladenen Software erfolgen muss.
Die Separation der einzelnen fachlichen Verarbeitungsvorgänge (Requests) innerhalb eines Funktionsmoduls voneinander kann der Anbieter des sektoralen IDP auf der Ebene der Anwendungssoftware umsetzen. Die Anwendungssoftware gehört zur Trusted Computing Base der VAU. Ihre Sicherheits- und insbesondere ihre Separationseigenschaften müssen sicherheitstechnisch bewertbar sein.

8.1.9 Open Source Software Stack

Die Vertrauenswürdigkeit der VAU soll dadurch untermauert werden, dass VAU-Server im Rahmen des Machbaren für die Öffentlichkeit transparente Systeme darstellen. Interessierte Personen oder Organisationen müssen – die notwendige Fachkenntnis vorausgesetzt – anhand öffentlich verfügbarer Informationen in der Lage sein, im Detail nachzuvollziehen, wie die Systeme aufgebaut sind und funktionieren. Diese Nachvollziehbarkeit soll dadurch erreicht werden, dass es dem Anbieter des sektoralen IDP auferlegt wird, eine geeignete Auswahl für die technische Basis der VAU-Server zu treffen, um zu erreichen, dass die Softwarekomponenten der VAU-Server möglichst weitgehend öffentlich im Quellcode offengelegt sind.
Der offengelegte Quellcode ist fortlaufend auf dem Stand des produktiven Systems zu halten. Bei Änderungen an der Software in der Produktionsumgebung ist die öffentliche Dokumentation des Quellcodes unverzüglich zu aktualisieren.
Für alle Teile der Software der VAU, deren Quellcode nicht öffentlich gemacht werden kann, ist der zum jeweiligen Zeitpunkt gegebene binäre Stand dieser Software zu veröffentlichen.

8.1.10 Attestation und Integritätsschutz für VAU-Server

Der Anbieter des sektoralen IDP stattet die VAU-Server mit der Fähigkeit zur Remote Attestation auf der Basis der beim Booten des Systems und beim Laden sämtlicher Software gemessenen Werte und einer Signatur des TPM aus. Die Attestation erfolgt gegenüber dem im VAU-Serverschrank integrierten HSM.
Zur Gewährleistung der Wirksamkeit des durch die Remote Attestation gegenüber dem HSM gegebenen Integritätsschutzes für die Laufzeitumgebung der VAU-Server wird der Anbieter des sektoralen IDP die Software für die VAU-Server im Rahmen des technisch Machbaren so gestalten, dass sich VAU-Server nach vollständigem Abschluss des Boot- und Ladevorgangs die Rechte für ein Nachladen von Software selbst entziehen.

8.1.11 HSM

Der Anbieter des sektoralen IDP integriert ein netzwerkfähiges HSM in den VAU-Serverschrank. Das HSM stellt drei systemspezifische Schnittstellen bereit, nämlich:

1. die Schnittstelle zur Remote Attestation von VAU-Servern,
2. eine Schnittstelle zur Nutzung der kryptographischen Identität der VAU für die Terminierung von TLS Verbindungen sowie
3. eine Schnittstelle zur Nutzung der Signaturfunktion auf Basis des privaten Schlüssels der kryptographischen Identität des sektoralen Identity Providers.

Darüber hinaus bietet das HSM eine Management-Schnittstelle zur Einrichtung des HSM im Rahmen einer Zeremonie und zur Einbringung gültiger Referenzwerte für die Attestation der VAU-Server sowie zur Handhabung des privaten Schlüssels der VAU-Identität.

Die Management-Schnittstelle des HSM wird über das Management Interface des VAU-Serverschranks über Netz verfügbar gemacht.
Das HSM macht die Schnittstellen 2 und 3 nur erfolgreich attestierten VAU-Servern über eine TLS-Verbindung verfügbar.

8.1.12 Datenbank

Der Anbieter des sektoralen IDP stellt ein Datenbanksystem außerhalb der VAU bereit, in das alle verschlüsselten Identitätsdaten gespeichert werden und dass diese Daten über alle Instanzen des sektoralen IDP synchronisiert.
Die Synchronisation von Änderungen muss unmittelbar erfolgen und innerhalb von 500 ms abgeschlossen sein. Eine Spiegelung der Daten mit noch geringerer Latenz ist aufgrund der Architektur des sektoralen IDP nicht erforderlich.
Das Datenbanksystem stellt für die VAU-Server eine REST-Schnittstelle bereit, über die alle benötigten Datenbanktransaktionen abgebildet werden können.
Der Anbieter des sektoralen IDP wird seine Wahl eines Datenbanksystems sowie dessen wesentliche Eigenschaften hinsichtlich Dimensionierung, Synchronisation der Datenbestände und Integration in seine Systems Management Prozesse im Umsetzungskonzept darlegen.

8.1.13 Repository

Der Anbieter des sektoralen IDP stellt ein Repository außerhalb der VAU bereit, aus dem die VAU-Server ihre Boot Images beziehen können. Die Schnittstelle des Repository richtet sich nach den Anforderungen des Bootloaders.
Das Repository muss ausreichend geschützt sein, um Ausfälle des sektoralen IDP durch fehlerhafte Boot Images auszuschließen.
Der Anbieter des sektoralen IDP wird sich mit der gematik über einen geeigneten Prozess zur kontrollierten Einbringung signierter Boot Images verständigen. Dort gibt es bereits etablierte Prozesse auch zu Remote Sitzungenfür Schlüsselzeremonien und HSM Interaktionen. Dergematik fällt in diesem Prozess die Rolle des Signers der Boot Images zu.

9 Anhang D - Verfahrensbeschreibung zur Migration nicht abwärtskompatibler Änderungen in der TI-Föderation

Nicht abwärtskompatible Änderungen in der TI-Föderation betreffen oft alle Teilnehmer der TI-Föderation. Eine zeitgleiche Produktivsetzung solcher Änderungen (Big Bang) ist sehr risikoreich und unrealistisch. Es ist notwendig, solche Änderungen über eine Zeitspanne (Übergangszeit) durchführen zu können, ohne dass die Funktion der beteiligten Systeme beeinträchtigt wird.

Analog zum Vorgehen in der Softwareentwicklung ist es notwendig, abzulösende Artefakte als "deprecated" oder "befristet" zu markieren. Jedem nutzenden Teilnehmer wird so signalisiert, dass die Unterstützung für dieses Artefakt zeitlich begrenzt und eine Umstellung auf aktuellere Versionen notwendig ist.

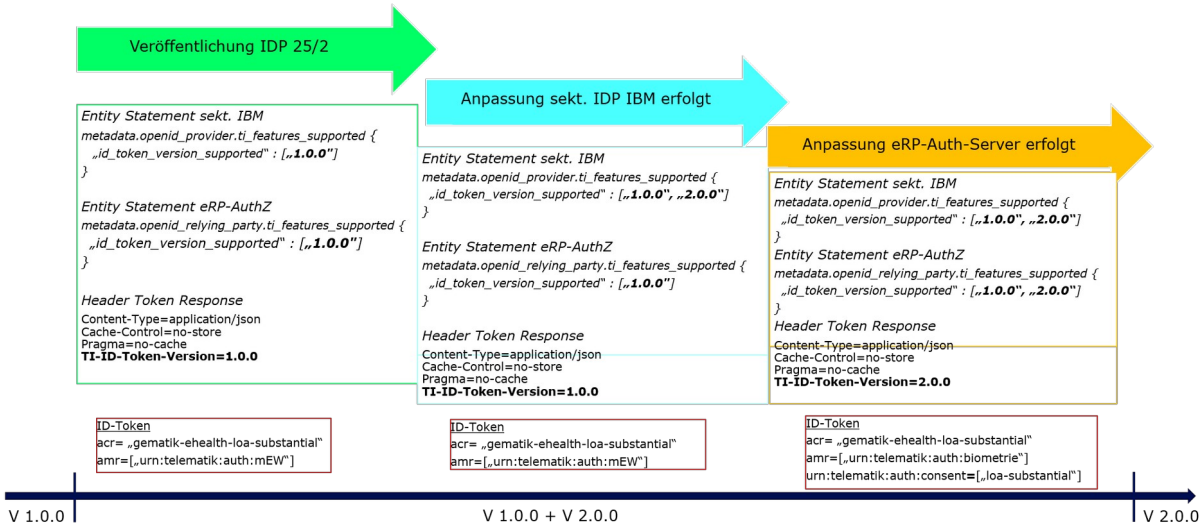
Für die Umsetzung dieses Ansatzes sind folgende Schritte notwendig:

Schritt	Beschreibung	Beteiligte
Spezifikationsanpassung	• Spezifikation der neuen Anforderungen • Markieren der abzulösenden Anforderungen als "Befristet gültig" mit Informationen zu den Alternativen. Die Markierung kann als Hinweistext unter die abzulösende Anforderung und/oder in der Anforderungsbeschreibung erfolgen Beispiel: *A_23207-02 - (Befristet) Single-Sign-On (SSO) als Authentifizierungsverfahren ..... [<=]* *Hinweis: Die Anforderung gilt noch befristet bis zur vollständigen Umsetzung der Anforderungen A_27591, A_27592 und A_27593 durch alle Teilnehmer der TI-Föderation.* • Die Festlegung der Syntax für die Eintragungen im Entity Statement erfolgt in der Spezifikation des Entity Statement	gematik
Signalisierung supporteter Versionen im Entity Statement	Die Teilnehmer der TI-Föderation signalisieren in ihrem Entity Statement, welche Versionen sie unterstützen. 1. Nach Spezifikationsveröffentlichung signalisieren sie die Unterstützung der abzulösenden Version Beispiel: *metadata.openid_relying_party.ti_features_supported { „id_token_version_supported“ : ["1.0.0"],*	TI-Teilnehmer

	} 2. Nach Implementierungsanpassung signalisieren sie die Unterstützung der abzulösenden und der neuen Version Beispiel: *metadata.openid_relying_party.ti_features_supported {* *„id_token_version_supported“ : ["1.0.0", "2.0.0"],* *}* 3. Nach Ablauf der Anpassungsfrist signalisieren sie die Unterstützung der neuen Version Beispiel: *metadata.openid_relying_party.ti_features_supported {* *„id_token_version_supported“ : ["2.0.0"],* *}*	
Implementierung	• Anpassung der Implementierung an die neuen Anforderungen • Aufrechterhaltung der Implementierung an die abgelösten Anforderungen • Signalisierung des Implementierungsfortschritts im Entity Statement • IOP-Tests mit abhängigen TI-Teilnehmern	TI-Teilnehmer
Bereinigung	Nach Ablauf des Übergangszeitraums (bzw. Abschluss der notwendigen Anpassungen bei den TI-Teilnehmern) muss eine Bereinigung erfolgen. • Spezifikationsbereinigung - Der Ausbau der befristet gültigen Anforderungen hat keine Auswirkungen auf die Hersteller und Betreiber • Implementierung - Der Ausbau der abgelösten Version kann unabhängig von anderen TI-Teilnehmern nach Ablösung der befristet gültigen Version individuell durch jeden Teilnehmer erfolgen	gematik TI-Teilnehmer

Beispiel - nicht abwärtskompatible Änderung des ID Token

Ein sektoraler IDP hat vor einem Fachdienst umgestellt



Ein Fachdienst hat vor einem sektoralen IDP umgestellt

